

报告编号:密评 20240041-1

新点电子交易平台 商用密码应用安全性评估报告

被测单位:

苏州国泰新点软件有限公司

密评机构:

北京市产品质量监督检验研究院

报告时间:

2024 年 12 月 05 日

声 明

本报告是新点电子交易平台的商用密码应用安全性评估报告，报告模板为 2023 年版。

本报告评估结论的有效性建立在被测单位提供相关证据的真实性基础之上。

本报告中给出的评估结论仅对被测信息系统当时的安全状态有效。被测信息系统发生变更后，应重新对其进行评估，本报告不再适用。

本报告中给出的评估结论不能作为对被测信息系统内部署的相关系统构成组件（或产品）的评估结论。

在任何情况下，若需引用本报告中的评估结果或结论都应保持其原有的意义，不得对相关内容擅自进行增加、修改和伪造或掩盖事实。

北京市产品质量监督检验研究院



（盖章）

2024 年 12 月 05 日

被测信息系统基本信息表

被测单位				
单位名称	苏州国泰新点软件有限公司			
单位地址	江苏省苏州市张家港市江帆路 8 号	邮政编码	215600	
所属省部密码管理部门	江苏省国家密码管理局			
联系人	姓名	严汉青	职务/职称	产品管理工程师
	所属部门	产品管理部	办公电话	0512-58188000-5708
	移动电话	18962285722	电子邮件	yanhanqing@epoint.com.cn
被测信息系统				
系统名称	新点电子交易平台			
是否为关键信息基础设施	☐ 已认定，所属安全保护工作部门：_____ ☒ 未认定			
网络安全等级保护定级和备案情况	☐ 已定级备案，第 ____ 级（一至四），S A G 备案证明编号：_____ 本次被测信息系统与等级保护定级系统是否一致： ☐ 是 ☐ 否，变化情况说明：_____ ☒ 未定级，本次密评依据 GB/T 39786—2021《信息安全技术 信息系统密码应用基本要求》第三级（一至四）信息系统要求			
网络安全等级测评情况	☐ 已测评 测评机构名称：_____ 测评时间：_____ 测评结论：_____		☐ 正在测评 测评机构名称：_____ ☒ 未测评	
系统服务情况	服务范围	☒ 全国 ☐ 跨省（区、市）跨 ____ 个 ☐ 全省（区、市） ☐ 跨地（市、区）跨 ____ 个 ☐ 地（市、区）内 ☐ 其他 _____		
	服务领域	☐ 电信 ☐ 广电 ☐ 经营性公众互联网 ☐ 铁路 ☐ 银行 ☐ 海关 ☐ 税务 ☐ 民航 ☐ 电力 ☐ 证券 ☐ 保险 ☐ 国防科技工业 ☐ 公安 ☐ 财政 ☐ 人事劳动和社会保障 ☐ 审计 ☒ 商业贸易 ☐ 国土资源 ☐ 能源 ☐ 交通 ☐ 统计 ☐ 工商行政管理 ☐ 邮政 ☐ 教育 ☐ 文化 ☐ 卫生 ☐ 农业 ☐ 水利 ☐ 外交 ☐ 发展改革 ☐ 科技 ☐ 宣传 ☐ 质量监督检验检疫 ☐ 其他 _____		
	服务对象	☒ 单位内部人员 ☐ 社会公众人员 ☐ 两者均包括 ☐ 其他 _____		
系统网络平台	覆盖范围	☒ 局域网 ☐ 城域网 ☐ 广域网 ☐ 其他 _____		
	网络性质	☐ 业务专网 ☒ 互联网 ☐ 其他 _____		

系统服务用户数量	5000		
系统是否已投入运行	☐ 是, 投入运行时间: _____ 年 ____ 月 ☒ 否, 目前情况: 待密评通过后上线运行		
系统互联情况	☐ 与其他行业系统连接 ☐ 与本行业其他单位系统连接 ☐ 与本单位其他系统连接 ☒ 其他独立运行 互联系统名称: _____		
系统是否依赖不在本系统范围内的云平台运行	☐ 是, 云平台名称: _____ ☒ 否	☐ 云平台已评估 ☐ 云平台正在评估 ☐ 云平台未评估 密评机构名称: _____ 评估时间: _____ 评估结论: _____	
系统是否具有密码应用方案	☒ 有密码应用方案, 且通过密评, 通过时间: _____ 密评方式: ☐ 自行评估 ☒ 委托密评机构评估, 密评机构名称: 北京市产品质量监督检验研究院 ☐ 有密码应用方案, 但未通过评审 ☐ 无密码应用方案		
系统使用的密码产品情况	☒ 系统使用的密码产品 5 (台/套), 独立使用 5 (台/套), 共享使用 (台/套); 其中, 取得认证证书的产品数量 5 (台/套), 未取得认证证书的国内产品数量 (台/套), 国外产品数量 0 (台/套)。 ☐ 系统未使用密码产品		
系统使用的密码算法	分组算法: ☐ SM1 ☒ SM4 ☐ SM7 ☒ AES ☐ DES ☐ 3DES ☐ 其他 非对称算法: ☒ SM2 ☐ SM9 ☐ RSA1024 ☒ RSA2048 ☒ 其他 RSA4096 杂凑算法: ☒ SM3 ☐ SHA-1 ☒ SHA-256 ☐ SHA-384 ☐ SHA-512 ☐ MD5 ☐ 其他 序列算法: ☐ ZUC ☐ 其他 其他算法: ECDHE		
单位名称	北京市产品质量监督检验研究院		
通信地址	北京市东城区永定门内大街	邮政编码	100062
联系人	姓名	戴晓婧	项目负责人
	所属部门	软件与信息安全测评部	办公电话
	移动电话	15652613540	电子邮件
审核批准	编制人	戴晓婧	编制日期
	审核人	赵光年	审核日期
	批准人	刘雅峰	批准日期

商用密码应用安全性评估结论

系统名称	新点电子交易平台		
系统简介	新点电子交易平台部署于江苏省苏州市张家港市沙洲湖科技创新园新点数据中心机房，系统采用 B/S 架构，使用中间件进行应用发布，以数据库为载体存储系统业务信息，新点电子交易平台为各方交易主体提供在线交易过程，对交易过程资料进行存档备案，收集、发布公共资源交易信息，对交易数据进行汇总分析，为交易活动提供信息交互和技术共享服务，建立和维护各类交易主体信用信息数据库，推进交易信息交互共享。		
测评情况简介	受苏州国泰新点软件有限公司委托，北京市产品质量监督检验研究院于 2024 年 10 月 8 日至 2024 年 12 月 5 日对新点电子交易平台进行了商用密码应用安全性评估工作。 测评准备和方案编制工作于 2024 年 10 月 8 日至 10 月 11 日进行。 现场测评工作于 2024 年 10 月 28 日至 10 月 30 日进行，测评范围包括物理和环境安全、网络和通信安全、设备和计算安全、应用和数据安全、管理制度、人员管理、建设运行和应急处置等方面。 报告编制活动于 2024 年 10 月 31 日至 12 月 5 日进行，通过单元测评结果汇总分析、整体测评、总体安全状况分析，得出评估结论，形成评估报告。		
评估结论	基本符合	综合得分	67.96
不适用项数目 /总测评指标 项数目	3/41	高风险项数目	0

总体评价

本次信息系统商用密码应用安全性评估依据 GB/T 39786-2021《信息安全技术 信息系统密码应用基本要求》的第3级别要求,选取的测评指标总数为41项,其中不适用项为3项,特殊指标0项。测评结果为:符合项22项,部分符合项12项,不符合项4项。在被测信息系统存在的安全问题中:高风险项0项,中风险项17项,低风险项0项。

1. 在物理和环境安全方面,机房进出人员需经过IC卡刷卡,现场人工身份核对,专人陪同方式进入机房,通过上述手段以保证机房进出人员身份的真实性,未采用密码技术对进入机房人员进行身份鉴别。未使用密码技术保证电子门禁系统进出记录数据的存储完整性。未使用密码技术保证视频监控音像记录数据的存储完整性。

测评结果:符合项0项,部分符合项0项,不符合项3项,不适用项0项。

2. 在网络和通信安全方面,办公内网国密浏览器与综合安全网关之间的通信信道及办公内网运维客户端与综合安全网关之间的通信信道,使用服务端证书进行身份鉴别,保证通信实体的真实性,使用国密通信协议保证通信数据机密性与完整性,使用综合安全网关进行网络边界的访问控制,通过密码产品自身的安全机制保证访问控制信息的完整性。互联网公众用户与新点电子交易平台之间的通信信道,使用服务端证书进行身份鉴别,证书使用了AES_256_GCM算法,能够保证网络通信实体的真实性,通信过程中采用TLS协议,能够保证数据在通信过程的机密性和完整性,但未使用商用密码算法。

测评结果:符合项0项,部分符合项4项,不符合项0项,不适用项1项。

3. 在设备和计算安全方面,被测部分密码产品使用证书进行身份鉴别,证书存储在智能密码钥匙中,能够保证登录用户身份的真实性,使用的密码算法经国家密码管理部门认可,使用的密码产品获得了商用密码产品认证证书,达到了密码产品二级安全要求,服务器、数据库使用用户名/口令对登录的用户进行身份鉴别,未使用密码技术保证用户身份的真实性。综合安全网关、服务器、数据库时使用了TLCP、SSH协议进行通信,能够保证远程管理过程中数据传输的安全性。所有被测密码产品使用密码产品自身的安全机制,保证系统资源访问控制信息的

完整性,日志记录完整性及重要可执行程序完整性、重要可执行程序来源真实性,服务器、数据库未使用密码技术保护系统资源访问控制信息的完整性,日志记录完整性及重要可执行程序完整性、重要可执行程序来源真实性。

测评结果：符合项 0 项，部分符合项 5 项，不符合项 0 项，不适用项 1 项。

4. 在应用和数据安全方面,应用系统使用证书或用户名/口令/进行身份鉴别。通过手机验证码对用户名/口令问题进行一定程度上的弥补,使用服务器密码机对重要数据按照其安全需求进行了签名和加密,保证了应用系统访问控制信息的完整性及重要数据存储的完整性和机密性。鉴别数据(数字证书)存储在对应密码产品中,使用密码产品的安全机制保证数据存储的机密性和完整性。未使用密码技术保证重要数据在传输过程中的机密性和完整性,但在网络层使用综合安全网关构建了基于国密算法的 SSL VPN 综合安全网关通信信道,可以在一定程度上弥补该问题。应用系统的关键操作使用操作人员证书对操作日志及相关数据进行签名,通过电子签章系统及时间戳服务器保证关键行为的不可否认性。

测评结果：符合项 4 项，部分符合项 2 项，不符合项 1 项，不适用项 1 项。

5. 在管理制度方面,建立了安全管理制度体系,规范密码安全管理制度,对密码安全组织的工作管理、安全体系的运作管理、安全风险管、项目建设安全管理、运行维护安全管理等进行要求,具备已通过评估的密码应用方案,建立了密钥管理规则。安全管理制度评审和修订工作每年开展。明确了管理制度的发布流程并进行版本控制。记录了密码应用操作规程的执行情况。

测评结果：符合项 6 项，部分符合项 0 项，不符合项 0 项，不适用项 0 项。

6. 在人员管理方面,密钥管理和密码管理相关人员了解并遵守密码相关法律法规和密码管理制度。明确规定各岗位职责。目前已设立密钥管理员、安全审计员等管理员岗位,规定了每年组织至少一次培训,规定每年对密钥管理人员、安全审计人员、密码操作人员和其他相关人员组织一次考核。建立了关键人员保密制度和调离制度,要求关键岗位人员签署保密协议。

测评结果：符合项 5 项，部分符合项 0 项，不符合项 0 项，不适用项 0 项。

7. 在建设运行方面,制定了密码应用方案且经过评审。依据密码应用方案制定密钥安全管理策略,具备实施方案,被测系统目前处于试运行阶段,评估通过

后系统才能正式上线运行。规定了定期开展安全性评估，明确了演习步骤，但未提供攻防对抗演习报告。

测评结果：符合项 4 项，部分符合项 1 项，不符合项 0 项，不适用项 0 项。

8. 在应急处置方面，明确了应急事件处理流程及其他管理措施，做好了应急资源准备。发现的密码应用安全事故及时向密码应用安全工作小组报告，密码应用安全工作小组接到故障申报后，初步判定故障的严重程度、影响范围，重大密码应用安全事件需要上报密码应用安全领导小组，同时按信息系统应急预案处理故障。事件处置完成后向信息系统主管部门及归属的密码管理部门报告事件发生情况及处置情况。

测评结果：符合项 3 项，部分符合项 0 项，不符合项 0 项，不适用项 0 项。

通过对新点电子交易平台的物理和环境安全、网络和通信安全、设备和计算安全、应用和数据安全、管理制度、人员管理、建设运行和应急处置等方面的测评，该系统基本符合 GB/T 39786-2021《信息安全技术 信息系统密码应用基本要求》的第 3 级别要求。



安全问题及改进建议

本次信息系统商用密码应用安全性评估依据 GB/T 39786-2021《信息安全技术 信息系统密码应用基本要求》的第 3 级别要求，发现被测信息系统存在以下安全问题。建议被测信息系统根据实际情况和以下给出的建议进行整改。

一、物理和环境安全

(1) 未采用密码技术进行物理访问身份鉴别，不能保证机房进入人员身份的真实性。(国泰新点中心机房)

改进建议：建议使用遵循 GM/T 0036-2014《采用非接触卡的门禁系统密码应用技术指南》的电子门禁系统，电子门禁系统可以采用基于国产密码算法 SM7 的非接触逻辑加密卡方案或基于国产密码算法 SM1/SM4 的非接触 CPU 卡方案，采用国家密码管理部门指定的 SM1 分组加密算法进行密钥分散，实现一卡一密；采用 SM7 或 SM4 分组加密算法进行门禁卡与门禁读卡器之间的身份鉴别。

(2) 未使用密码技术保证电子门禁系统进出记录数据的存储完整性。(国泰新点中心机房)

改进建议：建议选择合适的密码产品（如智能密码钥匙、服务器密码机等），采用 MAC 或数字签名等技术对电子门禁系统进出记录进行完整性保护。

(3) 未使用密码技术保证视频监控音像记录数据的存储完整性。(国泰新点中心机房)

改进建议：建议采用专用设备（如服务器密码机、加密存储设备、视频加密系统等），采用 MAC 或数字签名等技术对视频监控系统音像记录进行完整性保护。

二、网络和通信安全

(1) 身份鉴别机制采用非商用密码算法。(互联网公众用户与新点电子交易平台之间的通信信道)

改进建议：建议身份鉴别机制采用商用密码算法。

(2) 通信过程中完整性保护机制采用非商用密码算法。(互联网公众用户与新点电子交易平台之间的通信信道)

改进建议：建议通信过程中完整性保护机制采用商用密码算法。

(3) 通信过程中机密性保护机制采用非商用密码算法。(互联网公众用户与

新点电子交易平台之间的通信信道)

改进建议：建议通信过程中机密性保护机制采用商用密码算法。

(4) 未采用密码技术保证网络边界访问控制信息的完整性。(互联网公众用户与新点电子交易平台之间的通信信道)

改进建议：建议采用密码技术保证网络边界访问控制信息的完整性。

三、设备和计算安全

(1) 未使用密码技术保证用户身份的真实性。(数据库、应用服务器、数据库服务器、电子签章服务器、新点电子签章系统)

改进建议：建议使用密码技术保证用户身份的真实性。

(2) 远程管理通道采用非商用密码算法。(数据库、应用服务器、数据库服务器、电子签章服务器)

改进建议：建议在远程管理设备时，利用商用密码算法建立安全的信息传输通道。

(3) 远程管理设备时，未采用密码技术建立安全的信息传输通道。(服务器密码机、签名验签服务器、时间戳服务器、新点电子签章系统)

改进建议：建议在远程管理设备时，未采用密码技术建立安全的信息传输通道。

(4) 未使用密码技术保证访问控制信息的完整性。(数据库、应用服务器、数据库服务器、电子签章服务器)

改进建议：建议使用密码技术保证访问控制信息的完整性。

(5) 未使用密码技术保证日志记录的完整性。(数据库、应用服务器、数据库服务器、电子签章服务器)

改进建议：建议使用密码技术保证日志记录的完整性。

(6) 未使用密码技术保证重要可执行程序的完整性和来源的真实性。(数据库、应用服务器、数据库服务器、电子签章服务器)

改进建议：建议使用密码技术保证重要可执行程序的完整性和来源的真实性。

四、应用和数据安全

(1) 未使用密码技术保证用户身份的真实性。(公众用户)

改进建议：建议使用密码技术保证用户身份的真实性。

（2）未使用密码技术保证数据在传输过程中的机密性。（个人信息数据）

改进建议：建议使用密码技术保证数据在传输过程中的机密性。

（3）未使用密码技术保护数据在传输过程中的机密性。（业务数据、鉴别数据（非数字证书））

改进建议：建议使用密码技术保护数据在传输过程中的机密性。

（4）未使用密码技术保护数据在传输过程中的机密性。（个人信息数据、业务数据、鉴别数据（非数字证书））

改进建议：建议使用密码技术保护数据在传输过程中的机密性。

五、建设运行

（1）未提供攻防对抗演习报告。（建设运行）

改进建议：建议严格执行既定的密码应用安全管理制度，定期开展密码应用安全性评估及攻防对抗演习，并存留记录。

目录

声 明.....	I
被测信息系统基本信息表.....	I
商用密码应用安全性评估结论.....	I
总体评价.....	I
安全问题及改进建议.....	I
1 测评项目概述.....	1
1.1 测评目的.....	1
1.2 测评依据.....	1
1.2.1 依据标准和规范.....	1
1.2.2 参考标准和规范.....	1
1.2.3 术语和缩略语.....	2
1.3 测评过程.....	2
1.3.1 测评准备阶段.....	3
1.3.2 方案编制阶段.....	4
1.3.3 现场测评阶段.....	4
1.3.4 分析与报告编制阶段.....	5
1.4 报告分发范围.....	5
2 被测系统情况.....	6
2.1 承载的业务情况.....	6
2.2 网络拓扑图及描述.....	6
2.3 密码应用情况.....	7
2.3.1 网络和通信安全密码应用情况.....	7
2.3.2 设备和计算安全密码应用情况.....	7
2.3.3 应用和数据安全密码应用情况.....	8
2.4 系统资产.....	8
2.4.1 物理环境.....	8
2.4.2 物理安防设施.....	8

2.4.3	密码产品	8
2.4.4	服务器/存储设备	9
2.4.5	网络及安全设备	9
2.4.6	数据库管理系统	10
2.4.7	关键业务应用	10
2.4.8	重要数据	11
2.4.9	安全管理文档	11
2.4.10	人员	12
2.5	密码服务	12
2.6	安全威胁	12
2.7	前次测评情况	13
3	测评范围与方法	14
3.1	测评指标	14
3.1.1	基本指标	14
3.1.2	特殊指标	17
3.1.3	不适用指标	18
3.2	测评方法及工具	18
3.2.1	现场测评方法	18
3.2.2	测评工具	19
3.2.3	测评工具检查点	19
3.3	测评对象和对应测评方式	21
3.3.1	测评对象确定方法	21
3.3.2	测评对象确定结果	21
4	单元测评	25
4.1	密码技术应用要求	25
4.1.1	物理和环境安全	25
4.1.2	网络和通信安全	26
4.1.3	设备和计算安全	28

4.1.4	应用和数据安全	30
4.2	安全管理	33
4.2.1	管理制度	33
4.2.2	人员管理	34
4.2.3	建设运行	36
4.2.4	应急处置	37
5	整体测评	39
5.1	测评结果修正	39
5.2	整体测评结果和量化评估	39
6	风险分析	43
7	评估结论	48
附录 A	测评结果记录	1
A. 1.	物理和环境安全	1
A. 2.	网络和通信安全	2
A. 3.	设备和计算安全	18
A. 4.	应用和数据安全	38
A. 5.	管理制度	69
A. 6.	人员管理	70
A. 7.	建设运行	72
A. 8.	应急处置	73
附录 B	密评活动有效性证明记录	1
B. 1.	密评委托证明	1
B. 2.	进场记录	2
B. 3.	密评活动质量文件	5
B. 4.	密评人员资格证明	8
B. 5.	系统定级匹配证明	11

1 测评项目概述

1.1 测评目的

北京市产品质量监督检验研究院受苏州国泰新点软件有限公司的委托，于2024年10月8日至2024年12月5日，依据GB/T 39786-2021《信息安全技术 信息系统密码应用基本要求》的第3级别要求，对苏州国泰新点软件有限公司的新点电子交易平台从物理和环境安全、网络和通信安全、设备和计算安全、应用和数据安全、管理制度、人员管理、建设运行和应急处置等方面进行商用密码应用安全性评估，通过测评项目的实施，根据被测信息系统当前的安全状况，给出测评结果并提出改进建议，以确保被测信息系统达到GB/T 39786-2021《信息安全技术 信息系统密码应用基本要求》的要求，也为其信息资产安全和业务持续稳定运行提供保障。

1.2 测评依据

1.2.1 依据标准和规范

GB/T 39786-2021《信息安全技术 信息系统密码应用基本要求》

GB/T 43206-2023《信息安全技术 信息系统密码应用测评要求》

GM/T 0116-2021《信息系统密码应用测评过程指南》

《信息系统密码应用高风险判定指引》

《商用密码应用安全性评估量化评估规则》

《商用密码应用安全性评估FAQ（第三版）》

《新点电子交易平台密码应用方案》

1.2.2 参考标准和规范

GM/T 0005-2012《随机性检测规范》

GM/T 0022-2023《IPSec VPN技术规范》

GM/T 0023-2023《IPSec VPN网关产品规范》

GM/T 0024-2023《SSL VPN技术规范》

GM/T 0025-2023《SSL VPN网关产品规范》

GM/T 0026-2023《安全认证网关产品规范》

GM/T 0030-2014《服务器密码机技术规范》

GM/T 0037-2014《证书认证系统检测规范》

GM/T 0038-2014《证书认证密钥管理系统检测规范》

GB/T 38629-2020《信息安全技术 签名验签服务器技术规范》

GB/T 20518-2018《信息安全技术 公钥基础设施 数字证书格式规范》

1.2.3 术语和缩略语

无。

1.3 测评过程

商用密码应用安全性评估过程分为四个基本测评活动：测评准备活动、方案编制活动、现场测评活动、分析与报告编制活动。测评双方之间的沟通与洽谈贯穿整个商用密码应用安全性评估过程。测评工作流程如图 1-1 所示。

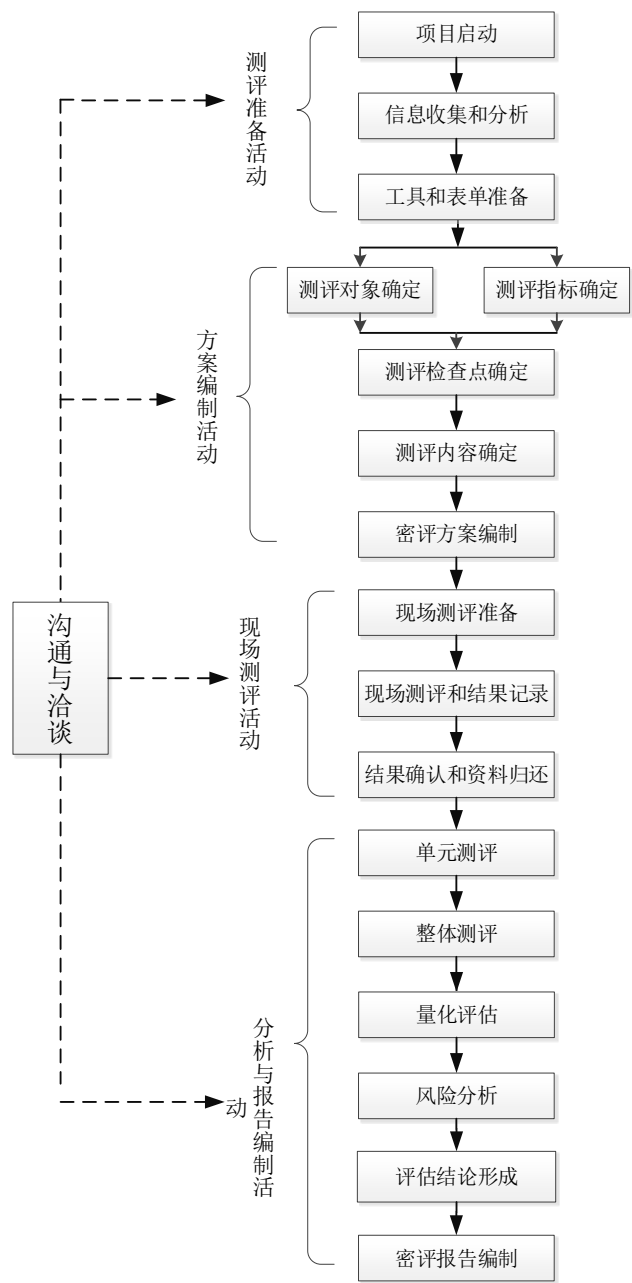


图 1-1 测评工作流程

1.3.1 测评准备阶段

根据测评双方签订的委托测评协议书和被测信息系统规模，密评机构组建测评项目组，从人员方面做好准备，并编制项目计划书。密评机构通过查阅被测系统已有资料并使用调查表格的方式，了解整个系统的构成和密码保护情况，为编写密评方案和开展现场测评工作奠定基础。测评项目组成员在进行现场测评之前，熟悉与被测信息系统相关的各种组件、调试测评工具、准备各种表单等。

测评准备阶段时间：2024 年 10 月 8 日 - 2024 年 10 月 9 日。

测评项目组成员如表 1-1 所示：

表 1-1 测评项目组成员

角色	姓名	任务分工	是否通过密评人员考核
项目负责人	戴晓婧	项目管理、报告编写、技术测评	是
测评项目组成员	段昱延	管理测评	是

1.3.2 方案编制阶段

根据已经了解到的被测信息系统情况，分析整个被测系统及其涉及的业务应用系统，以及与此相关的密码应用情况，确定出本次测评的测评对象；根据已经了解到的被测系统定级结果，确定出本次测评的测评指标；确认测评过程中需要现场检查的关键安全点，并且充分考虑到检查的可行性和风险，最大限度的避免对被测系统，尤其是在线运行业务系统的影响；确定现场测评的具体实施内容；最终完成测评方案的编制。

方案编制阶段时间：2024 年 10 月 10 日 - 2024 年 10 月 11 日。

1.3.3 现场测评阶段

现场测评准备：召开测评现场首次会，密评机构介绍测评工作，交流测评信息，进一步明确测评计划和测评方案中的内容，说明测评过程中具体的实施工作内容，测评时间安排，测评过程中可能存在的安全风险等，以便于后面的测评工作开展。测评双方确认现场测评需要的各种资源，包括被测单位的配合人员和需要提供的测评条件等，确认被测信息系统已备份过系统及数据。被测单位签署现场测评授权书。密评人员根据会议沟通结果，对测评结果记录表单和测评程序进行必要的更新。

测评项目组根据密评方案以及现场测评准备的结果，安排密评人员在现场完成测评工作，汇总现场测评的测评记录；召开测评现场结束会，测评双方对测评过程中发现的问题进行现场确认；密评机构归还测评过程中借阅的所有文档资料，并由被测单位文档资料提供者签字确认。

现场测评阶段时间：2024 年 10 月 28 日 - 2024 年 10 月 30 日。

1.3.4 分析与报告编制阶段

在现场测评工作结束后，密评机构对现场测评获得的测评结果进行汇总分析，形成评估结论，并编制评估报告。

密评人员在初步判定各测评单元涉及的各个测评对象的测评结果后，还需进行单元测评、整体测评、量化评估和风险分析。经过整体测评后，有的测评对象的测评结果可能会有所变化，需进一步修订测评结果，而后进行量化评估和风险分析，最后形成评估结论。

分析与报告编制阶段时间：2024 年 10 月 31 日 - 2024 年 12 月 5 日。

1.4 报告分发范围

本报告一式 3 份，1 份提交给被测单位所属省部密码管理部门，1 份提交被测单位，1 份由密评机构留存。

2 被测系统情况

2.1 承载的业务情况

新点电子交易平台为各方交易主体提供在线交易过程，对交易过程资料进行存档备案，收集、发布公共资源交易信息，对交易数据进行汇总分析，为交易活动提供信息交互和技术共享服务，建立和维护各类交易主体信用信息数据库，推进交易信息交互共享。

新点电子交易平台在日常的运行和管理过程中，系统在用户身份鉴别，重要数据传输的机密性和完整性、重要数据存储的机密性和完整性、关键操作不可否认性方面都需要利用密码技术进行保护，密码应用需求包括如下内容：

1、身份鉴别需求：对机房、设备管理、登录应用系统的用户进行身份标识和身份鉴别，保证用户身份的真实性。

2、重要数据安全传输需求：保证用户鉴别数据、业务数据等关键信息在传输过程中的机密性，保证用户鉴别数据、业务数据、日志数据等关键信息在传输过程中的完整性。

3、重要数据安全存储需求：保证用户鉴别数据、业务数据等关键信息在存储过程中的机密性，保证用户鉴别数据、业务数据、日志数据等关键信息在存储过程中的完整性。

4、不可否认性需求：保证关键操作行为的不可否认性。

2.2 网络拓扑图及描述

新点电子交易平台部署于江苏省苏州市张家港市沙洲湖科技创新园新点数据中心机房。整体网络可分为边界防护区、安全管理服务区、应用服务区、办公终端区、密码服务区、核心交换区。边界防护区负责实现对外部网络的链接功能，包括边界防护、入侵防御、远程管理所需 VPN 服务等。核心交换区提供数据交换与安全接入认证。应用服务区提供新点电子交易平台需要的服务器，支撑业务运行。安全管理区主要提供安管平台、安全配置检查，保证新点电子交易平台的安全运行。密码服务区部署了服务器密码机、签名验签服务器、时间戳服务器、电子签章系统，为新点电子交易平台提供数据的机密性保护、完整性保护以及关键

操作行为的不可否认性。

被测系统的网络结构示意图如图 2-1 所示：

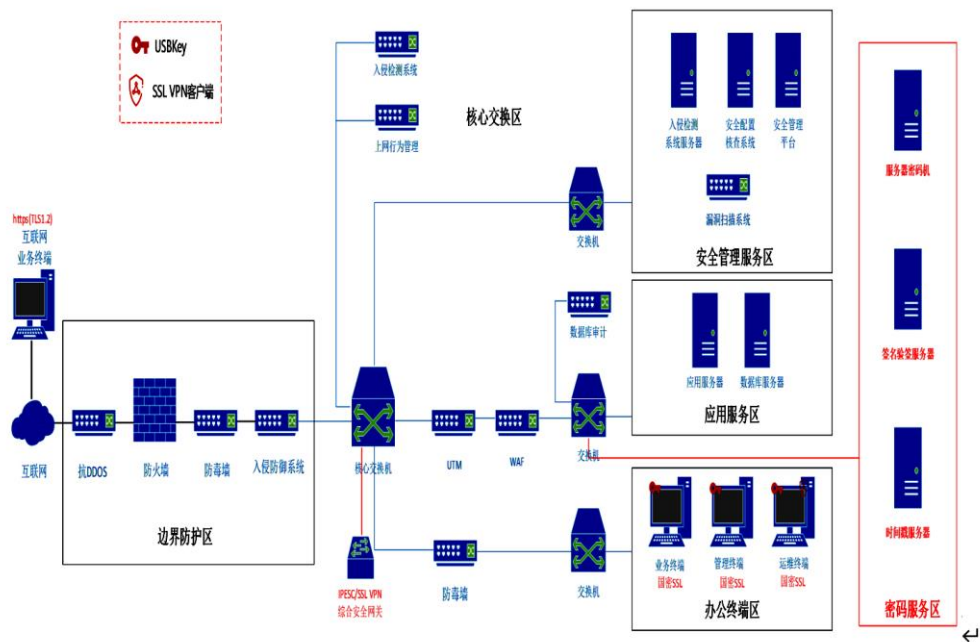


图 2-1 被测系统网络拓扑图

2.3 密码应用情况

2.3.1 网络和通信安全密码应用情况

网络和通信安全层面，办公内网国密浏览器与综合安全网关之间的通信信道，办公内网运维客户端与综合安全网关之间通信信道、互联网公众用户与电子交易平台之间通信信道全部通过服务端证书进行身份鉴别。所有信道采用 TLCP 协议或 HTTPS 协议进行传输，能够保证数据在通信过程中完整性和机密性。

2.3.2 设备和计算安全密码应用情况

设备和计算安全层面，综合安全网关、服务器密码机、时间戳服务器、签名验签服务器使用证书对登录设备的用户进行身份鉴别，证书由中金金融认证中心有限公司签发，存储在智能密码钥匙和设备中，对综合安全网关使用基于国密算法的 TLCP 协议建立了安全的数据传输通道，对服务器、数据库进行远程管理时，使用了 SSH、SSL 协议建立了安全的数据传输通道。

2.3.3 应用和数据安全密码应用情况

应用和数据安全层面，业务用户访问应用系统使用证书进行身份鉴别，证书由中金金融认证中心有限公司签发，存储在智能密码钥匙中。鉴别信息（非数字证书）、个人信息数据、业务数据通过 SM4 算法进行加密后存储在数据库中，用于保证数据存储过程中的机密性，系统访问控制策略配置数据、日志数据通过 SM2、SM3 算法的数字签名技术对数据进行签名后，将签名值存储在数据库中，用于保证数据在存储过程中的完整性，签名过程在服务器密码机中完成，使用的密钥存储在服务器密码机中。

2.4 系统资产

2.4.1 物理环境

表 2-1 物理环境

序号	物理环境名称	物理位置	重要程度
1	国泰新点中心机房	苏州市张家港市沙洲湖科技创新园	关键

2.4.2 物理安防设施

表 2-2 物理安防设施

序号	产品名称	生产厂商和型号	所在物理环境名称	重要程度
1	综合安防管理平台	海康威视 V1.5.100	国泰新点中心机房	关键

2.4.3 密码产品

表 2-3 密码产品

序号	产品名称	生产厂商	商密产品 认证证书 编号	使用的密 码算法	数量	用途
1	服务器 密码机	渔翁信 息	GM0037110 20231016	SM2、 SM3、SM4	1	数据加解密
2	签名验签 服务器	渔翁信 息	GM0037111 20210128	SM2、 SM3、SM4	1	签名验签

序号	产品名称	生产厂商	商密产品 认证证书 编号	使用的密 码算法	数量	用途
3	综合安全 网关	渔翁信 息	GM0037199 20201754	SM2、 SM3、SM4	1	安全接入
4	时间戳 服务器	渔翁信 息	GM0037112 20210159	SM2、 SM3、SM4	1	时间戳
5	国密浏览器	360	GM0011128 20240111	SM2、 SM3、SM4	50	安全浏览
6	智能密码 钥匙	渔翁信 息	GM0037101 20220721	SM2、 SM3、SM4	50	身份鉴别
7	新点电子 签章系统	国泰新 点股份 有限公 司	GM0032115 20202072	SM2、 SM3、SM4	1	签章服务

2.4.4 服务器/存储设备

表 2-4 服务器/存储设备

序号	设备名称	生产厂商	型号	操作系 统版本	是否为虚 拟设备	用途	数 量	重要 程度
1	应用 服务器	-	-	CentOS 7.6	否	应用部 署	1	关键
2	数据库 服务器	-	-	CentOS 7.6	是	数据库 部署	1	关键
3	签章 服务器	-	-	CentOS 7.6	是	签章系 统部署	1	关键

2.4.5 网络及安全设备

表 2-5 网络及安全设备

序号	设备名称	生产厂商	型号	用途	数量	重要 程度
1	防火墙	启明星辰	USG-FW-3680DP	边界防护	1	关键
2	WAF 防火墙	深信服	WAF-1000-FA40	应用防护	1	关键
3	抗 DDOS	启明星辰	ADM-DETECTOR- D3500N	边界防护	1	关键

序号	设备名称	生产厂商	型号	用途	数量	重要程度
4	入侵检测系统	启明星辰	NT16000-CS-L-PLUS	边界防护	1	关键
5	上网行为管理	深信服	AC-1000-B1300-LV	安全管理	1	关键
6	漏洞扫描	安恒	DAS-RAS-Q128	安全管理	1	关键
7	数据库审计	安恒	DAS-A270	安全管理		关键
8	安全管理平台	启明星辰	TSOC-BSM2200	安全管理	1	关键
9	交换机	锐捷	S5024PV2-EI	数据交换	4	关键
10	接入交换机	H3C	S5024PV2-EI	设备接入	4	关键

2.4.6 数据库管理系统

表 2-6 数据库管理系统

序号	数据库管理系统名称	版本	部署位置	主要功能	重要程度
1	数据库	MySQL 5.7.29	数据库服务器	数据存储	关键

2.4.7 关键业务应用

表 2-7 关键业务应用

序号	应用名称	版本	部署位置	主要功能
1	新点电子交易平台	V1.01	应用服务器	为各方交易主体提供在线交易过程，对交易过程资料进行存档备案，收集、发布公共资源交易信息，对交易数据进行汇总分析，为交易活动提供信息交互和技术共享服务，建立和维护各类交易主体信用信息数据库，推进交易信息交互共享。

2.4.8 重要数据

表 2-8 重要数据

序号	数据	描述	所属应用	存储位置	安全需求
1	个人信息数据	主要包括，个人身份信息、手机号、住址、姓名等	新点电子交易平台	数据库	机密性 完整性
2	业务数据	交易数据	新点电子交易平台	数据库	机密性 完整性
3	鉴别数据 (数字证书)	公钥、私钥	新点电子交易平台	智能密码钥匙	机密性 完整性
4	鉴别数据 (非数字证书)	用户名、口令	新点电子交易平台	数据库	机密性 完整性
5	日志数据	系统日志	新点电子交易平台	数据库	完整性

2.4.9 安全管理文档

表 2-9 安全管理文档

序号	文档名称	主要内容
1	密码应用安全管理制度	内容包括总体要求、密码应用技术管控、密码专业人员管理、组织机构及职责、密码算法与密钥管理等
2	密码安全制度文件控制管理规定	内容包括总则、控制流程、文件版本、附件等
3	密码人员管理制度	内容包括密码人员岗位与职责、密码人员管理、密码人员培训、密码人员考核与奖惩、密码人员离岗等
4	密钥管理制度	内容包括密钥的产生、分发、存储、使用、更新、归档、撤销、备份、恢复、销毁等
5	密码应用操作管理制度	内容包括密码应用在物理和环境安全、网络和通信安全、设备和计算安全、应用和数据安全四个方面的使用和操作管理要求
6	苏州国泰新点软件有限公司信息系统制度执行记录表	内容包括规章制度名称、日期、制度执行部门、制度内容、执行情况等

序号	文档名称	主要内容
7	密码安全事件应急处置管理制度	内容包括组织机构与职责、事件分类分级、应急响应流程、应急处置方案管理、应急资源协调等
8	应急事件报告表	内容包括事件现象、事件编号、报告人、联系电话、报告时间、事件描述、影响范围等

2.4.10人员

表 2-10 人员

序号	姓名	岗位及角色	职责说明	联系方式
1	屈智	密钥管理员	负责密钥保管，确保密钥可用性、完整性、唯一性。	13812995671
2	张鹏	密码操作员	按照设备管理的各项规定，维护加密机等密码设备保持良好的运行状态。	18260622809
3	蒋铭	密码安全审计员	负责对密钥管理过程中的操作活动进行监督，确保操作过程的合规性。	18962289227

2.5 密码服务

表 2-11 密码服务

序号	密码服务名称	密码服务提供商
1	电子认证服务	中金金融认证中心有限公司

2.6 安全威胁

表 2-12 安全威胁

序号	威胁类别	威胁分类
1	物理和环境	非法人员进入物理环境，对软硬件设备和数据进行直接破坏
2		物理进出记录和视频记录遭到篡改，以掩盖非法人员进出情况
3	网络和通信	非法通信实体接入网络
4		通信数据在信息系统外部被非授权的截取、篡改
5		非法设备从外部接入内部网络，或网络边界被破坏
6	设备和计算	设备被非法人员登录
7		搭建的远程管理通道被非法使用，或传输的管理数据被非授权获取和篡改
8		设备资源被登录设备的其他用户获取

序号	威胁类别	威胁分类
9		重要信息资源安全标记被非授权获取和篡改
10		设备日志记录被非法篡改，以掩盖非法操作
11		设备内重要程序和文件的来源不可信
12	应用和数据	应用被非法人员登录
13		应用资源被登录应用的其他用户获取
14		重要信息资源安全标记被非授权获取和篡改
15		传输或存储的数据被外部攻击者非法获取
16		某个应用传输或存储的数据被其他应用获取
17		应用日志记录被非法篡改，以掩盖非法操作
18		应用程序、重要应用配置等重要信息被非法修改
19		数据发送者或接收者不承认发送或接受到数据，或者否认所做的操作和交易
20	密钥管理和安全管理	生成的密钥缺少随机性，被攻击者猜测
21		密钥被非法获取
22		密钥被非法篡改，或密钥与实体之间的关联关系被非法篡改
23		密钥被非法使用
24		密钥备份和归档机制不健全，导致密钥泄露，或密钥被恢复到非法的设备中
25		密钥销毁不及时导致密钥泄露，或销毁的密钥被恶意恢复
26		安全管理制度和密钥管理策略等不完善，管理流程不健全，执行不到位，职责不明确，导致密钥泄露、数据泄露等风险

2.7 前次测评情况

本次测评是被测信息系统进行的第 1 次商用密码应用安全性评估。

3 测评范围与方法

3.1 测评指标

3.1.1 基本指标

根据被测信息系统密码应用安全要求等级，选择 GB/T 39786-2021《信息安全技术 信息系统密码应用基本要求》中第 3 级别的安全要求作为本次测评工作的基本指标，在表 3-1 中列出指标。

表 3-1 第三级要求基本指标

测评指标			测评指标描述	应用要求
技术要求	物理和环境安全	身份鉴别	8.1 a) 宜采用密码技术进行物理访问身份鉴别，保证重要区域进入人员身份的真实性；	宜
		电子门禁记录数据存储完整性	8.1 b) 宜采用密码技术保证电子门禁系统进出记录数据的存储完整性；	宜
		视频监控记录数据存储完整性	8.1 c) 宜采用密码技术保证视频监控音像记录数据的存储完整性。	宜
	网络和通信安全	身份鉴别	8.2 a) 应采用密码技术对通信实体进行身份鉴别，保证通信实体身份的真实性；	应
		通信数据完整性	8.2 b) 宜采用密码技术保证通信过程中数据的完整性；	宜
		通信过程中重要数据的机密性	8.2 c) 应采用密码技术保证通信过程中重要数据的机密性；	应
		网络边界访问控制信息的完整性	8.2 d) 宜采用密码技术保证网络边界访问控制信息的完整性；	宜
		安全接入认证	8.2 e) 可采用密码技术对从外部连接到内部网络的设备进行接入认证，确保接入的设备身份真实性。	可
	设备和计算安全	身份鉴别	8.3 a) 应采用密码技术对登录设备的用户进行身份鉴别，保证用户身份的真实性；	应
		远程管理通道安全	8.3 b) 远程管理设备时，应采用密码技术建立安全的信息传输通道；	应
		系统资源访问控制信息完整性	8.3 c) 宜采用密码技术保证系统资源访问控制信息的完整性；	宜

测评指标			测评指标描述	应用要求
		重要信息资源安全标记完整性	8.3 d) 宜采用密码技术保证设备中的重要信息资源安全标记的完整性;	宜
		日志记录完整性	8.3 e) 宜采用密码技术保证日志记录的完整性;	宜
		重要可执行程序完整性、重要可执行程序来源真实性	8.3 f) 宜采用密码技术对重要可执行程序进行完整性保护, 并对其来源进行真实性验证。	宜
	应用和数据安全	身份鉴别	8.4 a) 应采用密码技术对登录用户进行身份鉴别, 保证应用系统用户身份的真实性;	应
		访问控制信息完整性	8.4 b) 宜采用密码技术保证信息系统应用的访问控制信息的完整性;	宜
		重要信息资源安全标记完整性	8.4 c) 宜采用密码技术保证信息系统应用的重要信息资源安全标记的完整性;	宜
		重要数据传输机密性	8.4 d) 应采用密码技术保证信息系统应用的重要数据在传输过程中的机密性;	应
		重要数据存储机密性	8.4 e) 应采用密码技术保证信息系统应用的重要数据在存储过程中的机密性;	应
		重要数据传输完整性	8.4 f) 宜采用密码技术保证信息系统应用的重要数据在传输过程中的完整性;	宜
		重要数据存储完整性	8.4 g) 宜采用密码技术保证信息系统应用的重要数据在存储过程中的完整性;	宜
		不可否认性	8.4 h) 在可能涉及法律责任认定的应用中, 宜采用密码技术提供数据原发证据和数据接收证据, 实现数据原发行为的不可否认性和数据接收行为的不可否认性。	宜
管理要求	管理制度	具备密码应用安全管理制度	8.5 a) 应具备密码应用安全管理制度, 包括密码人员管理、密钥管理、建设运行、应急处置、密码软硬件及介质管理等制度;	应
		密钥管理规则	8.5 b) 应根据密码应用方案建立相应密钥管理规则;	应
		建立操作规程	8.5 c) 应对管理人员或操作人员执行的日常管理操作建立操作规程;	应

测评指标			测评指标描述	应用要求
		定期修订安全管理制度	8.5 d) 应定期对密码应用安全管理制度和操作规程的合理性和适用性进行论证和审定,对存在不足或需要改进之处进行修订;	应
		明确管理制度发布流程	8.5 e) 应明确相关密码应用安全管理制度和操作规程的发布流程并进行版本控制;	应
		制度执行过程记录留存	8.5 f) 应具有密码应用操作规程的相关执行记录并妥善保存。	应
	人员管理	了解并遵守密码相关法律法规和密码管理制度	8.6 a) 相关人员应了解并遵守密码相关法律法规、密码应用安全管理制度;	应
		建立密码应用岗位责任制度	8.6 b) 应建立密码应用岗位责任制度,明确各岗位在安全系统中的职责和权限: 1) 根据密码应用的实际情况,设置密钥管理员、密码安全审计员、密码操作员等关键安全岗位; 2) 对关键岗位建立多人共管机制; 3) 密钥管理、密码安全审计、密码操作人员职责互相制约互相监督,其中密钥管理员岗位不可与密码审计员、密码操作员等关键安全岗位兼任; 4) 相关设备与系统的管理和使用账号不得多人共用。	应
		建立上岗人员培训制度	8.6 c) 应建立上岗人员培训制度,对于涉及密码的操作和管理的人员进行专门培训,确保其具备岗位所需专业技能;	应
		定期进行安全岗位人员考核	8.6 d) 应定期对密码应用安全岗位人员进行考核;	应
		建立关键岗位人员保密制度和调离制度	8.6 e) 应建立关键人员保密制度和调离制度,签订保密合同,承担保密义务。	应
	建设运行	制定密码应用方案	8.7 a) 应依据密码相关标准和密码应用需求,制定密码应用方案;	应

测评指标			测评指标描述	应用要求
		制定密钥安全管理策略	8.7 b) 应根据密码应用方案，确定系统涉及的密钥种类、体系及其生命周期环节，各环节安全管理要求参照《信息安全技术 信息系统密码应用基本要求》附录 B；	应
		制定实施方案	8.7 c) 应按照应用方案实施建设；	应
		投入运行前进行密码应用安全性评估	8.7 d) 投入运行前应进行密码应用安全性评估，评估通过后系统方可正式运行；	应
		定期开展密码应用安全性评估及攻防对抗演习	8.7 e) 在运行过程中，应严格执行既定的密码应用安全管理制度，应定期开展密码应用安全性评估及攻防对抗演习，并根据评估结果进行整改。	应
	应急处置	应急策略	8.8 a) 应制定密码应用应急策略，做好应急资源准备，当密码应用安全事件发生时，应立即启动应急处置措施，结合实际情况及时处置；	应
		事件处置	8.8 b) 事件发生后，应及时向信息系统主管部门进行报告；	应
		向有关主管部门上报处置情况	8.8 c) 事件处置完成后，应及时向信息系统主管部门及归属的密码管理部门报告事件发生情况及处置情况。	应
测评指标合计		41 项		

3.1.2 特殊指标

无。

3.1.3 不适用指标

鉴于信息系统的复杂性和特殊性，GB/T 39786-2021《信息安全技术 信息系统密码应用基本要求》的第 3 级要求中的个别项可能不适用于被测信息系统，对于这些不适用项及其不适用原因如表 3-2 所示：

表 3-2 不适用指标及说明

安全层面	测评指标	测评指标描述	不适用原因
网络和通信安全	安全接入认证	8.2 e) 可采用密码技术对从外部连接到内部网络的设备进行接入认证，确保接入的设备身份真实性。	依据密码应用方案，无安全接入认证需求，本项不适用。
设备和计算安全	重要信息资源安全标记完整性	8.3 d) 宜采用密码技术保证设备中的重要信息资源安全标记的完整性；	依据密码应用方案，综合安全网关无重要信息资源安全标记完整性需求，本项不适用。
应用和数据安全	重要信息资源安全标记完整性	8.4 c) 宜采用密码技术保证信息系统应用的重要信息资源安全标记的完整性；	根据密码应用方案，本系统不涉及重要信息资源安全标记，本项不适用。
不适用项合计		3 项	

3.2 测评方法及工具

3.2.1 现场测评方法

本次商用密码应用安全性评估使用的测评方法包括：

访谈：通过与被测单位的相关人员进行交谈和问询，了解被测信息系统技术和管理方面的一些基本信息，并对一些测评内容进行确认；

文档审查：审核被测单位提交的有关信息系统安全的各个方面的文档，如：被测系统总体描述文件，被测系统密码总体描述文件，安全管理制度文件，密钥管理制度，各种密码安全规章制度及相关过程管理记录、配置管理文档，被测单位的信息化建设与发展状况以及联络方式；密码应用方案及评审意见，安全保护等级定级报告，系统验收报告，安全需求分析报告，安全总体方案，自查或上次评估报告等等。通过对这些文档的审核与分析确认测评的相关内容是否达到安全保护等级的要求；

实地查看：现场查看测评对象所处的环境、外观等情况；

配置检查：查看测评对象的相关配置；

工具测试：根据被测信息系统的实际情况，密评人员使用适合的技术工具对其进行测试。

3.2.2 测评工具

本次商用密码应用安全性评估使用的测评工具如表 3-3 所示：

表 3-3 测评工具

序号	工具名称	版本	生产厂商	工具说明
1	网络传输协议分析工具	V3.3.0	开源软件	对网络传输协议进行抓包，分析数据格式与内容，评估通信协议
2	网络传输密码使用检测仪	V2.5.0	北京中海闻达信息技术有限公司	可进行通信密码算法类型检测、数字证书检测、电子签章检测、电子数字信封检测、系统密钥源检测

3.2.3 测评工具检查点

本次测评计划选取的工具接入点如图 3-1 所示：

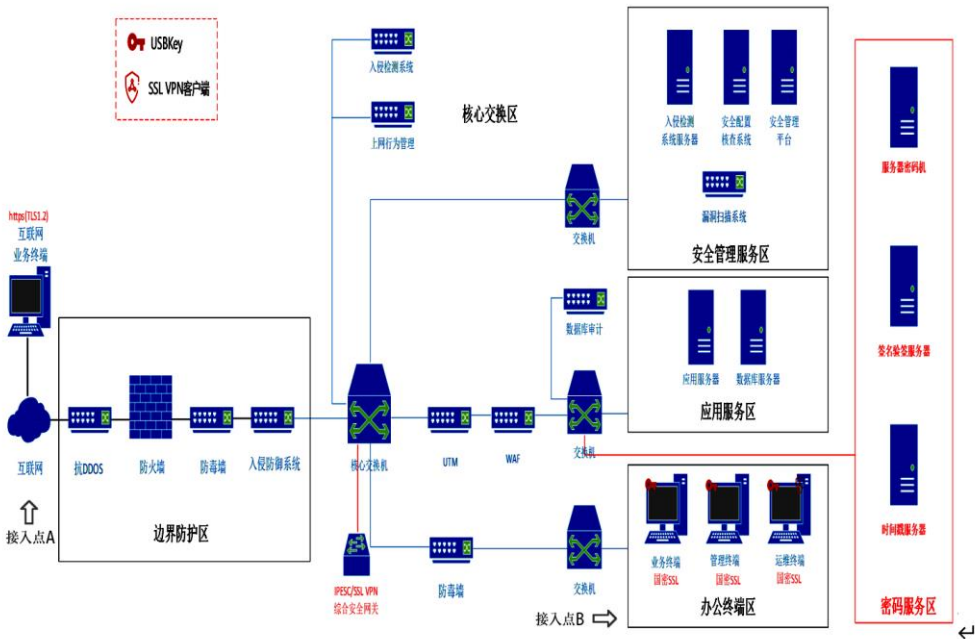


图 3-1 工具接入点测试示意图

检查点 A：在检查点 A 进行抓包，互联网公众用户与新点电子交易平台之间通信信道的身份鉴别机制，查看数据在传输过程中是否使用密码技术进行保护，使用的算法是否为国家密码管理部门认可的算法。

检查点 B：在检查点 B 进行抓包，查看办公内网运维客户端与综合安全网关之间通信信道以及办公内网国密浏览器与综合安全网关之间通信信道的身份鉴别机制，查看数据在传输过程中是否使用密码技术进行保护，使用的算法是否为国家密码管理部门认可的算法。

3.3 测评对象和对应测评方式

3.3.1 测评对象确定方法

依据《信息系统密码应用测评过程指南》的测评对象确定方法，根据被测信息系统的重要程度及其相关资产等的价值认定结果，明确核心资产在信息系统内的流转，从而确定与密码相关的测评对象。

3.3.2 测评对象确定结果

3.3.2.1 密码技术应用测评

3.3.2.1.1 物理和环境安全测评

表 3-4 物理和环境安全测评对象

序号	测评对象	测评方式	说明
1	国泰新点中心机房	√ 访谈 √ 文档审查 √ 实地查看 □ 配置检查 □ 工具测试	-

3.3.2.1.2 网络和通信安全测评

表 3-5 网络和通信安全测评对象

序号	测评对象	测评方式	说明
1	办公内网国密浏览器与综合安全网关之间的通信信道	√ 访谈 □ 文档审查 □ 实地查看 √ 配置检查 √ 工具测试	-
2	办公内网运维客户端与综合安全网关之间的通信信道	√ 访谈 □ 文档审查 □ 实地查看 √ 配置检查 √ 工具测试	-

序号	测评对象	测评方式	说明
3	互联网公众用户与新点电子交易平台之间的通信信道	√ 访谈 □ 文档审查 □ 实地查看 √ 配置检查 √ 工具测试	-

3.3.2.1.3 设备和计算安全测评

表 3-6 设备和计算安全测评对象

序号	测评对象	测评方式	说明
1	服务器密码机	√ 访谈 √ 文档审查 □ 实地查看 √ 配置检查 □ 工具测试	-
2	签名验签服务器	√ 访谈 √ 文档审查 □ 实地查看 √ 配置检查 □ 工具测试	-
3	综合安全网关	√ 访谈 √ 文档审查 □ 实地查看 √ 配置检查 □ 工具测试	-
4	时间戳服务器	√ 访谈 √ 文档审查 □ 实地查看 √ 配置检查 □ 工具测试	-

序号	测评对象	测评方式	说明
5	新点电子签章系统	√ 访谈 √ 文档审查 ☐ 实地查看 √ 配置检查 ☐ 工具测试	—
6	数据库	√ 访谈 √ 文档审查 ☐ 实地查看 √ 配置检查 ☐ 工具测试	—
7	应用服务器	√ 访谈 √ 文档审查 ☐ 实地查看 √ 配置检查 ☐ 工具测试	—
8	数据库服务器	√ 访谈 √ 文档审查 ☐ 实地查看 √ 配置检查 ☐ 工具测试	—
9	签章服务器	√ 访谈 √ 文档审查 ☐ 实地查看 √ 配置检查 ☐ 工具测试	—

3.3.2.1.4 应用和数据安全测评

表 3-7 应用和数据安全测评对象

序号	测评对象	测评方式	说明
11	新点电子交易平台	☒ 访谈 ☐ 文档审查 ☐ 实地查看 ☒ 配置检查 ☐ 工具测试	-

3.3.2.2 安全管理测评

表 3-8 安全管理测评对象

序号	测评单元	测评对象	测评方式	说明
1	管理制度	管理体系（包括安全管理制度类文档、密码应用方案、密钥管理制度及策略类文档、操作规程类文档、记录表单类文档、系统相关人员）	☒ 访谈 ☒ 文档审查	-
2	人员管理	管理体系（包括安全管理制度类文档、记录表单类文档、系统相关人员）	☒ 访谈 ☒ 文档审查	-
3	建设运行	密码应用方案、密钥管理制度及策略类文档、密码实施方案、商用密码应用安全性评估报告、密码应用安全管理制度、攻防对抗演习报告、整改文档	☒ 访谈 ☒ 文档审查	-
4		管理体系（包括安全管理制度类文档、记录表单类文档、系统相关人员）	☒ 访谈 ☒ 文档审查	-
5	应急处置	管理体系（包括密码应用应急处置方案、应急处置记录类文档、安全事件发生情况及处置情况报告、系统相关人员）	☒ 访谈 ☒ 文档审查	-

4 单元测评

4.1 密码技术应用要求

4.1.1 物理和环境安全

4.1.1.1 结果汇总

针对不同测评单元，对各个测评对象的测评结果进行汇总和统计，如表 4-1 所示：

表 4-1 物理和环境安全测评结果汇总

序号	测评对象	测评指标符合情况		
		身份鉴别	电子门禁记录数据存储完整性	视频监控记录数据存储完整性
1	国泰新点中心机房	不符合	不符合	不符合
单元测评结果		不符合	不符合	不符合

4.1.1.2 结果分析

物理和环境安全层面发现的问题：

（1）身份鉴别：

机房进出人员需经过 IC 卡刷卡，现场人工身份核对，专人陪同方式进入机房，通过上述手段以保证机房进出人员身份的真实性，但未采用密码技术对机房进出人员进行身份鉴别。

（2）电子门禁记录数据存储完整性：

机房的进出记录数据明文存储于电子门禁系统，未使用密码技术保证电子门禁系统进出记录数据的存储完整性。

（3）视频监控记录数据存储完整性：

机房的视频监控音像记录明文存储于视频监控系统，未使用密码技术保证视频监控音像记录数据的存储完整性。

4.1.2 网络和通信安全

4.1.2.1 结果汇总

针对不同测评单元，对各个测评对象的测评结果进行汇总和统计，如表 4-2 所示：

表 4-2 网络和通信安全测评结果汇总

序号	测评对象	测评指标符合情况				
		身份鉴别	通信数据完整性	通信过程中重要数据的机密性	网络边界访问控制信息的完整性	安全接入认证
1	办公内网国密浏览器与综合安全网关之间的通信信道	符合	符合	符合	符合	不适用
2	办公内网运维客户端与综合安全网关之间的通信信道	符合	符合	符合	符合	不适用
3	互联网公众用户与新点电子交易平台之间的通信信道	部分符合	部分符合	部分符合	不符合	不适用
单元测评结果		部分符合	部分符合	部分符合	部分符合	不适用

4.1.2.2 结果分析

网络和通信安全层面具备的防护措施：

（1）身份鉴别：

办公内网国密浏览器与综合安全网关之间的通信信道、办公内网运维客户端与综合安全网关之间的通信信道，使用服务端证书进行身份鉴别，使用的 SM2、SM3 算法经过国家密码管理部门认可，能够保证通信实体的真实性。互联网公众用户与新点电子交易平台之间的通信信道，使用服务端证书进行身份鉴别，证书使用了 AES_256_GCM_算法，能够保证网络通信实体的真实性。

(2) 通信数据完整性:

办公内网国密浏览器与综合安全网关之间的通信信道、互联网公众用户与新点电子交易平台之间的通信信道、办公内网运维客户端与综合安全网关之间的通信信道采用 TLCP 协议或 HTTPS 协议，算法套件分别为 ECC_SM4_CBC_SM3、TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384，可以保证通信数据的完整性。

(3) 通信过程中重要数据的机密性:

办公内网国密浏览器与综合安全网关之间的通信信道、互联网公众用户与新点电子交易平台之间的通信信道、办公内网运维客户端与综合安全网关之间的通信信道采用 TLCP 协议或 HTTPS 协议，算法套件分别为 ECC_SM4_CBC_SM3、TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384，可以保证通信数据的机密性。

(4) 网络边界访问控制信息的完整性:

办公内网国密浏览器与综合安全网关之间的通信信道和办公内网运维客户端与综合安全网关之间的通信信道，使用综合安全网关进行网络边界的访问控制，通过密码产品自身的安全机制保证访问控制信息的完整性。

网络和通信安全层面发现的问题:**(1) 身份鉴别:**

互联网公众用户与新点电子交易平台之间的通信信道，采用 SHA384RSA 国际算法进行身份鉴别，但未采用商用密码算法保证通信实体身份真实性。

(2) 通信数据完整性:

互联网公众用户与新点电子交易平台之间的通信信道，采用 TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 的算法套件以保证通信数据的完整性，但未采用商用密码算法保证通信数据的完整性。

(3) 通信过程中重要数据的机密性:

互联网公众用户与新点电子交易平台之间的通信信道，采用 TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 的算法套件以保证通信数据的机密性，但未采用商用密码算法保证通信数据的机密性。

(4) 网络边界访问控制信息的完整性:

互联网公众用户与新点电子交易平台之间的通信信道，未采用密码技术保证

网络边界访问控制信息的完整性。

4.1.3 设备和计算安全

4.1.3.1 结果汇总

针对不同测评单元，对各个测评对象的测评结果进行汇总和统计，如表 4-3 所示：

表 4-3 设备和计算安全测评结果汇总

序号	测评对象	测评指标符合情况					
		身份鉴别	远程管理通道安全	系统资源访问控制信息完整性	重要信息资源安全标记完整性	日志记录完整性	重要可执行程序完整性、重要可执行程序来源真实性
1	电子签章服务器	不符合	部分符合	不符合	不适用	不符合	不符合
2	服务器密码机	符合	不符合	符合	不适用	符合	符合
3	签名验签服务器	符合	不符合	符合	不适用	符合	符合
4	时间戳服务器	符合	不符合	符合	不适用	符合	符合
5	数据库	不符合	部分符合	不符合	不适用	不符合	不符合
6	数据库服务器	不符合	部分符合	不符合	不适用	不符合	不符合
7	新点电子签章系统	不符合	不符合	符合	不适用	符合	符合
8	应用服务器	不符合	部分符合	不符合	不适用	不符合	不符合
9	综合安全网关	符合	符合	符合	不适用	符合	符合
单元测评结果		部分符合	部分符合	部分符合	不适用	部分符合	部分符合

4.1.3.2 结果分析

设备和计算层面具有的防护措施:

(1) 身份鉴别:

服务器密码机、签名验签服务器、时间戳服务器、综合安全网关全部使用数字证书对登录的用户进行身份鉴别,证书使用的密码算法经国家密码管理部门认可,密码产品获得了商用密码产品认证证书,达到了密码产品二级安全要求。

(2) 远程管理通道安全:

数据库、应用服务器、数据库服务器、电子签章服务器使用使用 SSH 协议协议进行远程管理,能够保证远程管理通道安全,综合安全网关进行远程管理采用 TLCP 协议,能够保证远程管理通道安全。

(3) 系统资源访问控制信息完整性:

服务器密码机、签名验签服务器、时间戳服务器、新点电子签章系统、综合安全网关使用自身的安全机制保证系统资源访问控制信息的完整性,获得了商用密码产品认证证书,达到了密码产品二级安全要求。

(4) 日志记录完整性:

服务器密码机、签名验签服务器、时间戳服务器、新点电子签章系统、综合安全网关使用自身的安全机制保证日志记录的完整性,获得了商用密码产品认证证书,达到了密码产品二级安全要求。

(5) 重要可执行程序完整性、重要可执行程序来源真实性:

服务器密码机、签名验签服务器、时间戳服务器、新点电子签章系统、综合安全网关使用自身的安全机制保证重要可执行程序完整性、重要可执行程序来源真实性,获得了商用密码产品认证证书,达到了密码产品二级安全要求。

设备和计算层面发现的问题:

(1) 身份鉴别:

数据库、应用服务器、数据库服务器、电子签章服务器、新点电子签章系统,未使用密码技术保证用户身份的真实性。

(2) 远程管理通道安全:

数据库、应用服务器、数据库服务器、电子签章服务器均未采用商用密码算

法保证远程管理通道安全，服务器密码机、签名验签服务器、时间戳服务器、新点电子签章系统均未采用密码技术建立安全的信息传输通道。

(3) 系统资源访问控制信息完整性：
数据库、应用服务器、数据库服务器、电子签章服务器均未使用密码技术保证访问控制信息的完整性。

(4) 日志记录完整性：
数据库、应用服务器、数据库服务器、电子签章服务器均未使用密码技术保证日志记录的完整性。

(5) 重要可执行程序完整性、重要可执行程序来源真实性：
数据库、应用服务器、数据库服务器、电子签章服务器均未使用密码技术保证重要可执行程序的完整性和来源的真实性。

4.1.4 应用和数据安全

4.1.4.1 结果汇总

针对不同测评单元，对各个测评对象的测评结果进行汇总和统计，如表 4-4 所示：

表 4-4 应用和数据安全测评结果汇总

序号	测评对象	测评指标符合情况							
		身份鉴别	访问控制信息完整性	重要信息资源安全标记完整性	重要数据传输机密性	重要数据存储机密性	重要数据传输完整性	重要数据存储完整性	不可否认性
1	新点电子交易平台	部分符合	符合	不适用	不符合	符合	部分符合	符合	符合
单元测评结果		部分符合	符合	不适用	不符合	符合	部分符合	符合	符合

针对应用和数据安全层面身份鉴别情况进行说明和汇总，如表 4-5 所示：

表 4-5 应用和数据安全身份鉴别测评结果汇总

序号	应用用户	身份鉴别
1	业务用户	符合
2	公众用户	不符合
单元测评结果		部分符合

针对应用和数据安全层面重要数据的机密性和完整性保护情况进行说明和汇总，如表 4-6 所示：

表 4-6 应用和数据安全重要数据测评结果汇总

序号	重要数据	传输机密性	存储机密性	传输完整性	存储完整性
1	个人信息数据	不符合	符合	不符合	符合
2	鉴别数据（数字证书）	不适用	符合	符合	符合
3	业务数据	不符合	符合	不符合	符合
4	日志数据	不适用	不适用	不适用	符合
5	鉴别数据（非数字证书）	不符合	符合	不符合	符合
单元测评结果		不符合	符合	部分符合	符合

针对应用和数据安全层面不可否认性情况进行说明和汇总，如表 4-7 所示：

表 4-7 应用和数据安全不可否认性测评结果汇总

序号	操作行为	不可否认性
1	应用系统重要操作行为	符合
单元测评结果		符合

4.1.4.2 结果分析

应用与数据安全层面具有的防护措施：

（1）身份鉴别：

业务用户利用配发的智能密码钥匙访问应用系统，使用基于 SM2 算法的挑战-响应机制实现系统用户的身份鉴别，能够保证登录应用系统的用户的真实性。使用的智能密码钥匙获得了商用密码产品认证证书，达到了密码产品二级安全要

求。

(2) 访问控制信息完整性：

新点电子交易平台在数据库中存储了应用系统的访问控制策略，通过服务器密码机，使用 SM2、SM3 算法对访问控制信息进行了签名，能够保证访问控制信息的完整性。

(3) 重要数据存储机密性：

个人信息数据、鉴别数据（非数字证书）、业务数据均通过服务器密码机使用 SM4 算法对重要数据进行加密后存储到数据库中，能够保证数据存储的机密性。鉴别数据（数字证书）的私钥使用其自身的安全机制保证数据存储的机密性。

(4) 重要数据传输完整性：

鉴别数据（数字证书）的公钥由公钥证书的安全机制保证数据传输的完整性。

(5) 重要数据存储完整性：

个人信息数据、鉴别数据（非数字证书）、业务数据、日志数据均通过服务器密码机使用 SM3 算法对重要数据进行加密后存储到数据库中，能够保证数据存储的完整性。鉴别数据（数字证书）的用户私钥存储在智能密码钥匙中，使用其自身的安全机制保证数据存储的完整性。

(6) 不可否认性：

电子签章系统进行证书签发时，应用系统使用操作人员智能密码钥匙中的私钥对电子印章数据进行签名，并调用时间戳服务器在电子印章数据中添加时间戳，能够保证关键行为的不可否认性。

应用与数据安全层面发现的问题：

(1) 身份鉴别：

公众用户采用用户名+口令+手机验证码方式进行身份鉴别以保证用户的真实性，但未使用密码技术保证用户的真实性。

(2) 重要数据传输机密性：

个人信息数据、鉴别数据（非数字证书）、业务数据均未使用密码技术保证数据在传输过程中的机密性。

(3) 重要数据传输完整性:

个人信息数据、业务数据、鉴别数据（非数字证书）均未使用密码技术保护传输过程中的机密性。

4.2 安全管理

4.2.1 管理制度

4.2.1.1 结果汇总

针对不同测评单元，对各个测评对象的测评结果进行汇总和统计，如表 4-8 所示：

表 4-8 管理制度测评结果汇总

序号	测评对象	测评指标符合情况					
		具备密码应用安全管理制度	密钥管理规则	建立操作规程	定期修订安全管理制度	明确管理制度发布流程	制度执行过程记录留存
1	管理体系(包括安全管理制度类文档、密码应用方案、密钥管理制度及策略类文档、操作规程类文档、记录表单类文档、系统相关人员)	符合	符合	符合	符合	符合	符合
单元测评结果		符合	符合	符合	符合	符合	符合

4.2.1.2 结果分析

管理制度层面具有的防护措施：

(1) 具备密码应用安全管理制度：

建立了安全管理制度体系，具有《密码应用安全管理制度》、《密钥管理制度》等相关管理制度，规范密码安全管理制度，对密码安全基本原则、组织架构、体系运作、风险管理、系统安全和密钥安全等进行要求。

(2) 密钥管理规则：

制定了《密码应用安全管理制度》，第四章安全体系的运作管理规定了密码

应用技术体系框架，第十章密钥安全管理要求根据密码应用方案建立相应密钥管理规则。

(3) 建立操作规程：

制定了《密码应用操作管理制度》，对管理人员和操作人员执行的日常管理操作进行规范。

(4) 定期修订安全管理制度：

制定了《密码安全制度文件控制管理规定》，明确密码安全管理制度评审和修订工作至少每年开展一次。

(5) 明确管理制度发布流程：

具有《密码安全制度文件控制管理规定》，明确了管理制度的发布流程并进行版本控制。

(6) 制度执行过程记录留存：

制定了《苏州国泰新点软件有限公司信息系统制度执行记录表》记录了密码应用操作规程的执行情况。

4.2.2 人员管理

4.2.2.1 结果汇总

针对不同测评单元，对各个测评对象的测评结果进行汇总和统计，如表 4-9 所示：

表 4-9 人员管理测评结果汇总

序号	测评对象	测评指标符合情况				
		了解并遵守密码相关法律法规和密码管理制度	建立密码应用岗位责任制度	建立上岗人员培训制度	定期进行安全岗位人员考核	建立关键岗位人员保密制度和调离制度
1	管理体系（包括安全管理制度类文档、记录表单类文档、系统相关人员）	符合	符合	符合	符合	符合
单元测评结果		符合	符合	符合	符合	符合

4.2.2.2 结果分析

人员管理层面具有的防护措施：

（1）了解并遵守密码相关法律法规和密码管理制度：

系统管理员等了解商用密码的相关法律法规。

（2）建立密码应用岗位责任制度：

建立了密码应用岗位责任制度，《密码人员管理制度》明确了人员岗位职责、人员考核、人员培训、人员保密和调离、人员的配备与管理等相关规定，规定了权限、职能不同的角色必须分离，相关设备与系统的管理和使用账号不得多人共用。

（3）建立上岗人员培训制度：

建立了人员培训制度和相关培训计划，《密码人员管理制度》中规定设置内部密码专题培训机制，每年组织至少一次培训，由内部人员或聘请外部专家担任培训讲师，内容涉及密码相关法律法规和标准规范、商用密码应用、商用密码应用安全性评估等多个方面，并提供了培训记录。

（4）定期进行安全岗位人员考核：

建立了人员考核管理制度和相关培训计划，《密码人员管理制度》中规定每年对相关人员进行一次考核，根据考核结果安排后续的培训并记录，并提供了考核记录。

（5）建立关键岗位人员保密制度和调离制度：

建立了关键岗位人员保密制度和人员离岗管理制度，《密码人员管理制度》中规定外单位聘任人员或关键岗位人员与被测单位签订保密协议，承担保密义务，相关人员若要调离岗位时，按照制定的人员调离制度承担相应的保密义务。

4.2.3 建设运行

4.2.3.1 结果汇总

针对不同测评单元，对各个测评对象的测评结果进行汇总和统计，如表 4-10 所示：

表 4-10 建设运行测评结果汇总

序号	测评对象	测评指标符合情况				
		制定密码应用方案	制定密钥安全管理策略	制定实施方案	投入运行前进行密码应用安全性评估	定期开展密码应用安全性评估及攻防对抗演习
1	密码应用方案、密钥管理制度及策略类文档、密码实施方案、商用密码应用安全性评估报告、密码应用安全管理制度、攻防对抗演习报告、整改文档、管理体系（包括安全管理制度类文档、记录表单类文档、系统相关人员）	符合	符合	符合	符合	部分符合
单元测评结果		符合	符合	符合	符合	部分符合

4.2.3.2 结果分析

建设运行层面具有的防护措施：

（1）制定密码应用方案：

具有《新点电子交易平台密码应用方案》，且通过了专家评审。

（2）制定密钥安全管理策略：

被测单位在《密码应用安全管理制度》中明确了密钥管理规则，根据《新点电子交易平台密码应用方案》确定系统涉及的密钥种类、体系及其生命周期环节，制定了密钥安全管理策略。

（3）制定实施方案：

被测单位在《新点电子交易平台密码应用方案》中明确了项目人员组织、经费保障、质量保证和监督检查。

(4) 投入运行前进行密码应用安全性评估：

被测系统目前处于试运行阶段，评估通过后系统才能正式上线运行。

(5) 定期开展密码应用安全性评估及攻防对抗演习：

《密码应用安全管理制度》中规定了定期开展安全性评估，《密码安全事件应急处置管理制度》中明确了演习步骤。

建设运行层面发现的问题：**(1) 定期开展密码应用安全性评估及攻防对抗演习：**

未提供攻防对抗演习报告。

4.2.4 应急处置**4.2.4.1 结果汇总**

针对不同测评单元，对各个测评对象的测评结果进行汇总和统计，如表 4-11 所示：

表 4-11 应急处置测评结果汇总

序号	测评对象	测评指标符合情况		
		应急策略	事件处置	向有关主管部门 上报处置情况
1	管理体系（包括密码应用应急处置方案、应急处置记录类文档、安全事件发生情况及处置情况报告、系统相关人员）	符合	符合	符合
单元测评结果		符合	符合	符合

4.2.4.2 结果分析**应急处置层面具有的防护措施：****(1) 应急策略：**

《密码安全事件应急处置管理制度》中明确了应急事件处理流程及其他管理措施，做好了应急资源准备。

(2) 事件处置：

按照《密码安全事件应急处置管理制度》中规定，发现的密码应用安全事故及时向密码应用安全工作小组报告，密码应用安全工作小组接到故障申报后，填写《应急事件报告表》并初步判定故障的严重程度、影响范围，重大密码应用安

全事件需要上报密码应用安全领导小组，同时按信息系统应急预案处理故障。

（3）向有关主管部门上报处置情况：

《密码安全事件应急处置管理制度》中规定了事件处置完成后向信息系统主管部门及归属的密码管理部门报告事件发生情况及处置情况。

5 整体测评

5.1 测评结果修正

针对各个“部分符合”及“不符合”测评指标要求的测评对象，分析与其相关的其他单元、其他层面的测评对象能否和它发生关联关系，发生何种的关联关系，这些关联关系产生的作用是否可以“弥补”该测评对象的不足，以及该测评对象的不足是否会影响与其有关联关系的其他测评对象的测评结果。

表 5-1 测评结果修正

序号	安全 层面	测评单元	测评 对象	经弥补 前的测 评结果/ 分值	经弥补 后的测 评结果/ 分	弥补原因及相关测评对象
-	-	-	-	-	-	-

5.2 整体测评结果和量化评估

修正后的整体测评结果和量化评估汇总如表 5-2 所示。其中，测评单元得分的计算过程参见附录 A。

表 5-2 整体测评结果

层面 (类)	测评指标	符合情况				测评单元 得分 $S_{i,j}$	安全层面得分 情况 S_i $= \frac{\sum_{1 \leq j \leq n_i} w_{i,j} S_{i,j}}{\sum_{1 \leq j \leq n_i} w_{i,j}}$
		符 合	部 分 符 合	不 符 合	不 适 用		
物理和 环境安 全	身份鉴别			√		0.0000	0.0000
	电子门禁记录数据存储 完整性			√		0.0000	
	视频监控记录数据存储 完整性			√		0.0000	
网络和 通信安 全	身份鉴别		√			0.7500	0.7392
	通信数据完整性		√			0.7500	
	通信过程中重要数据的		√			0.7500	

层面 (类)	测评指标	符合情况				测评单元 得分 S_{ij}	安全层面得分 情况 S_i $= \frac{\sum_{1 \leq j \leq n_i} w_{ij} S_{ij}}{\sum_{1 \leq j \leq n_i} w_{ij}}$
		符 合	部 分 符 合	不 符 合	不 适 用		
	机密性						
	网络边界访问控制信息的完整性		√			0.6667	
	安全接入认证				√	N/A	
设备和 计算安 全	身份鉴别		√			0.4444	0.4286
	远程管理通道安全		√			0.2222	
	系统资源访问控制信息完整性		√			0.5556	
	重要信息资源安全标记完整性				√	N/A	
	日志记录完整性		√			0.5556	
	重要可执行程序完整性、重要可执行程序来源真实性		√			0.5556	
应用和 数据安 全	身份鉴别		√			0.5000	0.6509
	访问控制信息完整性	√				1.0000	
	重要信息资源安全标记完整性				√	N/A	
	重要数据传输机密性			√		0.0000	
	重要数据存储机密性	√				1.0000	
	重要数据传输完整性		√			0.2500	
	重要数据存储完整性	√				1.0000	
	不可否认性	√				1.0000	
管理制 度	具备密码应用安全管理制度	√				1.0000	1.0000

层面 (类)	测评指标	符合情况				测评单元 得分 S_{ij}	安全层面得分 情况 S_i $= \frac{\sum_{1 \leq j \leq n_i} w_{ij} S_{ij}}{\sum_{1 \leq j \leq n_i} w_{ij}}$
		符 合	部 分 符 合	不 符 合	不 适 用		
	密钥管理规则	√				1.0000	
	建立操作规程	√				1.0000	
	定期修订安全管理制度	√				1.0000	
	明确管理制度发布流程	√				1.0000	
	制度执行过程记录留存	√				1.0000	
人员管 理	了解并遵守密码相关法律法规和密码管理制度	√				1.0000	1.0000
	建立密码应用岗位责任制度	√				1.0000	
	建立上岗人员培训制度	√				1.0000	
	定期进行安全岗位人员考核	√				1.0000	
	建立关键岗位人员保密制度和调离制度	√				1.0000	
建设运 行	制定密码应用方案	√				1.0000	0.9205
	制定密钥安全管理策略	√				1.0000	
	制定实施方案	√				1.0000	
	投入运行前进行密码应用安全性评估	√				1.0000	
	定期开展密码应用安全性评估及攻防对抗演习		√			0.5000	
应急处 置	应急策略	√				1.0000	1.0000
	事件处置	√				1.0000	
	向有关主管部门上报处置情况	√				1.0000	

层面 (类)	测评指标	符合情况				测评单元 得分 $S_{i,j}$	安全层面得分 情况 S_i $= \frac{\sum_{1 \leq j \leq n_i} w_{i,j} S_{i,j}}{\sum_{1 \leq j \leq n_i} w_{i,j}}$
		符合	部分符合	不符合	不适用		
合计		22	12	4	3	67.96	
符合情况		符合	部分符合	不符合	不适用	综合得分 $S = \frac{\sum_{\text{安全}} w_i \cdot S_i}{\sum_{\text{安全}} w_i} \times 70 + \frac{\sum_{\text{非安全}} w_i \cdot S_i}{\sum_{\text{非安全}} w_i} \times 30$	

6 风险分析

具体地，根据威胁类型和威胁发生频率，判断测评结果汇总中部分符合项或不符合项所产生的安全问题被威胁利用的可能性，可能性的取值范围为高、中和低。根据资产价值的高低，判断测评结果汇总中部分符合项或不符合项所产生的安全问题被威胁利用后，对被测系统的业务信息安全造成的影响程度，影响程度取值范围为高、中和低。综合以上的结果，密评机构根据自身经验和相关国家标准要求，对被测系统面临的安全风险进行赋值，风险值的取值范围为高、中和低。结合被测系统的安全保护等级对风险分析结果进行评价，即对国家安全、社会秩序、公共利益以及公民、法人和其他组织的合法权益造成的风险。如果存在高风险项，则认为信息系统面临高风险；同时也需要考虑多个中低风险叠加可能导致的高风险问题。

根据《信息系统密码应用高风险判定指引》判定系统是否存在高风险。经风险分析，系统存在高风险 0 项，中风险 18 项，低风险 0 项，具体见表 6-1：

表 6-1 风险分析

序号	安全层面	问题描述	关联威胁	风险分析	风险等级		
					高	中	低
1	物理和环境安全	未采用密码技术进行物理访问身份鉴别，不能保证机房进入人员身份的真实性。	非法人员进入物理环境，对软硬件设备和数据进行直接破坏	可能会导致应用系统运行故障或应用数据泄露，对被测单位及相关公民的合法权益造成高等级风险，但通过进入人员持 IC 卡刷卡及现场人工身份核对，并由专人陪同方式进入机房以保证人员真实性，且采用视频监控系统进行实时监控等，可酌情降低风险等级。		√	

序号	安全层面	问题描述	关联威胁	风险分析	风险等级		
					高	中	低
2	物理和环境安全	未使用密码技术保证电子门禁系统进出记录数据的存储完整性。	物理进出记录和视频监控记录遭到篡改，以掩盖非法人员进出情况	可能会导致安全事件无法追溯，对被测单位的合法权益造成中等级风险。		√	
3	物理和环境安全	未使用密码技术保证视频监控音像记录数据的存储完整性。	物理进出记录和视频监控记录遭到篡改，以掩盖非法人员进出情况	可能会导致安全事件无法追溯，对被测单位的合法权益造成中等级风险。		√	
4	网络和通信安全	身份鉴别机制采用非商用密码算法。	非法通信实体接入网络	因非授权访问导致内部网络信息泄露和对系统的破坏，对被测单位及相关公民的合法权益造成中等级风险。		√	
5	网络和通信安全	通信过程中完整性保护机制采用非商用密码算法。	通信数据在信息系统外部被非授权的截取、篡改	导致通信数据的篡改和泄露，对被测单位及相关公民的合法权益造成中等级风险。		√	
6	网络和通信安全	通信过程中机密性保护机制采用非商用密码算法。	通信数据在信息系统外部被非授权的截取、篡改	导致通信数据的篡改和泄露，对被测单位及相关公民的合法权益造成中等级风险。		√	
7	网络和通信安全	未采用密码技术保证网络边界访问控制信息的完整性。	非法通信实体接入网络	因非授权访问导致内部网络信息泄露和对系统的破坏，对被测单位及相关公民的合法权益造成中等级风险。		√	

序号	安全层面	问题描述	关联威胁	风险分析	风险等级		
					高	中	低
8	设备和计算安全	未使用密码技术保证用户身份的真实性。	设备被非法人员登录	虽然被测对象未使用密码技术保证用户身份的真实性，但运维人员仅可采用智能密码钥匙及 VPN 拨入内网对被测对象进行管理，因此问题导致的非授权访问、内部网络信息泄露、系统破坏风险等级为中等风险。		√	
9	设备和计算安全	远程管理通道采用非商用密码算法。	搭建的远程管理通道被非法使用，或传输的管理数据被非授权获取和篡改	导致通信数据的篡改和泄露，对被测单位及相关公民的合法权益造成中等级风险。		√	
10	设备和计算安全	远程管理设备时，未采用密码技术建立安全的信息传输通道。	搭建的远程管理通道被非法使用，或传输的管理数据被非授权获取和篡改	在设备和计算安全层面，虽然被测对象未采用密码技术建立安全的信息传输通道，但被测对象在网络中进行了物理隔离，运维人员需要先通过 SSL VPN 客户端与安全认证网关建立 TLCP 国密信道，经认证后进入该区域，且建立的专用的集中管理通道，采用了商用密码技术进行保护，符合要求认证后才可访问，因此本问题带来的安全风险为中级。		√	

序号	安全层面	问题描述	关联威胁	风险分析	风险等级		
					高	中	低
11	设备和计算安全	未使用密码技术保证访问控制信息的完整性。	设备资源被登录设备的其他用户获取	因非授权访问导致内部网络信息泄露和对系统的破坏，对被测单位及相关公民的合法权益造成中等级风险。		√	
12	设备和计算安全	未使用密码技术保证日志记录的完整性。	设备日志记录被非法篡改，以掩盖非法操作	导致出现抵赖行为，不利于安全事件的追溯，不利于系统的日常安全运维，对被测单位及相关公民的合法权益造成中等级风险。		√	
13	设备和计算安全	未使用密码技术保证重要可执行程序的真实性和来源的真实性。	设备内重要程序和文件的来源不可信	导致设备因遭受恶意代码攻击而导致信息泄露和对系统的破坏，对被测单位及相关公民的合法权益造成中等级风险。		√	
14	应用和数据安全	未使用密码技术保证用户身份的真实性。	应用被非法人员登录	公众用户虽然未使用密码技术保证用户身份真实性，但采用了用户名+口令+手机验证码形式进行身份鉴别，比单一使用用户名+口令方式相对安全，因此导致的的相关问题为中等级风险。		√	
15	应用和数据安全	未使用密码技术保证数据在传输过程中的机密性。	传输或存储的数据被外部攻击者非法获取	虽然被测对象未采用密码技术保证数据在传输过程中的机密性，但整个网络和通信安全层面采用了商用密码技术或国际密码技术进行了安全防护可以保证通信过程中的机密性，所以此问题引起的风险为中风险。		√	

序号	安全层面	问题描述	关联威胁	风险分析	风险等级		
					高	中	低
16	应用和数据安全	未使用密码技术保护数据在传输过程中的机密性。	传输或存储的数据被外部攻击者非法获取	虽然被测对象未采用密码技术保证数据在传输过程中的机密性，但整个网络和通信安全层面采用了商用密码技术或国际密码技术进行了安全防护可以保证通信过程中的机密性，所以此问题引起的风险为中风险。		√	
17	应用和数据安全	未使用密码技术保护数据在传输过程中的完整性。	传输或存储的数据被外部攻击者非法获取	导致通信数据的篡改和泄露，对被测单位及相关公民的合法权益造成中等级风险。		√	
18	建设运行	未提供攻防对抗演习报告。	安全管理制度和密钥管理策略等不完善，管理流程不健全，执行不到位，职责不明确，导致密钥泄露、数据泄露等风险	安全管理制度不完善，管理流程不健全，影响被测单位的密码应用建设工作的执行，导致数据泄露风险，对被测单位的合法权益造成中等级风险。		√	
统计					0	18	0

7 评估结论

通过对苏州国泰新点软件有限公司新点电子交易平台的物理和环境安全、网络和通信安全、设备和计算安全、应用和数据安全、管理制度、人员管理、建设运行和应急处置等方面的测评，该系统综合得分为 67.96 分，系统密码应用面临中风险，基本符合 GB/T 39786-2021《信息安全技术 信息系统密码应用基本要求》的第三级别要求。

附录 A 测评结果记录

A. 1. 物理和环境安全

表 A-1 物理和环境安全测评结果记录

测评指标	测评对象	结果记录	量化指标				测评单元得分 $S_{i,j}$ $= \frac{\sum_{1 \leq k \leq n_{i,j}} S_{i,j,k}}{n_{i,j}}$
			密码使用安全 D	密码算法/技术合规性 A	密钥管理安全 K	测评对象评分 $S_{i,j,k}$	
身份鉴别	国泰新点中心机房	经实地察看，机房进入人员持 IC 卡刷卡进入，经现场人工身份核对后，由专人陪同方式进入机房以保证人员真实性，但未采用密码技术对进入机房人员进行身份鉴别。	×	×	×	0	0
电子门禁记录数据存储完整性	国泰新点中心机房	经实地察看，未使用密码技术保证电子门禁系统进出记录数据的存储完整性。	×	×	×	0	0
视频监控记录数据存储完整性	国泰新点中心机房	经实地察看，未使用密码技术保证视频监控音像记录数据的存储完整性。	×	×	×	0	0

A. 2. 网络和通信安全

表 A-2 网络和通信安全测评结果记录

测评指标	测评对象	结果记录	量化指标				测评单元得分 $S_{i,j} = \frac{\sum_{1 \leq k \leq n_{i,j}} S_{i,j,k}}{n_{i,j}}$
			密码使用安全 D	密码算法/技术合规性 A	密钥管理安全 K	测评对象评分 $S_{i,j,k}$	
身份鉴别	办公内网国密浏览器与综合安全网关之间的通信信道	经访谈、配置检查及工具测试，业务端通过综合安全网关接入应用系统，使用服务端证书进行身份鉴别，证书通过中金金融认证中心有限公司的电子认证服务颁发，服务端证书存储在安全认证网关中，证书由中金金融认证中心有限公司颁发，证书信息见图 A-1，能够保证网络通信实体的真实性，使用的 SM2、SM3 算法经过国家密码管理部门认可，中金金融认证中心有限公司具有电子认证服务许可，许可证见图 A-2、图 A-3，使用的密码产品获得了商用密码产品认证证书，达到了密码产品二级安全要求，见图 A-4、图 A-5、图 A-6。	√	√	√	1.0000	0.7500

测评指标	测评对象	结果记录	量化指标				测评单元得分 $S_{ij} = \frac{\sum_{1 \leq k \leq n_{ij}} S_{ij,k}}{n_{ij}}$
			密码使用安全 D	密码算法/技术合规性 A	密钥管理安全 K	测评对象评分 $S_{i,j,k}$	
	办公内网运维客户端与综合安全网关之间的通信信道	经访谈、配置检查及工具测试，运维客户端通过综合安全网关接入内部网络，使用服务端证书进行身份鉴别，证书通过中金金融认证中心有限公司的电子认证服务颁发，服务端证书存储在综合安全网关中，证书信息见图 A-1，能够保证网络通信实体的真实性，使用的 SM2、SM3 算法经过国家密码管理部门认可，中金金融认证中心有限公司具有电子认证服务使用密码许可证及电子认证服务许可证，见图 A-2、图 A-3，使用的密码产品获得了商用密码产品认证证书，达到了密码产品二级安全要求，见图 A-4、图 A-5、图 A-6。	√	√	√	1.0000	
	互联网公众用户与新点电子交易平台之间的通信信道	经访谈、配置检查及工具测试，互联网公众用户通过非国密浏览器访问应用系统时采用 HTTPS 协议，使用服务端证书进行身份鉴别，证书信息见图 A-7，证书使用了 SHA384RSA 算法，但身份鉴别机制采用非商用密码算法。	√	×	×	0.2500	

测评指标	测评对象	结果记录	量化指标				测评单元得分 $S_{ij} = \frac{\sum_{1 \leq k \leq n_{ij}} S_{ij,k}}{n_{ij}}$
			密码使用安全 D	密码算法/技术合规性 A	密钥管理安全 K	测评对象评分 $S_{i,j,k}$	
通信数据完整性	办公内网国密浏览器与综合安全网关之间的通信信道	经访谈、配置检查及工具测试，通信过程中采用 GMTLS 协议进行通信，能够保证数据在通信过程的完整性，使用了 ECC_SM4_SM3 算法，协议算法标签见图 A-8。	√	√	√	1.0000	0.7500
	办公内网运维客户端与综合安全网关之间的通信信道	经访谈、配置检查及工具测试，通信过程中采用 TLCP 协议进行通信，能够保证数据在通信过程的完整性，使用了 SM4_CBC_SM3 算法，协议算法标签见图 A-9。	√	√	√	1.0000	
	互联网公众用户与新点电子交易平台之间的通信信道	经访谈、配置检查及工具测试，通信过程中采用 HTTPS 协议进行通信，见图 A-10，算法套件采用 TLS_ECDHE_RSA_WITH_AES256_GCM_SHA384，但通信过程中完整性保护机制采用非商用密码算法。	√	×	×	0.2500	

测评指标	测评对象	结果记录	量化指标				测评单元得分 $S_{ij} = \frac{\sum_{1 \leq k \leq n_{ij}} S_{ij,k}}{n_{ij}}$
			密码使用安全 D	密码算法/技术合规性 A	密钥管理安全 K	测评对象评分 $S_{i,j,k}$	
通信过程中重要数据的机密性	办公内网国密浏览器与综合安全网关之间的通信信道	经访谈、配置检查及工具测试，通信过程中采用 GMTLS 协议进行通信，能够保证数据在通信过程的机密性，使用了 ECC_SM4_SM3 算法，协议算法标签见图 A-8。	√	√	√	1.0000	0.7500
	办公内网运维客户端与综合安全网关之间的通信信道	经访谈、配置检查及工具测试，通信过程中采用 TLCP 协议进行通信，能够保证数据在通信过程的机密性，使用了 SM4_CBC_SM3 算法，协议算法标签见图 A-9。	√	√	√	1.0000	
	互联网公众用户与新点电子交易平台之间的通信信道	经访谈、配置检查及工具测试，通信过程中采用 HTTPS 协议进行通信，见图 A-10，算法套件采用 TLS_ECDHE_RSA_WITH_AES256_GCM_SHA384，但通信过程中机密性保护机制采用非商用密码算法。	√	×	×	0.2500	

测评指标	测评对象	结果记录	量化指标				测评单元得分 $S_{ij} = \frac{\sum_{1 \leq k \leq n_{ij}} S_{ij,k}}{n_{ij}}$
			密码使用安全 D	密码算法/技术合规性 A	密钥管理安全 K	测评对象评分 $S_{i,j,k}$	
网络边界访问控制信息的完整性	办公内网国密浏览器与综合安全网关之间的通信信道	经访谈及配置检查，使用综合安全网关进行网络边界的访问控制，通过密码产品自身的安全机制保证访问控制信息的完整性，综合安全网关获得了商用密码产品认证证书，达到了密码产品二级安全要求，见图 A-4、图 A-5。	√	√	√	1.0000	0.6667
	办公内网运维客户端与综合安全网关之间的通信信道	经访谈及配置检查，使用综合安全网关进行网络边界的访问控制，通过密码产品自身的安全机制保证访问控制信息的完整性，综合安全网关获得了商用密码产品认证证书，达到了密码产品二级安全要求，见图 A-4、图 A-5。	√	√	√	1.0000	
	互联网公众用户与新点电子交易平台之间的通信信道	未采用密码技术保证网络边界访问控制信息的完整性。	×	×	×	0	

测评指标	测评对象	结果记录	量化指标				测评单元得分 $S_{ij} = \frac{\sum_{1 \leq k \leq n_{ij}} S_{ij,k}}{n_{ij}}$
			密码使用安全 D	密码算法/技术合规性 A	密钥管理安全 K	测评对象评分 $S_{i,j,k}$	
安全接入认证	办公内网国密浏览器与综合安全网关之间的通信信道	依据密码应用方案，无安全接入认证需求，本项不适用。	N/A	N/A	N/A	N/A	N/A
	办公内网运维客户端与综合安全网关之间的通信信道	依据密码应用方案，无安全接入认证需求，本项不适用。	N/A	N/A	N/A	N/A	
	互联网公众用户与新点电子交易平台之间的通信信道	依据密码应用方案，无安全接入认证需求，本项不适用。	N/A	N/A	N/A	N/A	

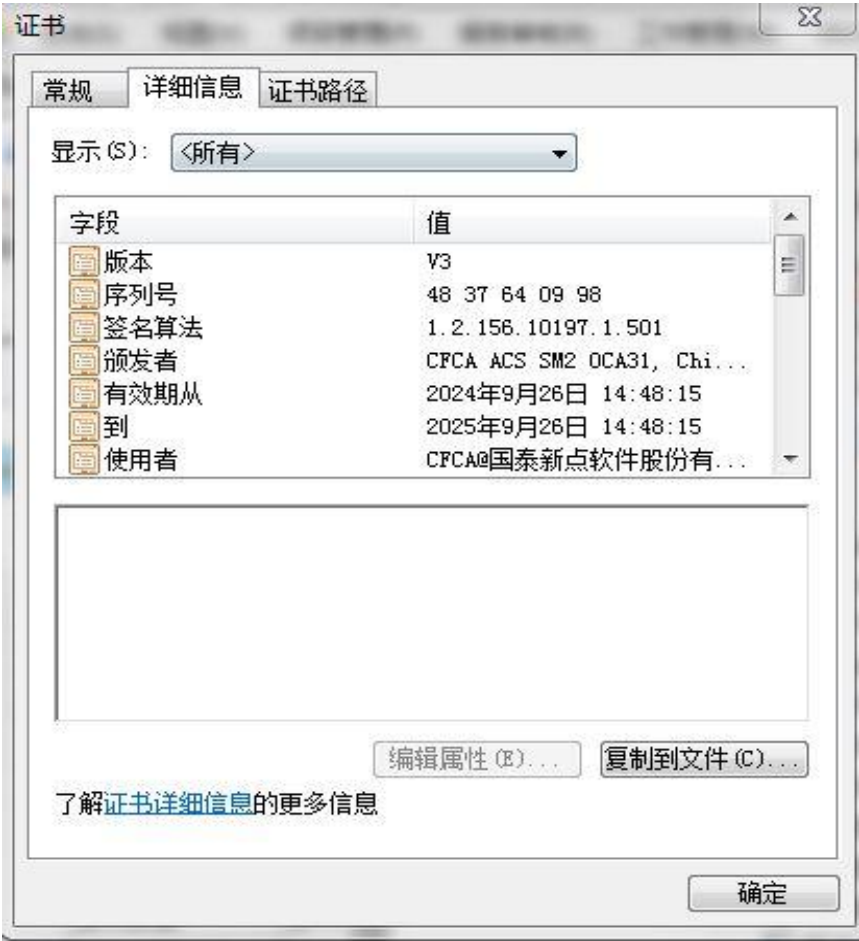


图 A-1 综合安全网关服务端证书



图 A-2 中金金融电子认证中心有限公司服务许可证

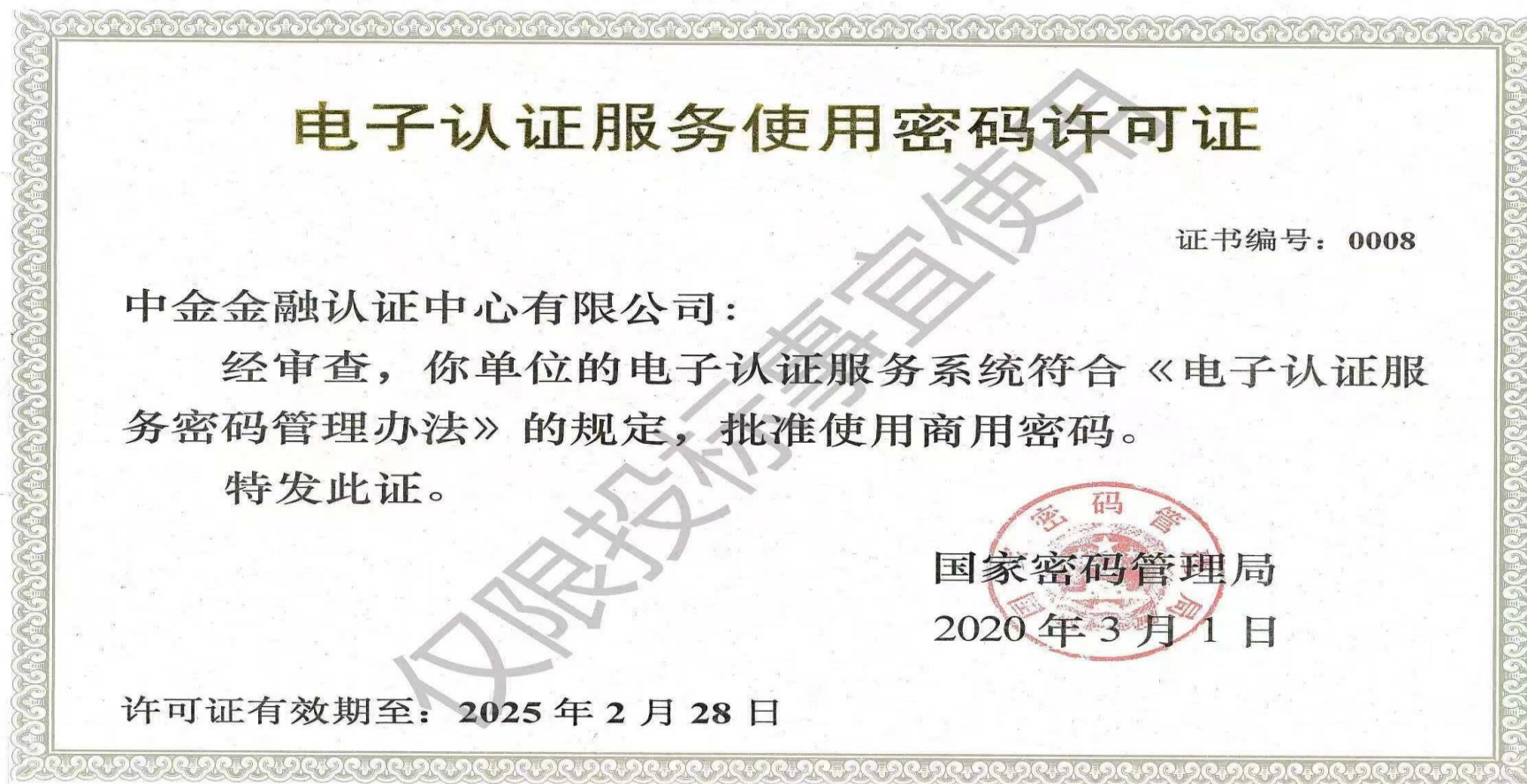


图 A-3 中金金融电子认证中心有限公司电子认证服务使用密码许可证



图 A-4 综合安全网关商用密码产品认证证书



图 A-5 综合安全网关商用密码产品型号证书



图 A-6 智能密码钥匙产品认证证书

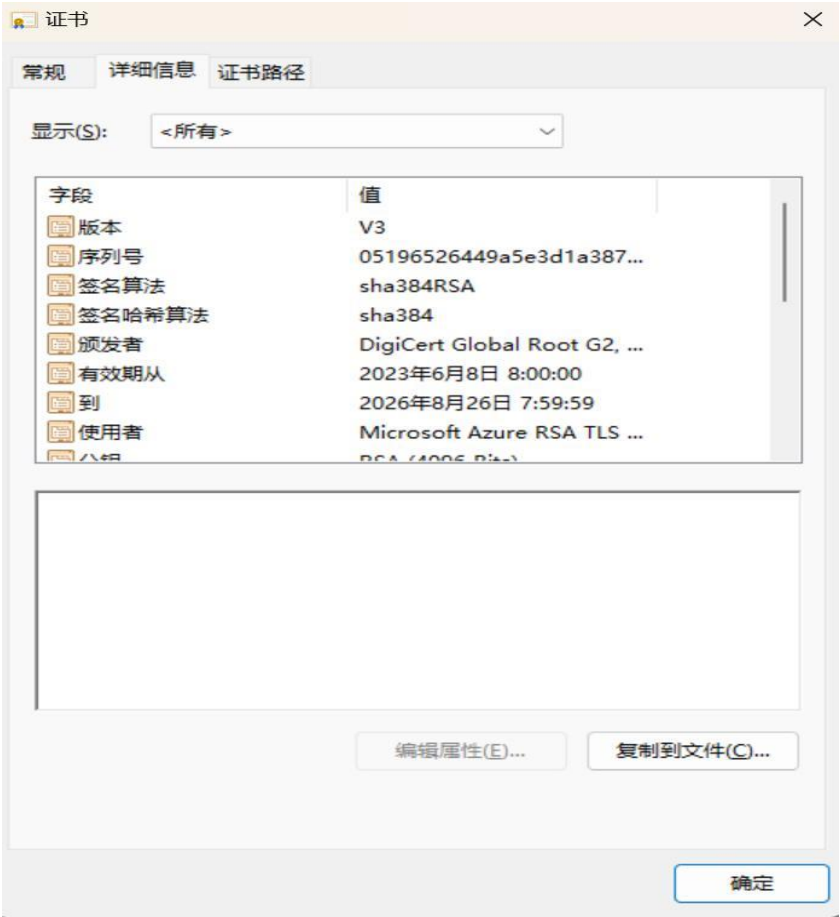


图 A-7 互联网公众用户与应用系统之间通信信道服务端证书

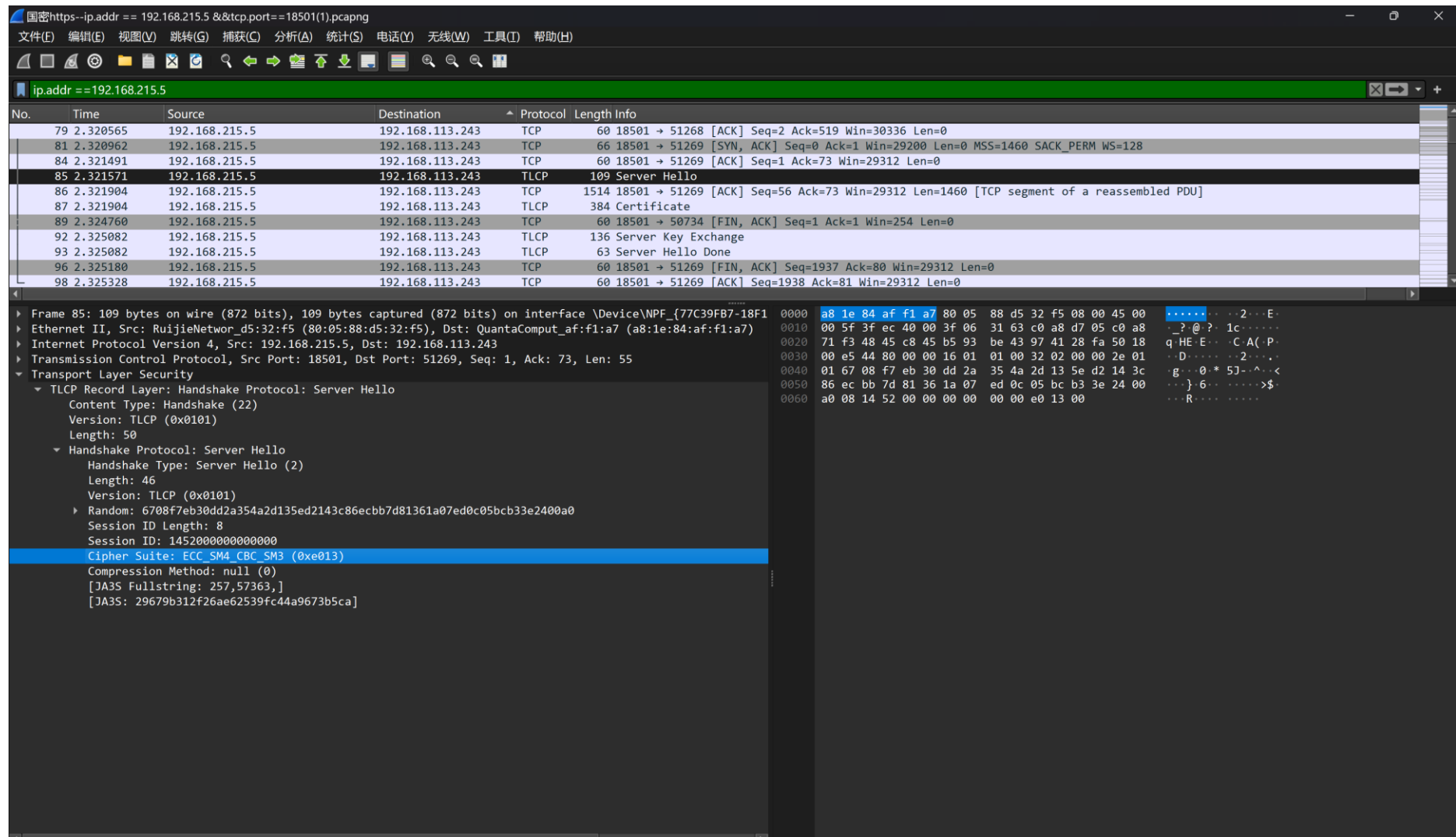


图 A-8 办公内网国密浏览器与综合安全网关之间通信信道算法标签

No.	Time	Source	Destination	Protocol	Length	Info
1007	72.129235	192.168.52.26	20.187.186.89	TCP	54	[TCP Dup ACK 1005#2] 54432 → 443 [ACK] Seq=2046 Ack=2721 Win=131840 Len=0
1008	72.129241	192.168.52.26	20.187.186.89	TCP	54	[TCP Dup ACK 1005#3] 54432 → 443 [ACK] Seq=2046 Ack=2721 Win=131840 Len=0
1009	72.129307	192.168.52.26	20.187.186.89	TCP	54	54432 → 443 [ACK] Seq=2046 Ack=5189 Win=131840 Len=0
1010	72.129314	192.168.52.26	20.187.186.89	TCP	54	[TCP Dup ACK 1009#1] 54432 → 443 [ACK] Seq=2046 Ack=5189 Win=131840 Len=0
1012	72.129696	192.168.52.26	20.187.186.89	TCP	118	[TCP Retransmission] 54432 → 443 [PSH, ACK] Seq=2046 Ack=5189 Win=131840 Len=64
1013	72.130203	192.168.52.26	20.187.186.89	TCP	1414	54432 → 443 [ACK] Seq=2110 Ack=5189 Win=131840 Len=1360 [TCP segment of a reassembled PDU]
1014	72.130203	192.168.52.26	20.187.186.89	TCP	1414	54432 → 443 [ACK] Seq=3470 Ack=5189 Win=131840 Len=1360 [TCP segment of a reassembled PDU]
1016	72.130214	192.168.52.26	20.187.186.89	TCP	1414	[TCP Retransmission] 54432 → 443 [ACK] Seq=2110 Ack=5189 Win=131840 Len=1360
1017	72.130232	192.168.52.26	20.187.186.89	TCP	1414	[TCP Retransmission] 54432 → 443 [ACK] Seq=3470 Ack=5189 Win=131840 Len=1360 [TCP segment of a reassembled PDU]
1018	72.130243	192.168.52.26	20.187.186.89	TCP	430	[TCP Retransmission] 54432 → 443 [PSH, ACK] Seq=4830 Ack=5189 Win=131840 Len=376 [TCP segment of a reassembled PDU]
1049	72.265851	192.168.52.26	20.187.186.89	TCP	54	54432 → 443 [ACK] Seq=5206 Ack=6460 Win=130560 Len=0
1050	72.265859	192.168.52.26	20.187.186.89	TCP	54	[TCP Dup ACK 1049#1] 54432 → 443 [ACK] Seq=5206 Ack=6460 Win=130560 Len=0
348	65.227685	192.168.52.26	218.4.136.119	TLCP	104	Client Hello
358	65.285087	218.4.136.119	192.168.52.26	TLCP	109	Server Hello
376	65.355044	218.4.136.119	192.168.52.26	TLCP	589	Certificate, Server Key Exchange, Certificate Request, Server Hello Done
382	65.397282	192.168.52.26	218.4.136.119	TLCP	410	Certificate
392	65.464588	192.168.52.26	218.4.136.119	TLCP	393	Client Key Exchange, Certificate Verify, Change Cipher Spec, Encrypted Handshake Message
406	65.543640	218.4.136.119	192.168.52.26	TLCP	60	Change Cipher Spec
414	65.650944	218.4.136.119	192.168.52.26	TLCP	139	Encrypted Handshake Message
658	68.676434	192.168.52.26	218.4.136.119	TLCP	223	Ignored Unknown Record
682	68.744497	192.168.52.26	218.4.136.119	TLCP	223	Ignored Unknown Record
754	69.433962	192.168.52.26	218.4.136.119	TLCP	223	Ignored Unknown Record
768	69.496648	192.168.52.26	218.4.136.119	TLCP	223	Ignored Unknown Record

▶ Frame 358: 109 bytes on wire (872 bits), 109 bytes captured (872 bits) on interface \Device\NPF_{33E86BE3-1E6C-4E17-B0E5-A172B64AC148}, id 0

▶ Ethernet II, Src: da:89:71:50:1a:a4 (da:89:71:50:1a:a4), Dst: Intel_db:2a:90 (7c:67:a2:db:2a:90)

▶ Internet Protocol Version 4, Src: 218.4.136.119, Dst: 192.168.52.26

▶ Transmission Control Protocol, Src Port: 8443, Dst Port: 54424, Seq: 17132, Ack: 196, Len: 55

▶ Transport Layer Security

- TLCP Record Layer: Handshake Protocol: Server Hello
 - Content Type: Handshake (22)
 - Version: TLCP (0x0101)
 - Length: 50
- Handshake Protocol: Server Hello
 - Handshake Type: Server Hello (2)
 - Length: 46
 - Version: TLCP (0x0101)
 - Random: 670650518ec1595aae4616890fc3a5fa37b18658d8d9a21f232cb88fd6b1829a3
 - Session ID Length: 8
 - Session ID: c702000000000000
 - Cipher Suite: ECC_SM4_CBC_SM3 (0xe013)
 - Compression Method: null (0)
 - [JA3S Fullstring: 257,57363,]
 - [JA3S: 29679b312f26ae62539fc44a9673b5ca]

图 A-9 办公内网运维客户端与综合安全网关之间通信信道 TLCP 协议算法标识

第16页/共 73 页

附录 A

6571	125.435055	192.168.113.243	192.168.141.141	TCP	54 51684 → 7680 [FIN, ACK] Seq=1 Ack=1 Win=513 Len=0
6572	125.436264	192.168.141.141	192.168.113.243	TCP	60 7680 → 51684 [ACK] Seq=1 Ack=2 Win=512 Len=0
6637	128.309207	192.168.113.243	218.4.136.118	TCP	55 [TCP Keep-Alive] 51665 → 7443 [ACK] Seq=1 Ack=2 Win=507 Len=1
6638	128.310148	218.4.136.118	192.168.113.243	TCP	60 7443 → 51665 [RST] Seq=2 Win=0 Len=0
6657	128.668334	192.168.113.243	192.168.215.5	TCP	54 51597 → 8181 [ACK] Seq=18126 Ack=51766 Win=4106 Len=0
6665	128.729616	192.168.113.243	192.168.215.5	TCP	54 51597 → 8181 [ACK] Seq=18851 Ack=52379 Win=4103 Len=0
6695	129.411543	192.168.113.243	192.168.105.37	TCP	66 [TCP Retransmission] 51746 → 7680 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
6705	130.024021	101.42.127.254	192.168.113.243	TCP	60 443 → 57420 [ACK] Seq=28 Ack=814 Win=641 Len=0
6791	133.727159	192.168.113.243	192.168.215.5	TCP	54 51597 → 8181 [ACK] Seq=18851 Ack=53775 Win=4106 Len=0
6795	133.793315	192.168.113.243	192.168.215.5	TCP	54 51597 → 8181 [ACK] Seq=19576 Ack=54388 Win=4103 Len=0
6827	135.250614	47.99.245.104	192.168.113.243	TCP	60 443 → 57430 [ACK] Seq=406 Ack=406 Win=42 Len=0
1	0.000000	192.168.113.243	101.42.127.254	TLSv1.2	83 Application Data
16	0.844931	192.168.113.243	202.89.233.100	TLSv1.2	559 Client Hello (SNI=www.bing.com)
25	0.911640	202.89.233.100	192.168.113.243	TLSv1.2	1433 Server Hello, Certificate, Certificate Status, Server Key Exchange, Server Hello Done
27	0.915297	192.168.113.243	202.89.233.100	TLSv1.2	212 Client Key Exchange, Change Cipher Spec, Encrypted Handshake Message
33	0.947513	202.89.233.100	192.168.113.243	TLSv1.2	396 New Session Ticket, Change Cipher Spec, Encrypted Handshake Message
34	0.947513	202.89.233.100	192.168.113.243	TLSv1.2	123 Application Data
36	0.948287	192.168.113.243	202.89.233.100	TLSv1.2	141 Application Data
37	0.948365	192.168.113.243	202.89.233.100	TLSv1.2	92 Application Data
38	0.948567	192.168.113.243	202.89.233.100	TLSv1.2	3233 Application Data
39	0.948713	192.168.113.243	202.89.233.100	TLSv1.2	1368 Application Data
40	0.948799	192.168.113.243	202.89.233.100	TLSv1.2	92 Application Data
42	0.972007	192.168.113.243	202.89.233.100	TLSv1.2	92 Application Data
▶ Frame 25: 1433 bytes on wire (11464 bits), 1433 bytes captured (11464 bits) on interface \Device\NPF_{77C39FB7-18F1-4664-8582-237C1185633F}, id 0 ▶ Ethernet II, Src: RuijieNetwork d5:32:f5 (80:05:88:d5:32:f5), Dst: QuantaComput_af:f1:a7 (a8:1e:84:af:f1:a7) ▶ Internet Protocol Version 4, Src: 202.89.233.100, Dst: 192.168.113.243 ▶ Transmission Control Protocol, Src Port: 443, Dst Port: 51725, Seq: 5841, Ack: 506, Len: 1379 ▶ [5 Reassembled TCP Segments (7219 bytes): #18(1460), #19(1460), #21(1460), #23(1460), #25(1379)] ▶ Transport Layer Security ▶ TLSv1.2 Record Layer: Handshake Protocol: Multiple Handshake Messages Content Type: Handshake (22) Version: TLS 1.2 (0x0303) Length: 7214 ▶ Handshake Protocol: Server Hello Handshake Type: Server Hello (2) Length: 98 Version: TLS 1.2 (0x0303) ▶ Random: 6708f0a40d55aa8f5b7465b5aa13a2df659ec333753e3251444f574e47524401 Session ID Length: 32 Session ID: 0605000b51719fb7a0c65c60bbf022e30c0d54266286d1f6a811c34c50c571 Cipher Suite: TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (0xc030) Compression Method: null (0) Extensions Length: 26 ▶ Extension: status_request (len=0) ▶ Extension: session_ticket (len=0) ▶ Extension: application_layer_protocol_negotiation (len=5) ▶ Extension: extended_master_secret (len=0) ▶ Extension: renegotiation_info (len=1) [JA3S Fullstring: 771,49200,5-35-16-23-65281] [JA3S: a66ea560599a2f5c89eec8c3a0d69cee] ▶ Handshake Protocol: Certificate ▶ Handshake Protocol: Certificate Status Handshake Type: Certificate Status (22) Length: 1850 Certificate Status Type: OCSP (1) OCSP Response Length: 1846 ▶ OCSP Response ▶ Handshake Protocol: Server Key Exchange ▶ Handshake Protocol: Server Hello Done Handshake Type: Server Hello Done (14) Length: 0					

图 A-10 互联网公众用户与应用系统之间的通信信道 HTTPS 协议算法标签

A. 3. 设备和计算安全

表 A-3 设备和计算安全测评结果记录

测评指标	测评对象	结果记录	量化指标				测评单元得分 $S_{ij} = \frac{\sum_{1 \leq k \leq n_{ij}} S_{ij,k}}{n_{ij}}$
			密码使用安全 D	密码算法/技术合规性 A	密钥管理安全 K	测评对象评分 $S_{i,j,k}$	
身份鉴别	服务器密码机	经访谈及配置检查，密码设备使用数字证书对登录的用户进行身份鉴别，证书由中金金融电子认证中心有限公司数字认证系统签发，电子认证服务许可见图 A-2，密码使用许可见图 A-3，证书信息存储在智能密码钥匙中，见图 A-11，使用的密码算法经国家密码管理部门认可，该密码产品获得了商用密码产品认证证书，达到了密码产品二级安全要求，见图 A-6。	√	√	√	1.0000	0.4444
	签名验签服务器	经访谈及配置检查，密码设备使用数字证书对登录的用户进行身份鉴别，证书由中金金融电子认证中心有限公司数字认证系统签发，证书信息存储在智能密码钥匙中，见图 A-11，使用的密码算法经国家密码管理部门认可，该密码产品获得了商用密码产品认证证书，达到了密码产品二级安全要求，见图 A-6。	√	√	√	1.0000	

测评指标	测评对象	结果记录	量化指标				测评单元得分 $S_{i,j} = \frac{\sum_{1 \leq k \leq n_{i,j}} S_{i,j,k}}{n_{i,j}}$
			密码使用安全 D	密码算法/技术合规性 A	密钥管理安全 K	测评对象评分 $S_{i,j,k}$	
	综合安全网关	经访谈及配置检查，密码设备使用数字证书对登录的用户进行身份鉴别，证书由中金金融电子认证中心有限公司数字认证系统签发，电子认证服务许可见图 A-2，密码使用许可见图 A-3，证书信息存储在智能密码钥匙中，见图 A-11，使用的密码算法经国家密码管理部门认可，该密码产品获得了商用密码产品认证证书，达到了密码产品二级安全要求，见图 A-6。	√	√	√	1.0000	
	时间戳服务器	经访谈及配置检查，密码设备使用数字证书对登录的用户进行身份鉴别，证书由中金金融电子认证中心有限公司数字认证系统签发，电子认证服务许可见图 A-2，密码使用许可见图 A-3，证书信息存储在智能密码钥匙中，见图 A-11，使用的密码算法经国家密码管理部门认可，该密码产品获得了商用密码产品认证证书，达到了密码产品二级安全要求，见图 A-6。	√	√	√	1.0000	
	新点电子签章系统	经访谈及配置检查，电子签章系统采用用户名/口令方式对登录的用户进行身份鉴别，未使用密码技术保证用户身份的真实性。	×	×	×	0	

测评指标	测评对象	结果记录	量化指标				测评单元得分 $S_{i,j} = \frac{\sum_{1 \leq k \leq n_{i,j}} S_{i,j,k}}{n_{i,j}}$
			密码使用安全 D	密码算法/技术合规性 A	密钥管理安全 K	测评对象评分 $S_{i,j,k}$	
	数据库	经访谈及配置检查，数据库使用用户名/口令形式进行身份鉴别，未使用密码技术保证用户身份的真实性。	×	×	×	0	
	应用服务器	经访谈及配置检查，服务器使用用户名/口令形式进行身份鉴别，未使用密码技术保证用户身份的真实性。	×	×	×	0	
	数据库服务器	经访谈及配置检查，服务器使用用户名/口令形式进行身份鉴别，未使用密码技术保证用户身份的真实性。	×	×	×	0	
	电子签章服务器	经访谈及配置检查，服务器使用用户名/口令形式进行身份鉴别，未使用密码技术保证用户身份的真实性。	×	×	×	0	
远程管理通道安全	服务器密码机	远程管理设备时，未采用密码技术建立安全的信息传输通道。	×	×	×	0	0.2222
	签名验签服务器	远程管理设备时，未采用密码技术建立安全的信息传输通道。	×	×	×	0	

测评指标	测评对象	结果记录	量化指标				测评单元得分 $S_{i,j} = \frac{\sum_{1 \leq k \leq n_{i,j}} S_{i,j,k}}{n_{i,j}}$
			密码使用安全 D	密码算法/技术合规性 A	密钥管理安全 K	测评对象评分 $S_{i,j,k}$	
	综合安全网关	经访谈、配置检查及工具测试，远程管理设备时，使用远程管理设备时使用 TLCP 协议进行通信，能够保证数据传输过程中的安全性，使用的 ECC_SM4_CBC_SM3 算法经过国家密码管理部门认可，TLCP 协议算法标识见图 A-12。	√	√	√	1.0000	
	时间戳服务器	远程管理设备时，未采用密码技术建立安全的信息传输通道。	×	×	×	0	
	新点电子签章系统	远程管理设备时，未采用密码技术建立安全的信息传输通道。	×	×	×	0	
	数据库	经访谈、配置检查，通过综合安全网关远程管理数据库时，先登录数据库服务器，在本地管理数据库，使用 SSH 协议进行通信，服务器配置见图 A-13，但远程管理通道采用非商用密码算法。	√	×	×	0.2500	
	应用服务器	经访谈、配置检查，通过安全认证网关远程管理服务时，使用了 SSH 协议进行通信，见图 A-14，但远程管理通道采用非商用密码算法。	√	×	×	0.2500	

测评指标	测评对象	结果记录	量化指标				测评单元得分 $S_{ij} = \frac{\sum_{1 \leq k \leq n_{ij}} S_{ij,k}}{n_{ij}}$
			密码使用安全 D	密码算法/技术合规性 A	密钥管理安全 K	测评对象评分 $S_{i,j,k}$	
	数据库服务器	经访谈、配置检查，通过安全认证网关远程管理服务器时，使用了 SSH 协议进行通信，见图 A-13，但远程管理通道采用非商用密码算法。	√	×	×	0.2500	
	电子签章服务器	经访谈、配置检查，通过安全认证网关远程管理服务器时，使用了 SSH 协议进行通信，见图 A-15，但远程管理通道采用非商用密码算法。	√	×	×	0.2500	
系统资源访问控制信息完整性	服务器密码机	经访谈及配置检查，使用密码产品自身的安全机制，能够保证系统资源访问控制信息的完整性，使用的密码产品获得了商用密码产品认证证书，见图 A-16。	√	√	√	1.0000	0.5556
	签名验签服务器	经访谈及配置检查，使用密码产品自身的安全机制，能够保证系统资源访问控制信息的完整性，使用的密码产品获得了商用密码产品认证证书，见图 A-17。	√	√	√	1.0000	
	综合安全网关	经访谈及配置检查，使用密码产品自身的安全机制，能够保证系统资源访问控制信息的完整性，使用的密码产品获得了商用密码产品认证证书，见图 A-4、图 A-5。	√	√	√	1.0000	

测评指标	测评对象	结果记录	量化指标				测评单元得分 $S_{i,j} = \frac{\sum_{1 \leq k \leq n_{i,j}} S_{i,j,k}}{n_{i,j}}$
			密码使用安全 D	密码算法/技术合规性 A	密钥管理安全 K	测评对象评分 $S_{i,j,k}$	
	时间戳服务器	经访谈及配置检查，使用密码产品自身的安全机制，能够保证系统资源访问控制信息的完整性，使用的密码产品获得了商用密码产品认证证书，见图 A-18。	√	√	√	1.0000	
	新点电子签章系统	经访谈及配置检查，使用密码产品自身的安全机制，能够保证系统资源访问控制信息的完整性，使用的密码产品获得了商用密码产品认证证书，见图 A-19。	√	√	√	1.0000	
	数据库	经访谈及配置检查，本地存储了各用户的身份信息及访问权限，授权方式为基于角色的访问控制，但未使用密码技术保证访问控制信息的完整性。	×	×	×	0	
	应用服务器	经访谈及配置检查，服务器本地存储了各用户的身份信息及访问权限，授权方式为基于角色的访问控制，但未使用密码技术保证访问控制信息的完整性。	×	×	×	0	
	数据库服务器	经访谈及配置检查，服务器本地存储了各用户的身份信息及访问权限，授权方式为基于角色的访问控制，但未使用密码技术保证访问控制信息的完整性。	×	×	×	0	

测评指标	测评对象	结果记录	量化指标				测评单元得分 $S_{i,j} = \frac{\sum_{1 \leq k \leq n_{i,j}} S_{i,j,k}}{n_{i,j}}$
			密码使用安全 D	密码算法/技术合规性 A	密钥管理安全 K	测评对象评分 $S_{i,j,k}$	
	电子签章服务器	经访谈及配置检查，服务器本地存储了各用户的身份信息及访问权限，授权方式为基于角色的访问控制，但未使用密码技术保证访问控制信息的完整性。	×	×	×	0	
重要信息资源安全标记完整性	服务器密码机	依据密码应用方案，服务器密码机无重要信息资源安全标记完整性需求，本项不适用。	N/A	N/A	N/A	N/A	N/A
	签名验签服务器	依据密码应用方案，签名验签服务器无重要信息资源安全标记完整性需求，本项不适用。	N/A	N/A	N/A	N/A	
	综合安全网关	依据密码应用方案，综合安全网关无重要信息资源安全标记完整性需求，本项不适用。	N/A	N/A	N/A	N/A	
	时间戳服务器	依据密码应用方案，时间戳服务器无重要信息资源安全标记完整性需求，本项不适用。	N/A	N/A	N/A	N/A	
	新点电子签章系统	依据密码应用方案，电子签章系统无重要信息资源安全标记完整性需求，本项不适用。	N/A	N/A	N/A	N/A	
	数据库	依据密码应用方案，数据库无重要信息资源安全标记完整性需求，本项不适用。	N/A	N/A	N/A	N/A	
	应用服务器	依据密码应用方案，服务器无重要信息资源安全标记完整性需求，本项不适用。	N/A	N/A	N/A	N/A	

测评指标	测评对象	结果记录	量化指标				测评单元得分 $S_{i,j} = \frac{\sum_{1 \leq k \leq n_{i,j}} S_{i,j,k}}{n_{i,j}}$
			密码使用安全 D	密码算法/技术合规性 A	密钥管理安全 K	测评对象评分 $S_{i,j,k}$	
	数据库服务器	依据密码应用方案，服务器无重要信息资源安全标记完整性需求，本项不适用。	N/A	N/A	N/A	N/A	
	电子签章服务器	依据密码应用方案，服务器无重要信息资源安全标记完整性需求，本项不适用。	N/A	N/A	N/A	N/A	
日志记录完整性	服务器密码机	经访谈及配置检查，使用密码产品自身的安全机制，能够保证日志记录的完整性，使用的密码产品获得了商用密码产品认证证书，见图 A-16。	√	√	√	1.0000	0.5556
	签名验签服务器	经访谈及配置检查，使用密码产品自身的安全机制，能够保证日志记录的完整性，使用的密码产品获得了商用密码产品认证证书，见图 A-17。	√	√	√	1.0000	
	综合安全网关	经访谈及配置检查，使用密码产品自身的安全机制，能够保证日志记录的完整性，使用的密码产品获得了商用密码产品认证证书，见图 A-4、图 A-5。	√	√	√	1.0000	
	时间戳服务器	经访谈及配置检查，使用密码产品自身的安全机制，能够保证日志记录的完整性，使用的密码产品获得了商用密码产品认证证书，见图 A-18。	√	√	√	1.0000	

测评指标	测评对象	结果记录	量化指标				测评单元得分 $S_{i,j} = \frac{\sum_{1 \leq k \leq n_{i,j}} S_{i,j,k}}{n_{i,j}}$
			密码使用安全 D	密码算法/技术合规性 A	密钥管理安全 K	测评对象评分 $S_{i,j,k}$	
	新点电子签章系统	经访谈及配置检查，使用密码产品自身的安全机制，能够保证日志记录的完整性，使用的密码产品获得了商用密码产品认证证书，见图 A-19。	√	√	√	1.0000	
	数据库	经访谈及配置检查，未使用密码技术保证日志记录的完整性。	×	×	×	0	
	应用服务器	经访谈及配置检查，未使用密码技术保证日志记录的完整性。	×	×	×	0	
	数据库服务器	经访谈及配置检查，未使用密码技术保证日志记录的完整性。	×	×	×	0	
	电子签章服务器	经访谈及配置检查，未使用密码技术保证日志记录的完整性。	×	×	×	0	
重要可执行程序完整性、重要可执行程序来源真实性	服务器密码机	经访谈及配置检查，使用密码产品自身的安全机制，能够保证重要可执行程序完整性、重要可执行程序来源真实性，使用的密码产品获得了商用密码产品认证证书，见图 A-16。	√	√	√	1.0000	0.5556

测评指标	测评对象	结果记录	量化指标				测评单元得分 $S_{i,j} = \frac{\sum_{1 \leq k \leq n_{i,j}} S_{i,j,k}}{n_{i,j}}$
			密码使用安全 D	密码算法/技术合规性 A	密钥管理安全 K	测评对象评分 $S_{i,j,k}$	
	签名验签服务器	经访谈及配置检查，使用密码产品自身的安全机制，能够保证重要可执行程序完整性、重要可执行程序来源真实性，使用的密码产品获得了商用密码产品认证证书，见图 A-17。	√	√	√	1.0000	
	综合安全网关	经访谈及配置检查，使用密码产品自身的安全机制，能够保证重要可执行程序完整性、重要可执行程序来源真实性，使用的密码产品获得了商用密码产品认证证书，见图 A-4、图 A-5。	√	√	√	1.0000	
	时间戳服务器	经访谈及配置检查，使用密码产品自身的安全机制，能够保证重要可执行程序完整性、重要可执行程序来源真实性，使用的密码产品获得了商用密码产品认证证书，见图 A-18。	√	√	√	1.0000	
	新点电子签章系统	经访谈及配置检查，使用密码产品自身的安全机制，能够保证重要可执行程序完整性、重要可执行程序来源真实性，使用的密码产品获得了商用密码产品认证证书，见图 A-19。	√	√	√	1.0000	

测评指标	测评对象	结果记录	量化指标				测评单元得分 $S_{i,j} = \frac{\sum_{1 \leq k \leq n_{i,j}} S_{i,j,k}}{n_{i,j}}$
			密码使用安全 D	密码算法/技术合规性 A	密钥管理安全 K	测评对象评分 $S_{i,j,k}$	
	数据库	经访谈及配置检查，未使用密码技术保证重要可执行程序完整性和来源的真实性。	×	×	×	0	
	应用服务器	经访谈及配置检查，未使用密码技术保证重要可执行程序完整性和来源的真实性。	×	×	×	0	
	数据库服务器	经访谈及配置检查，未使用密码技术保证重要可执行程序完整性和来源的真实性。	×	×	×	0	
	电子签章服务器	经访谈及配置检查，未使用密码技术保证重要可执行程序完整性和来源的真实性。	×	×	×	0	

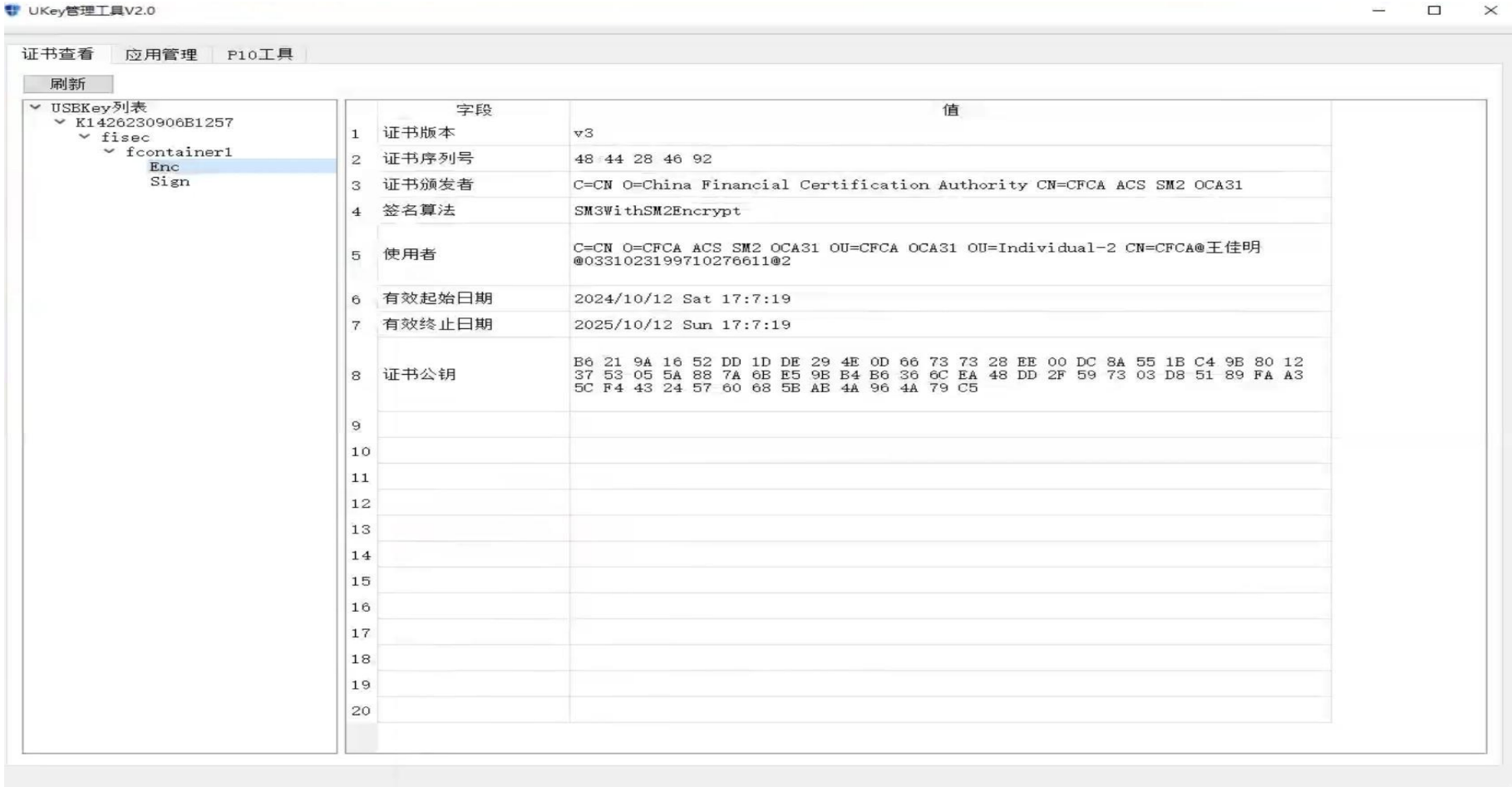


图 A-11 运维人员数字证书截图

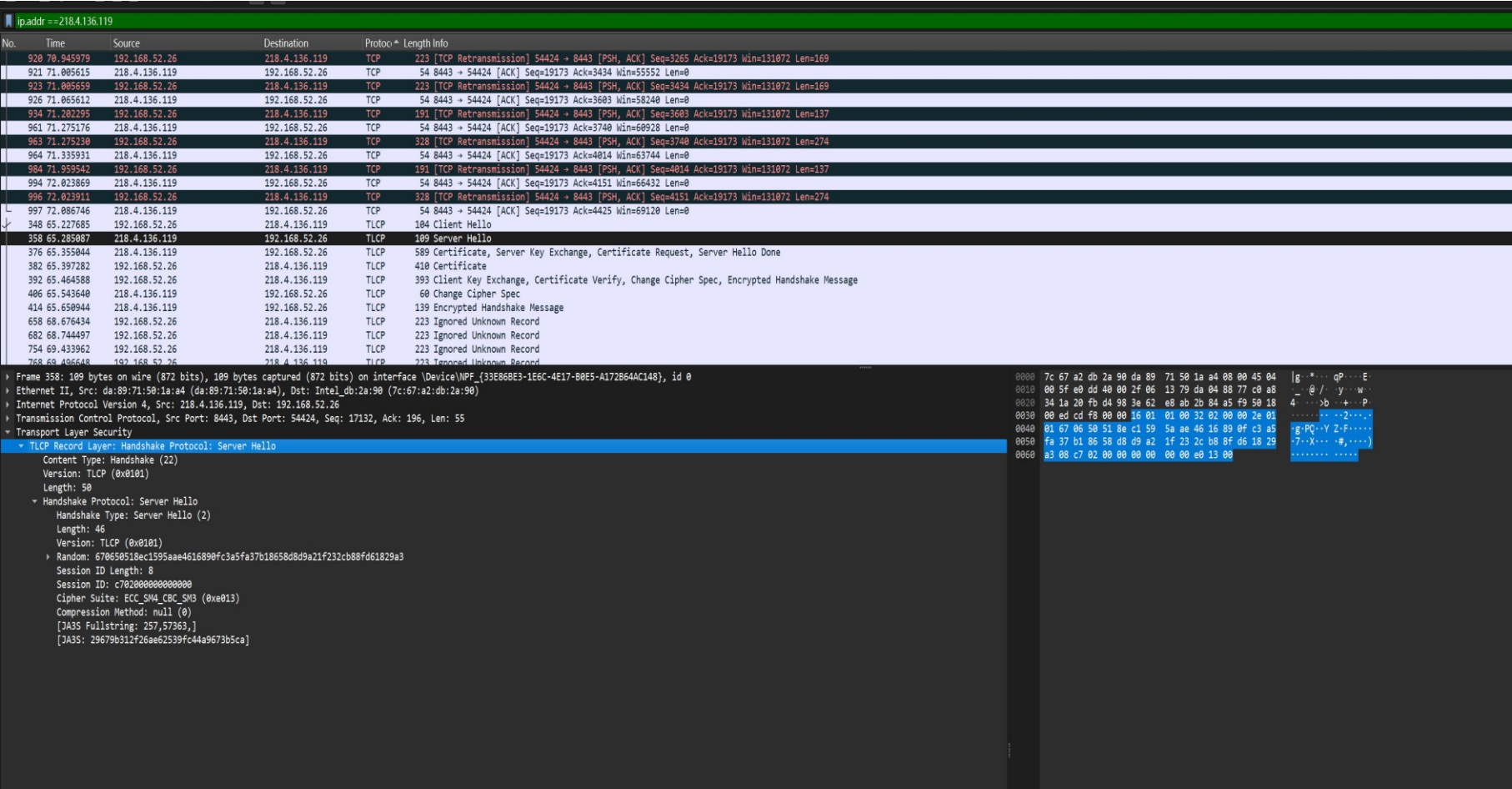


图 A-12 综合安全网关管理界面 TLCP 算法标签

```

bash-4.4$ openssl ciphers -v
TLS_AES_256_GCM_SHA384 TLSv1.3 Kx=any Au=any Enc=AESGCM(256) Mac=AEAD
TLS_CHACHA20_POLY1305_SHA256 TLSv1.3 Kx=any Au=any Enc=CHACHA20/POLY1305(256) Mac=AEAD
TLS_AES_128_GCM_SHA256 TLSv1.3 Kx=any Au=any Enc=AESGCM(128) Mac=AEAD
TLS_AES_128_CCM_SHA256 TLSv1.3 Kx=any Au=any Enc=AESCCM(128) Mac=AEAD
ECDHE-ECDSA-AES256-GCM-SHA384 TLSv1.2 Kx=ECDH Au=ECDSA Enc=AESGCM(256) Mac=AEAD
ECDHE-RSA-AES256-GCM-SHA384 TLSv1.2 Kx=ECDH Au=RSA Enc=AESGCM(256) Mac=AEAD
ECDHE-ECDSA-CHACHA20-POLY1305 TLSv1.2 Kx=ECDH Au=ECDSA Enc=CHACHA20/POLY1305(256) Mac=AEAD
ECDHE-RSA-CHACHA20-POLY1305 TLSv1.2 Kx=ECDH Au=RSA Enc=CHACHA20/POLY1305(256) Mac=AEAD
ECDHE-ECDSA-AES256-CCM TLSv1.2 Kx=ECDH Au=ECDSA Enc=AESCCM(256) Mac=AEAD
ECDHE-ECDSA-AES128-GCM-SHA256 TLSv1.2 Kx=ECDH Au=ECDSA Enc=AESGCM(128) Mac=AEAD
ECDHE-RSA-AES128-GCM-SHA256 TLSv1.2 Kx=ECDH Au=RSA Enc=AESGCM(128) Mac=AEAD
ECDHE-ECDSA-AES128-CCM TLSv1.2 Kx=ECDH Au=ECDSA Enc=AESCCM(128) Mac=AEAD
ECDHE-ECDSA-AES128-SHA256 TLSv1.2 Kx=ECDH Au=ECDSA Enc=AES(128) Mac=SHA256
ECDHE-RSA-AES128-SHA256 TLSv1.2 Kx=ECDH Au=RSA Enc=AES(128) Mac=SHA256
ECDHE-ECDSA-AES256-SHA TLSv1 Kx=ECDH Au=ECDSA Enc=AES(256) Mac=SHA1
ECDHE-RSA-AES256-SHA TLSv1 Kx=ECDH Au=RSA Enc=AES(256) Mac=SHA1
ECDHE-ECDSA-AES128-SHA TLSv1 Kx=ECDH Au=ECDSA Enc=AES(128) Mac=SHA1
ECDHE-RSA-AES128-SHA TLSv1 Kx=ECDH Au=RSA Enc=AES(128) Mac=SHA1
AES256-GCM-SHA384 TLSv1.2 Kx=RSA Au=RSA Enc=AESGCM(256) Mac=AEAD
AES256-CCM TLSv1.2 Kx=RSA Au=RSA Enc=AESCCM(256) Mac=AEAD
AES128-GCM-SHA256 TLSv1.2 Kx=RSA Au=RSA Enc=AESGCM(128) Mac=AEAD
AES128-CCM TLSv1.2 Kx=RSA Au=RSA Enc=AESCCM(128) Mac=AEAD
AES256-SHA256 TLSv1.2 Kx=RSA Au=RSA Enc=AES(256) Mac=SHA256
AES128-SHA256 TLSv1.2 Kx=RSA Au=RSA Enc=AES(128) Mac=SHA256
AES256-SHA SSLv3 Kx=RSA Au=RSA Enc=AES(256) Mac=SHA1
AES128-SHA SSLv3 Kx=RSA Au=RSA Enc=AES(128) Mac=SHA1

```

图 A-13 数据库服务器 SSH 算法标识

```
[root@192-168-215-205 ~]# openssl ciphers -v
ECDHE-RSA-AES256-GCM-SHA384 TLSv1.2 Kx=ECDH     Au=RSA     Enc=AESGCM(256) Mac=AEAD
ECDHE-ECDSA-AES256-GCM-SHA384 TLSv1.2 Kx=ECDH     Au=ECDSA   Enc=AESGCM(256) Mac=AEAD
ECDHE-RSA-AES256-SHA384 TLSv1.2 Kx=ECDH     Au=RSA     Enc=AES(256) Mac=SHA384
ECDHE-ECDSA-AES256-SHA384 TLSv1.2 Kx=ECDH     Au=ECDSA   Enc=AES(256) Mac=SHA384
ECDHE-RSA-AES256-SHA SSLv3 Kx=ECDH     Au=RSA     Enc=AES(256) Mac=SHA1
ECDHE-ECDSA-AES256-SHA SSLv3 Kx=ECDH     Au=ECDSA   Enc=AES(256) Mac=SHA1
DH-DSS-AES256-GCM-SHA384 TLSv1.2 Kx=DH/DSS   Au=DH     Enc=AESGCM(256) Mac=AEAD
DHE-DSS-AES256-GCM-SHA384 TLSv1.2 Kx=DH     Au=DSS     Enc=AESGCM(256) Mac=AEAD
DH-RSA-AES256-GCM-SHA384 TLSv1.2 Kx=DH/RSA   Au=DH     Enc=AESGCM(256) Mac=AEAD
DHE-RSA-AES256-GCM-SHA384 TLSv1.2 Kx=DH     Au=RSA     Enc=AESGCM(256) Mac=AEAD
DHE-RSA-AES256-SHA256 TLSv1.2 Kx=DH     Au=RSA     Enc=AES(256) Mac=SHA256
DHE-DSS-AES256-SHA256 TLSv1.2 Kx=DH     Au=DSS     Enc=AES(256) Mac=SHA256
DH-RSA-AES256-SHA256 TLSv1.2 Kx=DH/RSA   Au=DH     Enc=AES(256) Mac=SHA256
DH-DSS-AES256-SHA256 TLSv1.2 Kx=DH/DSS   Au=DH     Enc=AES(256) Mac=SHA256
DHE-RSA-AES256-SHA SSLv3 Kx=DH     Au=RSA     Enc=AES(256) Mac=SHA1
DHE-DSS-AES256-SHA SSLv3 Kx=DH     Au=DSS     Enc=AES(256) Mac=SHA1
DH-RSA-AES256-SHA SSLv3 Kx=DH/RSA   Au=DH     Enc=AES(256) Mac=SHA1
DH-DSS-AES256-SHA SSLv3 Kx=DH/DSS   Au=DH     Enc=AES(256) Mac=SHA1
DHE-RSA-CAMELLIA256-SHA SSLv3 Kx=DH     Au=RSA     Enc=Camellia(256) Mac=SHA1
DHE-DSS-CAMELLIA256-SHA SSLv3 Kx=DH     Au=DSS     Enc=Camellia(256) Mac=SHA1
DH-RSA-CAMELLIA256-SHA SSLv3 Kx=DH/RSA   Au=DH     Enc=Camellia(256) Mac=SHA1
DH-DSS-CAMELLIA256-SHA SSLv3 Kx=DH/DSS   Au=DH     Enc=Camellia(256) Mac=SHA1
ECDH-RSA-AES256-GCM-SHA384 TLSv1.2 Kx=ECDH/RSA Au=ECDH     Enc=AESGCM(256) Mac=AEAD
ECDH-ECDSA-AES256-GCM-SHA384 TLSv1.2 Kx=ECDH/ECDSA Au=ECDH     Enc=AESGCM(256) Mac=AEAD
ECDH-RSA-AES256-SHA384 TLSv1.2 Kx=ECDH/RSA Au=ECDH     Enc=AES(256) Mac=SHA384
ECDH-ECDSA-AES256-SHA384 TLSv1.2 Kx=ECDH/ECDSA Au=ECDH     Enc=AES(256) Mac=SHA384
ECDH-RSA-AES256-SHA SSLv3 Kx=ECDH/RSA Au=ECDH     Enc=AES(256) Mac=SHA1
ECDH-ECDSA-AES256-SHA SSLv3 Kx=ECDH/ECDSA Au=ECDH     Enc=AES(256) Mac=SHA1
AES256-GCM-SHA384 TLSv1.2 Kx=RSA     Au=RSA     Enc=AESGCM(256) Mac=AEAD
AES256-SHA256 TLSv1.2 Kx=RSA     Au=RSA     Enc=AES(256) Mac=SHA256
AES256-SHA SSLv3 Kx=RSA     Au=RSA     Enc=AES(256) Mac=SHA1
CAMELLIA256-SHA SSLv3 Kx=RSA     Au=RSA     Enc=Camellia(256) Mac=SHA1
PSK-AES256-CBC-SHA SSLv3 Kx=PSK     Au=PSK     Enc=AES(256) Mac=SHA1
ECDHE-RSA-AES128-GCM-SHA256 TLSv1.2 Kx=ECDH     Au=RSA     Enc=AESGCM(128) Mac=AEAD
ECDHE-ECDSA-AES128-GCM-SHA256 TLSv1.2 Kx=ECDH     Au=ECDSA   Enc=AESGCM(128) Mac=AEAD
ECDHE-RSA-AES128-SHA256 TLSv1.2 Kx=ECDH     Au=RSA     Enc=AES(128) Mac=SHA256
ECDHE-ECDSA-AES128-SHA256 TLSv1.2 Kx=ECDH     Au=ECDSA   Enc=AES(128) Mac=SHA256
ECDHE-RSA-AES128-SHA SSLv3 Kx=ECDH     Au=RSA     Enc=AES(128) Mac=SHA1
ECDHE-ECDSA-AES128-SHA SSLv3 Kx=ECDH     Au=ECDSA   Enc=AES(128) Mac=SHA1
DH-DSS-AES128-GCM-SHA256 TLSv1.2 Kx=DH/DSS   Au=DH     Enc=AESGCM(128) Mac=AEAD
DHE-DSS-AES128-GCM-SHA256 TLSv1.2 Kx=DH     Au=DSS     Enc=AESGCM(128) Mac=AEAD
DH-RSA-AES128-GCM-SHA256 TLSv1.2 Kx=DH/RSA   Au=DH     Enc=AESGCM(128) Mac=AEAD
DHE-RSA-AES128-GCM-SHA256 TLSv1.2 Kx=DH     Au=RSA     Enc=AESGCM(128) Mac=AEAD
DHE-RSA-AES128-SHA256 TLSv1.2 Kx=DH     Au=RSA     Enc=AES(128) Mac=SHA256
DHE-DSS-AES128-SHA256 TLSv1.2 Kx=DH     Au=DSS     Enc=AES(128) Mac=SHA256
DH-RSA-AES128-SHA256 TLSv1.2 Kx=DH/RSA   Au=DH     Enc=AES(128) Mac=SHA256
DH-DSS-AES128-SHA256 TLSv1.2 Kx=DH/DSS   Au=DH     Enc=AES(128) Mac=SHA256
DHE-RSA-AES128-SHA SSLv3 Kx=DH     Au=RSA     Enc=AES(128) Mac=SHA1
DHE-DSS-AES128-SHA SSLv3 Kx=DH     Au=DSS     Enc=AES(128) Mac=SHA1
DH-RSA-AES128-SHA SSLv3 Kx=DH/RSA   Au=DH     Enc=AES(128) Mac=SHA1
DH-DSS-AES128-SHA SSLv3 Kx=DH/DSS   Au=DH     Enc=AES(128) Mac=SHA1
DHE-RSA-SEED-SHA SSLv3 Kx=DH     Au=RSA     Enc=SEED(128) Mac=SHA1
DHE-DSS-SEED-SHA SSLv3 Kx=DH     Au=DSS     Enc=SEED(128) Mac=SHA1
DH-RSA-SEED-SHA SSLv3 Kx=DH/RSA   Au=DH     Enc=SEED(128) Mac=SHA1
DH-DSS-SEED-SHA SSLv3 Kx=DH/DSS   Au=DH     Enc=SEED(128) Mac=SHA1
DHE-RSA-CAMELLIA128-SHA SSLv3 Kx=DH     Au=RSA     Enc=Camellia(128) Mac=SHA1
DHE-DSS-CAMELLIA128-SHA SSLv3 Kx=DH     Au=DSS     Enc=Camellia(128) Mac=SHA1
DH-RSA-CAMELLIA128-SHA SSLv3 Kx=DH/RSA   Au=DH     Enc=Camellia(128) Mac=SHA1
DH-DSS-CAMELLIA128-SHA SSLv3 Kx=DH/DSS   Au=DH     Enc=Camellia(128) Mac=SHA1
```

图 A-14 应用服务器 SSH 算法标识


```

bash-4.2$ openssl ciphers -v
TLS_AES_256_GCM_SHA384 TLSv1.3 Kx=any Au=any Enc=AESGCM(256) Mac=AEAD
TLS_CHACHA20_POLY1305_SHA256 TLSv1.3 Kx=any Au=any Enc=CHACHA20/POLY1305(256) Mac=AEAD
TLS_AES_128_GCM_SHA256 TLSv1.3 Kx=any Au=any Enc=AESGCM(128) Mac=AEAD
ECDHE-ECDSA-AES256-GCM-SHA384 TLSv1.2 Kx=ECDH Au=ECDSA Enc=AESGCM(256) Mac=AEAD
ECDHE-RSA-AES256-GCM-SHA384 TLSv1.2 Kx=ECDH Au=RSA Enc=AESGCM(256) Mac=AEAD
DHE-RSA-AES256-GCM-SHA384 TLSv1.2 Kx=DH Au=RSA Enc=AESGCM(256) Mac=AEAD
ECDHE-ECDSA-CHACHA20-POLY1305 TLSv1.2 Kx=ECDH Au=ECDSA Enc=CHACHA20/POLY1305(256) Mac=AEAD
ECDHE-RSA-CHACHA20-POLY1305 TLSv1.2 Kx=ECDH Au=RSA Enc=CHACHA20/POLY1305(256) Mac=AEAD
DHE-RSA-CHACHA20-POLY1305 TLSv1.2 Kx=DH Au=RSA Enc=CHACHA20/POLY1305(256) Mac=AEAD
ECDHE-ECDSA-AES128-GCM-SHA256 TLSv1.2 Kx=ECDH Au=ECDSA Enc=AESGCM(128) Mac=AEAD
ECDHE-RSA-AES128-GCM-SHA256 TLSv1.2 Kx=ECDH Au=RSA Enc=AESGCM(128) Mac=AEAD
DHE-RSA-AES128-GCM-SHA256 TLSv1.2 Kx=DH Au=RSA Enc=AESGCM(128) Mac=AEAD
ECDHE-ECDSA-AES256-SHA384 TLSv1.2 Kx=ECDH Au=ECDSA Enc=AES(256) Mac=SHA384
ECDHE-RSA-AES256-SHA384 TLSv1.2 Kx=ECDH Au=RSA Enc=AES(256) Mac=SHA384
DHE-RSA-AES256-SHA256 TLSv1.2 Kx=DH Au=RSA Enc=AES(256) Mac=SHA256
ECDHE-ECDSA-AES128-SHA256 TLSv1.2 Kx=ECDH Au=ECDSA Enc=AES(128) Mac=SHA256
ECDHE-RSA-AES128-SHA256 TLSv1.2 Kx=ECDH Au=RSA Enc=AES(128) Mac=SHA256
DHE-RSA-AES128-SHA256 TLSv1.2 Kx=DH Au=RSA Enc=AES(128) Mac=SHA256
ECDHE-ECDSA-AES256-SHA TLSv1 Kx=ECDH Au=ECDSA Enc=AES(256) Mac=SHA1
ECDHE-RSA-AES256-SHA TLSv1 Kx=ECDH Au=RSA Enc=AES(256) Mac=SHA1
DHE-RSA-AES256-SHA SSLv3 Kx=DH Au=RSA Enc=AES(256) Mac=SHA1
ECDHE-ECDSA-AES128-SHA TLSv1 Kx=ECDH Au=ECDSA Enc=AES(128) Mac=SHA1
ECDHE-RSA-AES128-SHA TLSv1 Kx=ECDH Au=RSA Enc=AES(128) Mac=SHA1
DHE-RSA-AES128-SHA SSLv3 Kx=DH Au=RSA Enc=AES(128) Mac=SHA1
RSA-PSK-AES256-GCM-SHA384 TLSv1.2 Kx=RSAPSK Au=RSA Enc=AESGCM(256) Mac=AEAD

```

图 A-15 电子签章服务器 SSH 算法标识



图 A-16 服务器密码机商用密码产品认证证书



图 A-17 签名验签服务器商用密码产品认证证书



图 A-18 时间戳服务器产品认证证书



图 A-19 新点电子签章系统 V1.0 商用密码产品认证证书

A. 4. 应用和数据安全

表 A-4 应用和数据安全测评结果记录

测评指标	测评对象	结果记录	量化指标				测评单元得分 $S_{i,j} = \frac{\sum_{1 \leq k \leq n_{i,j}} S_{i,j,k}}{n_{i,j}}$
			密码使用安全 D	密码算法/技术合规性 A	密钥管理安全 K	测评对象评分 $S_{i,j,k}$	
身份鉴别	业务用户	经访谈及配置检查，业务用户利用配发的智能密码钥匙访问应用系统，使用基于 SM2 算法的挑战-响应机制实现系统用户的身份鉴别。用户通过终端向应用服务端发起登录请求，应用服务端向终端返回随机数，终端通过智能密码钥匙对随机数进行签名并发送给应用服务端，应用服务端判断通过验证后则分配访问权限，使用的证书通过中金金融认证中心有限公司颁发，中金金融认证中心有限公司具有电子认证服务使用密码许可证，私钥存储在智能密码钥匙中，使用的证书信息见图 A-20，电子认证服务使用密码许可证见图 A-3，电子认证服务许可见图 A-2，能够保证登录应用系统的用户的真实性。使用的智能密码钥匙获得了商用密码产品认证证书，达到了密码产品二级安全要求，见图 A-6。	√	√	√	1.0000	0.5000

测评指标	测评对象	结果记录	量化指标				测评单元得分 $S_{i,j}$ $= \frac{\sum_{1 \leq k \leq n_{i,j}} S_{i,j,k}}{n_{i,j}}$
			密码使用安全 D	密码算法/技术合规性 A	密钥管理安全 K	测评对象评分 $S_{i,j,k}$	
	公众用户	经访谈及配置检查，应用系统公众用户通过用户名+口令+手机验证码进行身份鉴别，未使用密码技术对登录用户的身份真实性进行鉴别。	×	×	×	0	
访问控制信息完整性	新点电子交易平台	经访谈、配置核查，在数据库中存储了应用系统的访问控制策略、数据库表访问控制信息，并使用服务器密码机对访问控制信息进行了签名，签名值存储在数据库中，数据存储情况见图 A-21，能够保证访问控制信息的完整性，使用的 SM2、SM3 算法经过国家密码管理部门认可，调用服务器密码机进行签名代码截图见图 A-22，完整性验证结果见图 A-23，使用的服务器密码机获得了商用密码产品认证证书，达到了密码产品二级安全要求，见图 A-16。	√	√	√	1.0000	1.0000
重要信息资源安全标记完整性	新点电子交易平台	根据密码应用方案，本系统不涉及重要信息资源安全标记，本项不适用。	N/A	N/A	N/A	N/A	N/A
重要数据传输机密性	个人信息数据	经访谈及配置检查，未使用密码技术保护数据在传输过程中的机密性。	×	×	×	0	0

测评指标	测评对象	结果记录	量化指标				测评单元得分 $S_{i,j} = \frac{\sum_{1 \leq k \leq n_{i,j}} S_{i,j,k}}{n_{i,j}}$
			密码使用安全 D	密码算法/技术合规性 A	密钥管理安全 K	测评对象评分 $S_{i,j,k}$	
	鉴别数据（数字证书）	经访谈及配置检查，用户私钥存储在智能密码钥匙中，不进行传输，公钥数据无机密性保护需求。	N/A	N/A	N/A	N/A	
	业务数据	经访谈及配置检查，未使用密码技术保护数据在传输过程中的机密性。	×	×	×	0	
	日志数据	依据商用密码应用方案，日志数据无机密性保护需求，不适用。	N/A	N/A	N/A	N/A	
	鉴别数据（非数字证书）	经访谈及配置检查，未使用密码技术保护数据在传输过程中的机密性。	×	×	×	0	
重要数据存储机密性	个人信息数据	经访谈及配置检查，应用系统使用 SM4 算法对重要数据进行加密后存储在数据库中，加密过程在服务器密码机中完成，能够保证数据存储的机密性，数据存储情况见图 A-24，调用服务器密码机代码见图 A-25，使用的算法经国家密码管理部门认可，使用的密码产品具有商用密码产品认证证书，达到了密码产品二级安全要求，见图 A-16。	√	√	√	1.0000	1.0000

测评指标	测评对象	结果记录	量化指标				测评单元得分 $S_{i,j} = \frac{\sum_{1 \leq k \leq n_{i,j}} S_{i,j,k}}{n_{i,j}}$
			密码使用安全 D	密码算法/技术合规性 A	密钥管理安全 K	测评对象评分 $S_{i,j,k}$	
	鉴别数据（数字证书）	经访谈及配置检查，用户私钥存储在智能密码钥匙中，使用智能密码钥匙自身的安全机制保证数据存储的机密性，公钥数据无机密性保护需求，使用的智能密码钥匙具有商用密码产品型号证书见图 A-6。	√	√	√	1.0000	
	业务数据	经访谈及配置检查，应用系统使用 SM4 算法对重要数据进行加密后存储在数据库中，加密过程在服务器密码机中完成，能够保证数据存储的机密性，数据存储情况见图 A-26，调用服务器密码机代码见图 A-25，使用的算法经国家密码管理部门认可，使用的密码产品具有商用密码产品认证证书，达到了密码产品二级安全要求，见图 A-16。	√	√	√	1.0000	
	日志数据	依据商用密码应用方案，日志数据无机密性保护需求，不适用。	N/A	N/A	N/A	N/A	

测评指标	测评对象	结果记录	量化指标				测评单元得分 $S_{i,j}$ $= \frac{\sum_{1 \leq k \leq n_{i,j}} S_{i,j,k}}{n_{i,j}}$
			密码使用安全 D	密码算法/技术合规性 A	密钥管理安全 K	测评对象评分 $S_{i,j,k}$	
	鉴别数据 (非数字证书)	经访谈及配置检查，应用系统使用 SM4 算法对重要数据进行加密后存储在数据库中，加密过程在服务器密码机中完成，能够保证数据存储在数据库中的机密性，数据存储情况见图 A-27，调用服务器密码机代码见图 A-25，使用的算法经国家密码管理部门认可，使用的密码产品具有商用密码产品认证证书，达到了密码产品二级安全要求，见图 A-16。	√	√	√	1.0000	
重要数据传输完整性	个人信息数据	经访谈及配置检查，未使用密码技术保护数据在传输过程中的完整性。	×	×	×	0	0.2500
	鉴别数据 (数字证书)	经访谈及配置检查，用户私钥存储在智能密码钥匙中，不进行传输，公钥由公钥证书的安全机制保证数据传输的完整性，证书使用的 SM2、SM3 算法经国家密码管理部门认可。使用的智能密码钥匙具有商用密码产品型号证书见图 A-6。证书通过中金金融电子认证中心有限公司的电子认证服务颁发，证书见图 A-2，电子认证服务使用密码许可证见图 A-3。	√	√	√	1.0000	
	业务数据	经访谈及配置检查，未使用密码技术保护数据在传输过程中的完整性。	×	×	×	0	

测评指标	测评对象	结果记录	量化指标				测评单元得分 $S_{i,j} = \frac{\sum_{1 \leq k \leq n_{i,j}} S_{i,j,k}}{n_{i,j}}$
			密码使用安全 D	密码算法/技术合规性 A	密钥管理安全 K	测评对象评分 $S_{i,j,k}$	
	日志数据	依据商用密码应用方案，日志数据无机密性保护需求，不适用。	N/A	N/A	N/A	N/A	
	鉴别数据（非数字证书）	经访谈及配置检查，未使用密码技术保护数据在传输过程中的完整性。	×	×	×	0	
重要数据存储完整性	个人信息数据	经访谈及配置检查，应用系统使用 SM2、SM3 算法的数字签名技术对数据进行签名后，将签名值存储在数据库中，签名过程在服务器密码机中完成，数据存储情况见图 A-24，调用服务器密码机进行签名代码见图 A-22、完整性保护验证结果见图 A-28，使用的 SM2、SM3 算法经国家密码管理部门认可，使用的密码产品具有商用密码产品认证证书，达到了密码产品二级安全要求，见图 A-16。	√	√	√	1.0000	1.0000

测评指标	测评对象	结果记录	量化指标				测评单元得分 $S_{i,j} = \frac{\sum_{1 \leq k \leq n_{i,j}} S_{i,j,k}}{n_{i,j}}$
			密码使用安全 D	密码算法/技术合规性 A	密钥管理安全 K	测评对象评分 $S_{i,j,k}$	
	鉴别数据 (数字证书)	经访谈及配置检查，用户的私钥存储于智能密码钥匙中，通过智能密码钥匙的安全机制保护其完整性。公钥由证书方式存储，通过数字证书技术保护其存储完整性，使用的签名算法为 SM3 算法。使用的智能密码钥匙具有商用密码产品认证证书，见图 A-6。证书通过中金金融电子认证中心有限公司的电子认证服务颁发，许可证见图 A-3、图 A-2。	√	√	√	1.0000	
	业务数据	经访谈及配置检查，应用系统使用 SM2、SM3 算法的数字签名技术对数据进行签名后，将签名值存储在数据库中，签名过程在服务器密码机中完成，数据存储情况见图 A-26，调用服务器密码机进行签名的代码截图见图 A-22，完整性结果见图 A-29，使用的 SM2、SM3 算法经国家密码管理部门认可，使用的密码产品具有商用密码产品认证证书，达到了密码产品二级安全要求，见图 A-16。	√	√	√	1.0000	

测评指标	测评对象	结果记录	量化指标				测评单元得分 $S_{i,j} = \frac{\sum_{1 \leq k \leq n_{i,j}} S_{i,j,k}}{n_{i,j}}$
			密码使用安全 D	密码算法/技术合规性 A	密钥管理安全 K	测评对象评分 $S_{i,j,k}$	
	日志数据	经访谈、配置核查，日志数据通过服务器密码机进行了签名，签名值存储在数据库中，日志数据存储情况见图 A-30，能够保证应用系统日志数据完整性，使用的 SM2、SM3 算法经过国家密码管理部门认可，实现完整性保护代码截图见图 A-22，完整性验证结果见图 A-31，使用的服务器密码机获得了商用密码产品认证证书，达到了密码产品二级安全要求，见图 A-16。	√	√	√	1.0000	
	鉴别数据（非数字证书）	经访谈及配置检查，应用系统使用 SM2、SM3 算法的数字签名技术对数据进行签名后，将签名值存储在数据库中，签名过程在服务器密码机中完成，数据存储情况见图 A-27，调用服务器密码机进行签名的代码截图见图 A-22，数据完整性验证结果见图 A-32，使用的 SM2、SM3 算法经国家密码管理部门认可，使用的密码产品具有商用密码产品认证证书，达到了密码产品二级安全要求，见图 A-16。	√	√	√	1.0000	

测评指标	测评对象	结果记录	量化指标				测评单元得分 $S_{i,j} = \frac{\sum_{1 \leq k \leq n_{i,j}} S_{i,j,k}}{n_{i,j}}$
			密码使用安全 D	密码算法/技术合规性 A	密钥管理安全 K	测评对象评分 $S_{i,j,k}$	
不可否认性	应用系统重要操作行为	经访谈及配置检查，当对投标文件、合同文件加盖电子公章及签名时，应用系统使用操作人员智能密码钥匙中的私钥对电子印章数据及操作日志进行签名，并调用时间戳服务器在电子印章数据中添加时间戳，能够保证关键行为的不可否认性，签名时使用的 SM2 算法经国家密码管理部门认可，证书由中金金融电子认证中心有限公司签发，使用时间戳服务器和智能密码钥匙具有商用密码产品认证证书，见图 A-18、图 A-6，达到密码产品二级安全要求，随机数代码见图 A-33，签名代码见图 A-34、验签代码见图 A-35、图 A-36、图 A-37，印章加盖截图见图 A-38，印章验证截图见图 A-39、操作员证书信息见图 A-40、签名有效性见图 A-41。	√	√	√	1.0000	1.0000

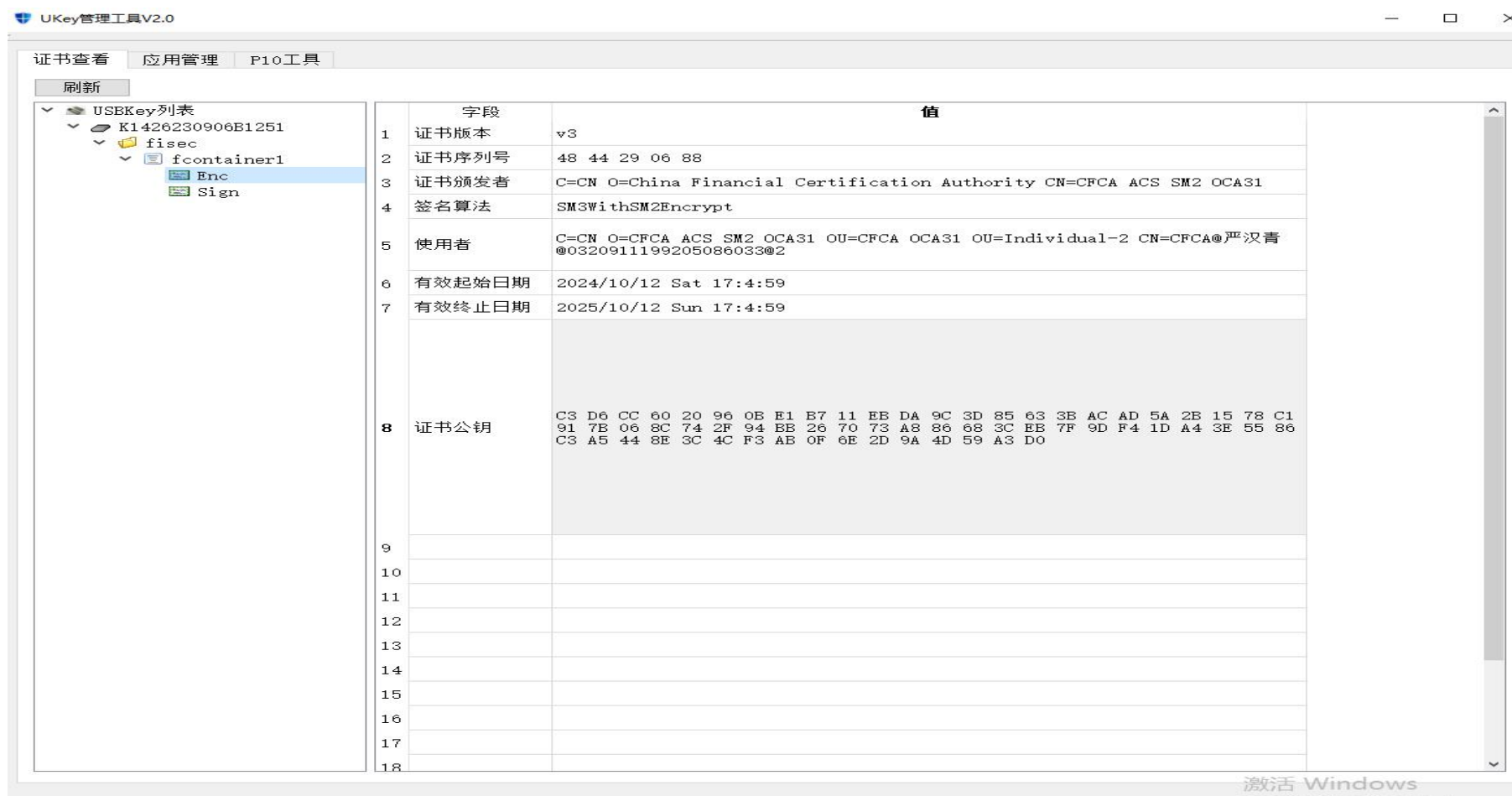
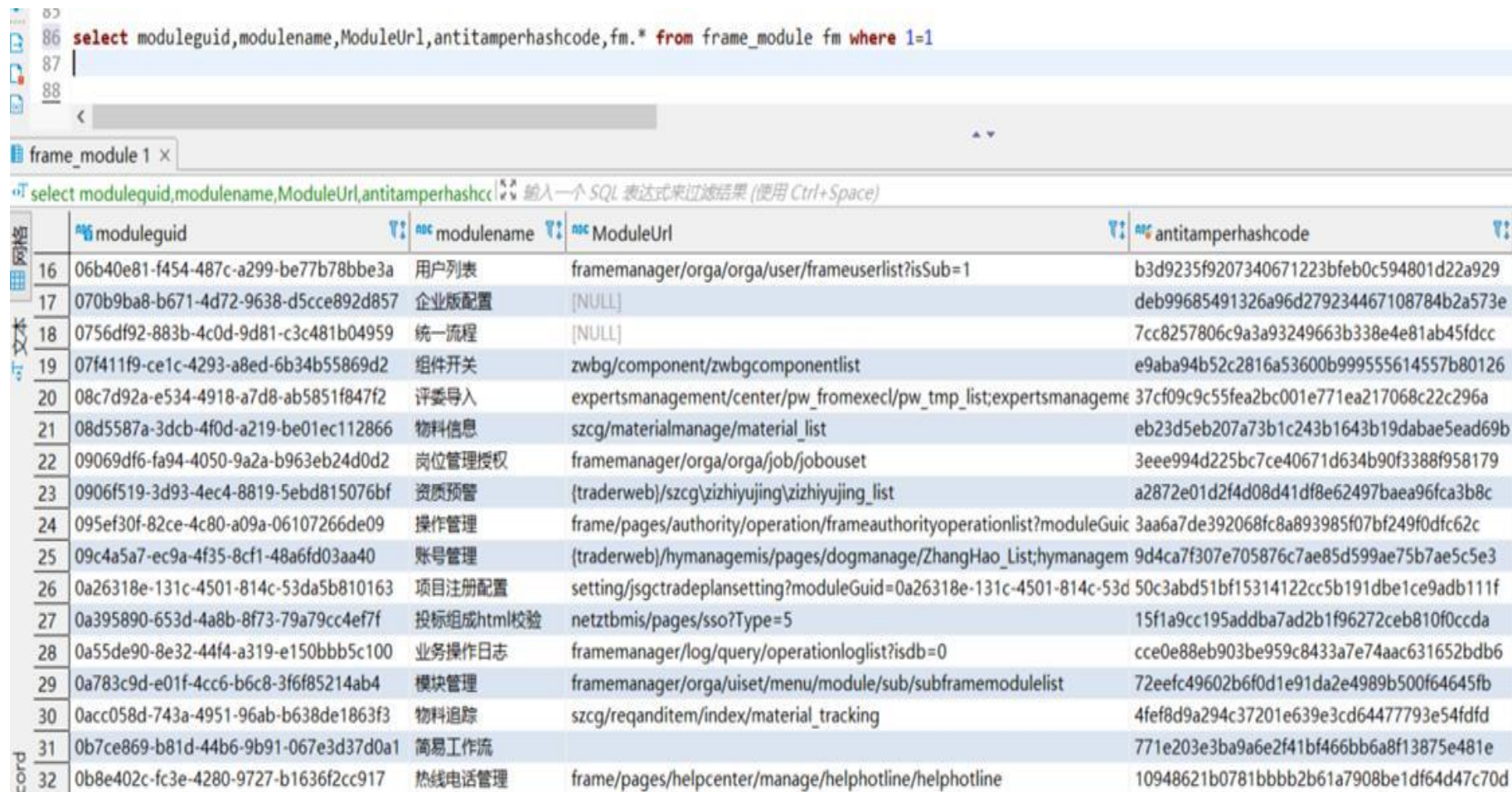


图 A-20 业务用户数字证书信息截图



	moduleguid	modulename	ModuleUrl	antitamperhashcode
16	06b40e81-f454-487c-a299-be77b78bbe3a	用户列表	framemanager/orga/orga/user/frameuserlist?isSub=1	b3d9235f9207340671223bfeb0c594801d22a929
17	070b9ba8-b671-4d72-9638-d5cce892d857	企业版配置	[NULL]	deb99685491326a96d279234467108784b2a573e
18	0756df92-883b-4c0d-9d81-c3c481b04959	统一流程	[NULL]	7cc8257806c9a3a93249663b338e4e81ab45fdcc
19	07f411f9-ce1c-4293-a8ed-6b34b55869d2	组件开关	zwbzg/component/zwbzgcomponentlist	e9aba94b52c2816a53600b999555614557b80126
20	08c7d92a-e534-4918-a7d8-ab5851f847f2	评委导入	expertsmanagement/center/pw_fromexcl/pw_tmp_list;expertsmanagem	37cf09c9c55fea2bc001e771ea217068c22c296a
21	08d5587a-3dc3-4f0d-a219-be01ec112866	物料信息	szcg/materialmanage/material_list	eb23d5eb207a73b1c243b1643b19dabae5ead69b
22	09069df6-fa94-4050-9a2a-b963eb24d0d2	岗位管理授权	framemanager/orga/orga/job/jobouset	3eee994d225bc7ce40671d634b90f3388f958179
23	0906f519-3d93-4ec4-8819-5ebd815076bf	资质预警	{traderweb}/szcg\zizhiyujing\zizhiyujing_list	a2872e01d2f4d08d41df8e62497baea96fca3b8c
24	095ef30f-82ce-4c80-a09a-06107266de09	操作管理	frame/pages/authority/operation/frameauthorityoperationlist?moduleGuic	3aa6a7de392068fc8a893985f07bf249f0dfc62c
25	09c4a5a7-ec9a-4f35-8cf1-48a6fd03aa40	账号管理	{traderweb}/hymanagemis/pages/dogmanage/ZhangHao_List;hymanagem	9d4ca7f307e705876c7ae85d599ae75b7ae5c5e3
26	0a26318e-131c-4501-814c-53da5b810163	项目注册配置	setting/jsqctradeplansetting?moduleGuid=0a26318e-131c-4501-814c-53d	50c3abd51bf15314122cc5b191dbe1ce9adb111f
27	0a395890-653d-4a8b-8f73-79a79cc4ef7f	投标组成html校验	netztbmis/pages/sso?Type=5	15f1a9cc195addba7ad2b1f96272ceb810fccda
28	0a55de90-8e32-44f4-a319-e150bbb5c100	业务操作日志	framemanager/log/query/operationloglist?isdb=0	cce0e88eb903be959c8433a7e74aac631652bdb6
29	0a783c9d-e01f-4cc6-b6c8-3f6f85214ab4	模块管理	framemanager/orga/uiset/menu/module/sub/subframemodulelist	72eefc49602b6f0d1e91da2e4989b500f64645fb
30	0acc058d-743a-4951-96ab-b638de1863f3	物料追踪	szcg/reqanditem/index/material_tracking	4fef8d9a294c37201e639e3cd64477793e54fdfd
31	0b7ce869-b81d-44b6-9b91-067e3d37d0a1	简易工作流		771e203e3ba9a6e2f41bf466bb6a8f13875e481e
32	0b8e402c-fc3e-4280-9727-b1636f2cc917	热线电话管理	frame/pages/helpcenter/manage/helphotline/helphotline	10948621b0781bbbbb2b61a7908be1df64d47c70d

图 A-21 数据库存储的应用系统访问控制信息签名值

```
246     }
247
248     public static byte[] hmac(int index, byte[] key, byte[] iv, byte[] srcData, String mode){
249         try {
250             FMSYS sys = new FMSYS();
251             SecretKey keysys = sys.ExportInternalKey(10);
252
253             // SecretKey skey = new SecretKeySpec(keysys.getEncoded(), "HMac/SM4");
254             // byte[] indata = "12345678".getBytes();
255             byte[] out = new byte[128];
256
257             Mac mac = Mac.getInstance("HMac/SM3", "FishermanJCE");
258             mac.init(keysys);
259             mac.reset();
260             mac.update(srcData, 0, srcData.length);
261             out = mac.doFinal();
262             return out;
263         } catch (Exception e) {
264             e.printStackTrace();
265         }
266         return null;
267     }
```

图 A-22 调用服务器密码机对数据进行签名代码截图

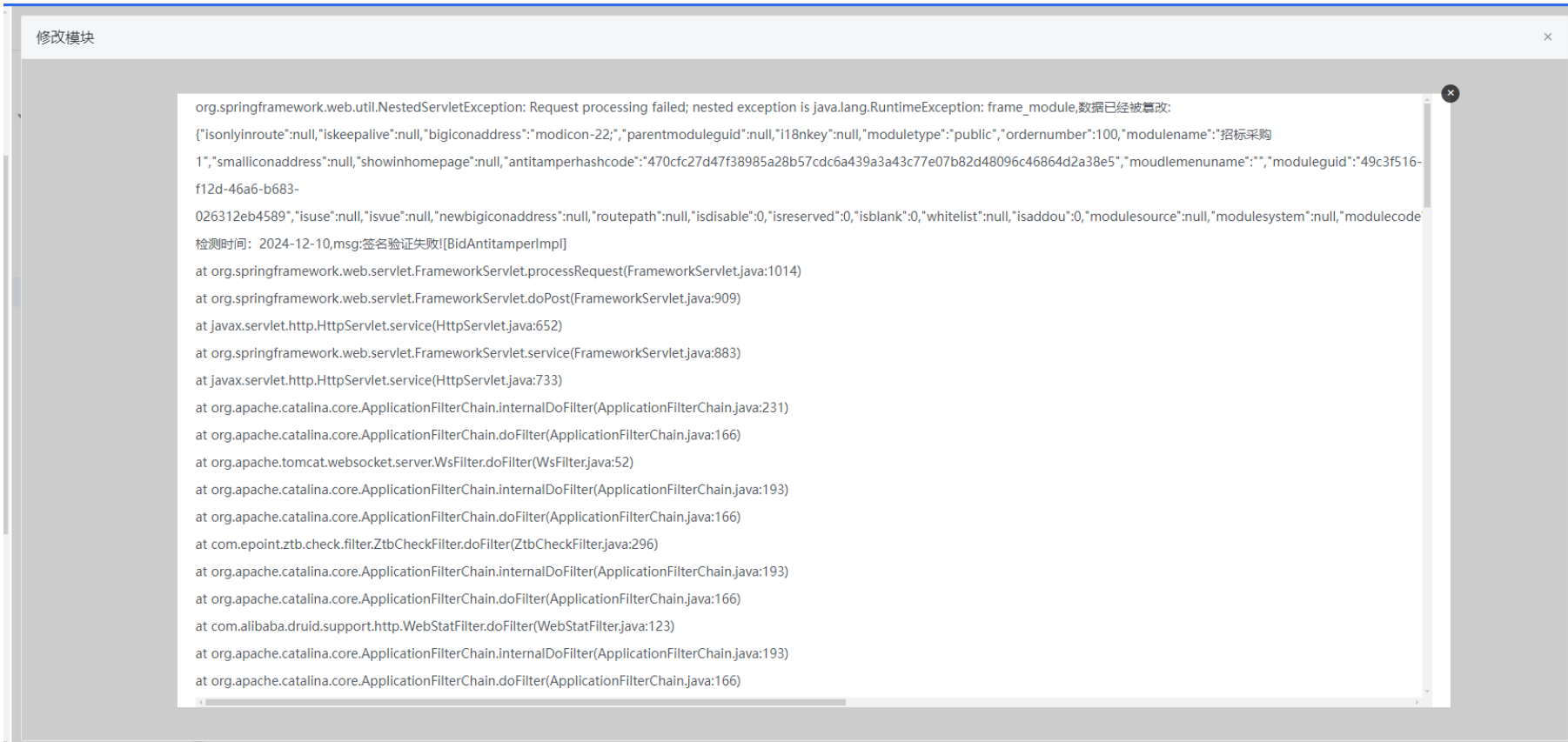


图 A-23 访问控制策略完整性验证结果截图

85# select rowguid,PMIDCardNo,PMMobile,address,antitamperhashcode from h_tbr_pm

86

身份证号 手机号 地址 完整性校验字段

h_tbr_pm 1 x

select rowguid,PMIDCardNo,PMMobile,address,antitamperhashcode

	rowguid	PMIDCardNo	PMMobile	address	antitamperhashcode
1	1a5650bb-6aa5-4fa6-b24a-0f46573fb18e	(SM4_1#:null:null)FC9FFD64CA7ADCDAA33	(SM4_1#:null:null)E0BDAC0EA81C450B	(SM4_1#:null:null)67404FE219: 08574b479242590eba46c46276f56ab943687f4f	
2	242ae9a5-2fc9-42bb-911d-0fffb9fb2fe6	(SM4_1#:null:null)E3E53119EBDF1EFF7313	(SM4_1#:null:null)E68D26600C2839CB	(SM4_1#:null:null)67404FE219: d27ebcdc354ae35c414c2b9b5b0ce9e1305cb1ae	
3	328c7d20-5acc-4490-b32b-ab20c72430d4	(SM4_1#:null:null)7178589BDB5C3287A417	(SM4_1#:null:null)ADDCC6F934CA0E1C	(SM4_1#:null:null)67404FE219: 354b51b3ab8c68cecdadfaa4831701bc6da8918	
4	4e3550fa-8417-4fae-9af3-7bed9efe9c1a	(SM4_1#:null:null)649F295331919E97AEA3f	(SM4_1#:null:null)D87E788DD47901C5		aa66328b50a5c9158ba0c8f2dad632d202211e09
5	67e11ca2-3e24-4d3b-a413-c6f69179ff45	(SM4_1#:null:null)B245E2B192E93803D3AC	(SM4_1#:null:null)971CA97E12D6984A	(SM4_1#:null:null)67404FE219: f3d28151e7993953622658e5fac1a13a1ede558e	
6	6bc70b90-a99b-4c97-ae08-2900c945eeda	(SM4_Bid#:null:null)LlxcRQ7XQ703yYUKI/T.	(SM4_Bid#:null:null)Kka0RUMvTaVfjC1		5a16fff36228e92ab991beafa17a4da6763696b5
7	8d703a07-907e-4a87-a362-9c9dcf73f585	(SM4_1#:null:null)3E0BC7A8C8851B433D25	(SM4_1#:null:null)83E06EFD4FE833BC3	(SM4_1#:null:null)67404FE219: 423e3bf5cb378e55a63e959def90b414469c19be	
8	98714ffb-bc47-4e9e-928f-9f75c24eaf2d	(SM4_1#:null:null)78C55680708EC0F15CA0	(SM4_1#:null:null)AFF75DC8E0C8CAB2	(SM4_1#:null:null)F1749A9717 42cb5fad9f3b8ec4149df4b0622054df74f60c34	
9	a0599178-07eb-4b6c-b056-2470727bbf66	(SM4_1#:null:null)6E964CE9C5E9D2191CA0	(SM4_1#:null:null)A0076526A49F2C6C		b750258c8e3573fa7e7f61f6e60768179dc62faf
10	b36927a5-46a0-469c-ab18-cf59ddd27d29	(SM4_1#:null:null)873F930E991432DAA84C	(SM4_1#:null:null)A11808B1306228D0	(SM4_1#:null:null)CB7712839E 08e17b99c8c32df238947d6642068c8b82a4f896	
11	b6142758-76f0-49ac-b4fd-f38cce5b6678	(SM4_1#:null:null)8D49858E9CB774CD4142	(SM4_1#:null:null)A43532101165E9557	(SM4_1#:null:null)67404FE219: 20d6885f9f3f27370fdb8c06b9f0c34af01a3a4	
12	e050e6bb-d5b9-418f-8675-293ef1118384	(SM4_Bid#:null:null)nnJLbWHafjQsqen8nY+	(SM4_Bid#:null:null)OL1zTToDOW1cl1		4f90861bac8a4694ee695d49962008171e137969
13	fe032756-9672-43a6-a2d1-e2e0e0aeae83	(SM4_1#:null:null)5877D4D6305072521BE0	(SM4_1#:null:null)3EBAB8C05DBF7B46	(SM4_1#:null:null)67404FE219: f961fdef2e4432e743d7930726ca54373287e9c0	

图 A-24 个人信息数据在数据库中存储情况

```
53:
54: public static byte[] encrypt_Cbc_Padding(int index,byte[] srcData,byte[] key,byte[] iv){
55:     FMSYS sm4=new FMSYS();
56:     byte[] orgData=paddingByte(srcData);
57:     return sm4.InternalSM4Enc(index, "CBC", true, orgData, iv);//加密方法
58: }
59:
60: public static byte[] decrypt_Cbc_Padding(int index,byte[] srcData,byte[] key,byte[] iv){
61:     FMSYS sm4=new FMSYS();
62:     byte[] orgData = sm4.InternalSM4Dec(index, "CBC", true, srcData, iv);//解密方法
63:     return unpad(orgData,8);
64: }
65:
66: public static byte[] encrypt_Ecb_Padding(int index,byte[] srcData,byte[] key){
67:     FMSYS sm4=new FMSYS();
68:     byte[] orgData=paddingByte(srcData);
69:     return sm4.InternalSM4Enc(index, "ECB", true, orgData, null);//加密方法
70: }
71:
72: public static byte[] decrypt_Ecb_Padding(int index,byte[] srcData,byte[] key){
73:     FMSYS sm4=new FMSYS();
74:     byte[] orgData = sm4.InternalSM4Dec(index, "ECB", true, srcData, null);//解密方法
75:     return unpad(orgData,8);
76: }
77:
78: public static byte[] encrypt_Ecb_NOPadding(int index,byte[] srcData,byte[] key){
79:     FMSYS sm4=new FMSYS();
80:     byte[] orgData=paddingByte(srcData);
81:     return sm4.InternalSM4Enc(index, "ECB", false, orgData, null);//加密方法
82: }
83:
84: public static byte[] decrypt_Ecb_NOPadding(int index,byte[] srcData,byte[] key){
85:     FMSYS sm4=new FMSYS();
86:     byte[] orgData = sm4.InternalSM4Dec(index, "ECB", false, srcData, null);//解密方法
87:     return unpad(orgData,8);
88: }
89:
90: }
```

图 A-25 数据加解密代码截图

81 select rowguid,DanWeiName ,LianXiRen ,LiXiRenTel from cg_toubiaodanwei ct where 1=1

82

83

cg_toubiaodanwei 1 x

select rowguid,DanWeiName ,LianXiRen ,LiXiRenTel from cg_t 输入一个 SQL 表达式来过滤结果 (使用 Ctrl+Space)

	rowguid	DanWeiName	LianXiRen	LiXiRenTel
1	000e74ec-99af-403c-8962-03af2185b4d6	(SM4_1#:null:null)07C285E624EA15716DD07098EA498396725883C076A11	(SM4_1#:null:null)B1ECCECA58D9AA70F7EA6BD94DC7BD9C66CB4357DF4E	(SM4_1#:null:null)6A6BA077CCE14BCB93F8C6AC
2	003ede5e-b491-4763-97c3-63bdec37fd9	(SM4_1#:null:null)07C285E624EA15716DD07098EA498396725883C076A11	(SM4_1#:null:null)331C1F42A1DEFCA45FEC4ECDBD86	(SM4_1#:null:null)B337D4CC344A7E526BE1A393F
3	004594ab-e086-4eee-a0ac-f1c1cf3b97ee	(SM4_1#:null:null)07C285E624EA15716DD07098EA49839642E23443DC76F	(SM4_1#:null:null)6197CD5F31167208A6F2FC4F99816A21	(SM4_1#:null:null)4839A5E169BC7C26179EABD3C
4	005f030e-e1be-4bcc-ab97-0047e11854a7	(SM4_1#:null:null)07C285E624EA15716DD07098EA498396C151C57E00FB6	(SM4_1#:null:null)078CB1496FF0967D91ABA8620A7E28EA	(SM4_1#:null:null)6CEFC435C9C4B6F047F8F730D
5	00ad8c57-1a72-426b-9aab-c711ab7e828d	(SM4_1#:null:null)07C285E624EA15716DD07098EA498396C151C57E00FB6	(SM4_1#:null:null)078CB1496FF0967D91ABA8620A7E28EA	(SM4_1#:null:null)0C1BBF8EDA393B522E1E8422C
6	00e8ea68-2ccb-4d5f-be0f-52723067828a	(SM4_1#:null:null)7C1B988CA065229EC8C7422FD73D2B89F8F0E4BC196A1	(SM4_1#:null:null)F7383DC2CEA2F3392A15E2FB2FC66F87077BE7AF10BCE	(SM4_1#:null:null)958341DCFD29B63C0963E439F
7	010d45a5-8fb1-49c0-8fb2-3739f96c7afb	(SM4_1#:null:null)07C285E624EA15716DD07098EA49839648FD4EE1C4AF1	(SM4_1#:null:null)DCC044D340AE5CF1F87E4CA8A369E884	(SM4_1#:null:null)0C6384A585B93CBFAF87BAEDE
8	010e6956-bbb0-4bb6-b235-ba1b1d131b15	(SM4_1#:null:null)7C1B988CA065229EC8C7422FD73D2B89F8F0E4BC196A1	(SM4_1#:null:null)F7383DC2CEA2F3392A15E2FB2FC66F87077BE7AF10BCE	(SM4_1#:null:null)C6DCB3CE0E7CCE68B976A2687
9	01195e86-84f7-4c37-a76d-33ca72678db5	(SM4_1#:null:null)7C1B988CA065229EC8C7422FD73D2B8970CC0DBDF839f	(SM4_1#:null:null)7AE918171674E8CC468E715C4C3E3849	(SM4_1#:null:null)C6DCB3CE0E7CCE68B976A2687
10	012670c8-ce36-4f12-9cd9-92e93cc15745	(SM4_1#:null:null)BF0168C1911158AFB17DB4FEDF2346F9081569C152C66f	(SM4_1#:null:null)096F7DF48569164E03717B0DB71F344A	(SM4_1#:null:null)08028B331E60211403029697EL
11	015c1e0b-bc1e-47eb-9fe6-95dd841076f2	(SM4_1#:null:null)7C1B988CA065229EC8C7422FD73D2B89F8F0E4BC196A1	(SM4_1#:null:null)F7383DC2CEA2F3392A15E2FB2FC66F87077BE7AF10BCE	(SM4_1#:null:null)EB107AAD213D90EDED490413
12	01a04bd5-5886-4b86-afb8-5eafbd4ea460	(SM4_1#:null:null)07C285E624EA15716DD07098EA498396C7B5CEAB0A1B1	(SM4_1#:null:null)348F080DC2F00070334F364A55AABA7	(SM4_1#:null:null)D80F6EC48F8FB2EC20F72ADED
13	01a487f4-a3e7-49a0-8b37-938711c7e74c	(SM4_1#:null:null)07C285E624EA15716DD07098EA49839644900788DFD03	(SM4_1#:null:null)50043366E689764929066699A2C0470F	(SM4_1#:null:null)742D094E5476AD81EE11C52AC
14	01b488c0-d006-4fbd-bf77-d4053bf3d479	(SM4_1#:null:null)07C285E624EA15716DD07098EA498396C7B5CEAB0A1B1	(SM4_1#:null:null)D0895CE62F3880F51D0E9F8B0D3D3A57	(SM4_1#:null:null)4F17BCC59659E04E220911D09!
15	01d4dbcd-f828-44ff-8bad-e2763afddedc	(SM4_1#:null:null)07C285E624EA15716DD07098EA49839644900788DFD03	(SM4_1#:null:null)07C285E624EA15716DD07098EA498396C4E01A1508802	(SM4_1#:null:null)D89F7B1C31E98336CB458E5D6
16	02113441-e1d5-4af2-8f4a-7593bdebcd50	(SM4_1#:null:null)07C285E624EA15716DD07098EA4983960E5F7C6DD1AD	(SM4_1#:null:null)7C148DA9465346838DEB8E96CE6DFE	(SM4_1#:null:null)7A8BC78DC4FE7FFF676636524
17	02192d37-4b0d-4261-91d4-617d0d5b8132	(SM4_1#:null:null)07C285E624EA15716DD07098EA498396725883C076A11	(SM4_1#:null:null)B1ECCECA58D9AA70F7EA6BD94DC7BD9C66CB4357DF4E	(SM4_1#:null:null)6A6BA077CCE14BCB93F8C6AC
18	021a5eae-0681-4cc7-a7ff-53d7d4b3f7a8	(SM4_1#:null:null)09D428A84E76E7122D4C8DE4A0D5F8D519728F1F1755E	(SM4_1#:null:null)6AA7BC3B3A64B5E1543DE618A836776D	(SM4_1#:null:null)B337D4CC344A7E526BE1A393F

图 A-26 业务数据所处数据库存储状态

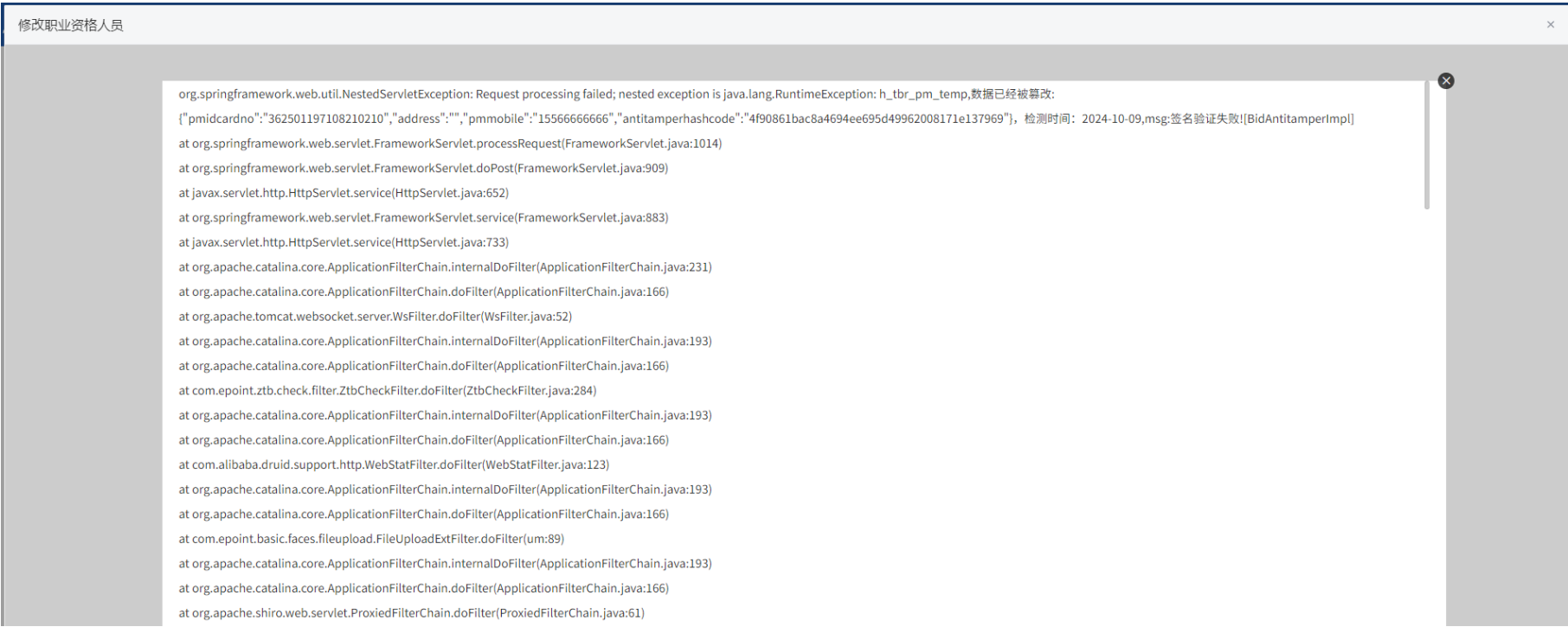


图 A-28 个人信息数据完整性保护验证结果

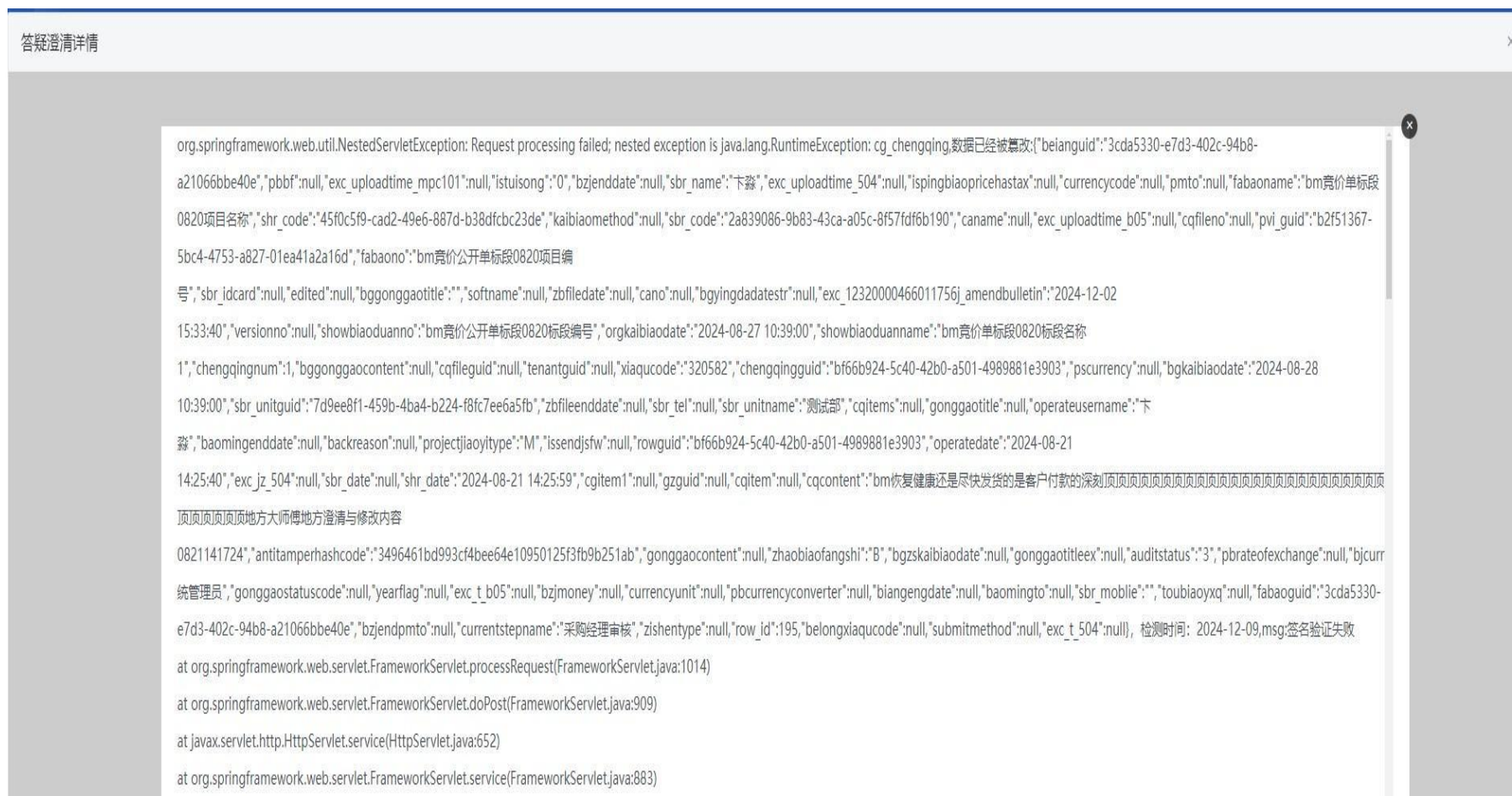


图 A-29 业务数据完整性验证结果

86 `select ROWGUID ,USERGUID,LOGTYPE ,MODULENAME ,antitamperhashcode from frame_log fl where 1=1`

87

88

frame_log 1 x

select ROWGUID ,USERGUID,LOGTYPE ,MODULENAME ,antitamperhashcode from frame_log fl where 1=1

	ROWGUID	USERGUID	LOGTYPE	MODULENAME	antitamperhashcode
1	000115c4-e5a1-4164-ba40-e563f7fcd2bf	45f0c5f9-cad2-49e6-887d-b38dfcbc23de	visit	采购寻源-踏勘通知	2f678f2bf4ba73cd44080776fad46a747e68c8cd
2	00037e1f-4169-416f-a673-c16f4a357b93	56432114-1c79-41df-b0f1-aaa78293c150	visit	采购需求-需求池	792fbce2ac9ad331b20bfe33d0b58128222f381b
3	00037fd7-e7e1-45d9-91d5-14f251f06166	45f0c5f9-cad2-49e6-887d-b38dfcbc23de	visit	采购需求-需求池	2f678f2bf4ba73cd44080776fad46a747e68c8cd
4	00038dde-65c3-481e-89b9-5ba2363d0d94	45f0c5f9-cad2-49e6-887d-b38dfcbc23de	visit	采购需求-需求申请	2f678f2bf4ba73cd44080776fad46a747e68c8cd
5	0003c515-66c6-45ed-830f-3a04430518af	45f0c5f9-cad2-49e6-887d-b38dfcbc23de	visit	后台管理-统一界面-模块管理-模块授权	2f678f2bf4ba73cd44080776fad46a747e68c8cd
6	0004af7f-3483-44ad-a66e-1c9e46404a43	45f0c5f9-cad2-49e6-887d-b38dfcbc23de	visit	采购寻源-询比采购	2f678f2bf4ba73cd44080776fad46a747e68c8cd
7	00072906-b793-4328-8bdf-59cb4c5ac545	45f0c5f9-cad2-49e6-887d-b38dfcbc23de	visit	履约售后-订单收货	2f678f2bf4ba73cd44080776fad46a747e68c8cd
8	0008c8bc-00d8-4097-aba4-2f50f6085c5e	56432114-1c79-41df-b0f1-aaa78293c150	visit	采购寻源-招标采购	792fbce2ac9ad331b20bfe33d0b58128222f381b
9	00093435-f5fb-4a41-9286-507a75b69207	50c48a48-a95f-4280-b8ee-a137eacc6b2b	visit	采购寻源-谈判采购	94bf0b703d137d871efea26b8a18db41b7f987c8
10	h5a8f38h-fd95-49fd-931e-1c5cf1d75228	45f0c5f9-cad2-49e6-887d-b38dfcbc23de	visit	采购寻源-询价采购	ff088a4329h5chd137f5f999fda0e58h38hed132

图 A-30 日志数据在数据库中的存储状态

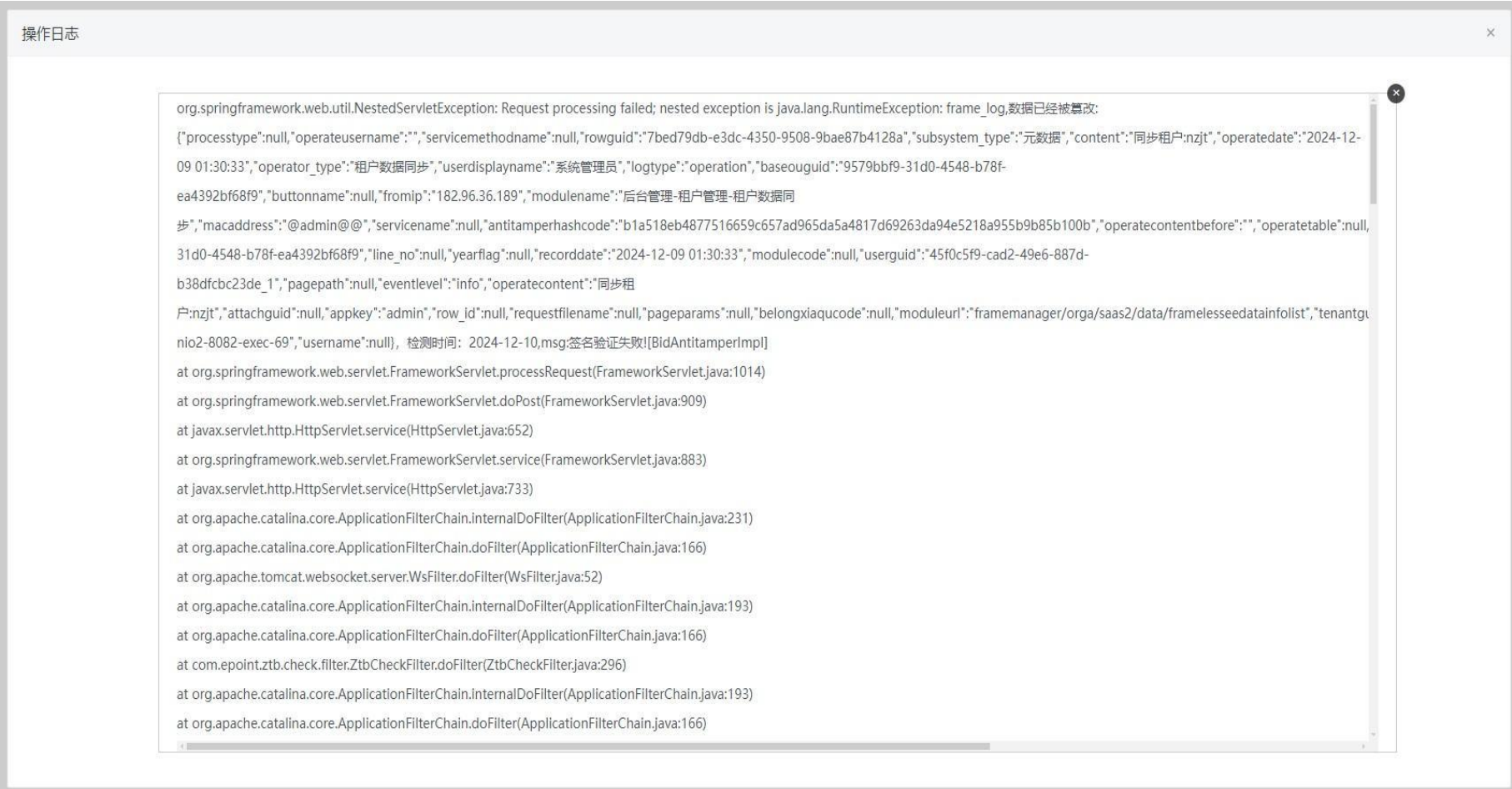


图 A-31 日志数据完整性验证结果

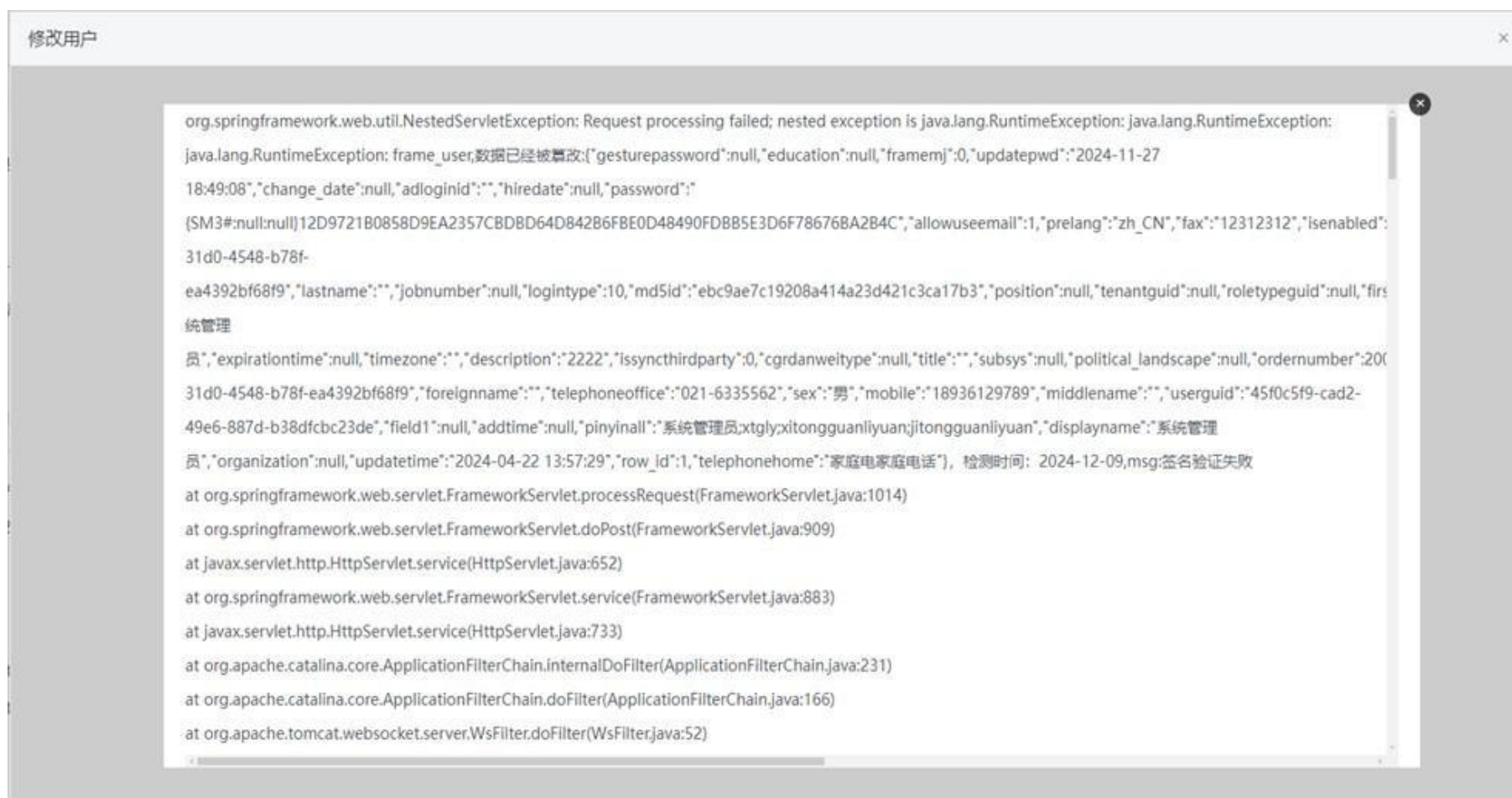


图 A-32 鉴别数据（非数字证书）完整性验证结果

```

public static String FM_DSVS_GenRandomData() {
    try{
        log.info("ca312获取随机数开始-----");
        long starttime=System.currentTimeMillis();
        String FmApiIP = ConfigUtil.getConfigValue("ztb", "FmApiIP");
        if (StringUtil.isBlank(FmApiIP))
        {
            FmApiIP="223.99.220.203";
        }
        String []ips=new String[1];
        //String ip="223.99.220.203";
        String ip=FmApiIP;
        ips[0]=ip;
        Class<?> FmApi = Class.forName("com.fisherman.api.FmApi");
        Constructor<?> Apicon = FmApi.getConstructor();
        Object info = Apicon.newInstance();
        Method FM_DSVS_Connection = info.getClass().getMethod("FM_DSVS_Connection", String[].class,int.class,int.class);
        FM_DSVS_Connection.invoke(info, new Object[] { ips,2020, 5 });
        long endtime1=System.currentTimeMillis();
        log.info("ca312连接设备测试成功结束时间-----"+(endtime1-starttime)+"ms");
        Method FM_DSVS_GenRandomData = info.getClass().getMethod("FM_DSVS_GenRandomData", int.class);
        byte [] iv=(byte[])FM_DSVS_GenRandomData.invoke(info, new Object[] { 32 });
        long endtime2=System.currentTimeMillis();
        log.info("ca312获取随机数成功结束时间-----"+(endtime2-endtime1)+"ms");
        String random=Base64Util.encode(iv);
        Method FM_DSVS_CloseConnection = info.getClass().getMethod("FM_DSVS_CloseConnection");
        FM_DSVS_CloseConnection.invoke(info, new Object[] { });
        long endtime3=System.currentTimeMillis();
        log.info("ca312获取随机数Close结束时间-----"+(endtime3-endtime2)+"ms");
        log.info("ca312随机数-----"+random);
        return random;
    }
    catch (InvocationTargetException ite) {
        log.error("ca312FM_DSVS_GenRandomData反射调用方法异常:" + ite.getCause());
        return null;
    }
    catch (Exception e) {
        log.error("\r\nca312生成随机数失败:"+e);
        return null;
    }
}

```

图 A-33 关键操作调用随机数代码


```
epqzfilesverconfig.properties  FISECTSAClientImp.java  PdfValidator.java  ztb.properties  EpQzBeijingYunActions.java  NHCloudSignService.java  Test.java  TSAClientFactory.java  ChangShaTSAClientImp.java
69      catch (Exception e) {
70          logger.error(" 时间戳签名失败!", e);
71          throw new Exception("时间戳对象签名失败, 错误信息请查看日志!");
72      }
73  }
74  |
75  public byte[] getTimeStampTokenFisecTSA(byte[] imprint) throws Exception {
76      try {
77          //返回时间戳对象
78          FmStfApi fmStfApi = new FmStfApi();
79
80          // 创建连接
81          fmStfApi.FM_STF_Connection(new String[] { ip }, port, 5);
82          logger.info("时间戳连接成功");
83
84          // 根据原文hash创建时间戳
85          byte[] tsa_byHash = fmStfApi.FM_STF_CreateTimestampWithDigest(Constants.SGD_SM3_SM2, imprint, true, null); // 签名算法, 原文的hash值, 是否
86
87          return tsa_byHash;
88      }
89      catch (Exception e) {
90          logger.error("时间戳签名失败!", e);
91          throw new Exception("时间戳对象签名失败, 错误信息请查看日志!");
92      }
93  }
94
95 }
```

图 A-34 关键操作签名调用代码


```
public long getSignDate(){  
    →    → try{  
    →    →     long datestamp=0;  
    →    →     → //判断 pkcs7 是否存在，不存在走 v4 结构的逻辑  
    →    →     → if(getStructtype().equals(StructType.PKCS7)){  
    →    →     →     → // 签名时间戳  
    →    →     →     → //如果对接了时间戳，获取时间戳服务器签出来的日期时间  
    ..... if(pkcs7.getTimeStampToken()!=null){  
    ..... try{  
    ..... // 签名原文  
    ..... String orgdata=getSignData();  
    .....  
    ..... //从 pdf 节点中取出头为 EPPDF_的节点数据  
    ..... | ..... Map<String,String> ext=new HashMap<String,String>();  
    .....  
    ..... // 提取印章图片  
    ..... Item item=fields.getFieldItem(name);
```

图 A-35 关键操作验签代码-1

```

.....
..... // 获取 Annot 签章节点
..... PdfDictionary dic=item.getValue(0);
.....
..... if(ext.isEmpty()){
..... for (PdfName key: dic.getKeys()){
..... String key_name=key.toString();
..... if(key_name.indexOf(EPPdfNames.EPPDF_HEAD)!=-1){
..... PdfString value={PdfString}dic.get(key);
..... if(value!=null){
..... String _key_name=key_name.split("_")[1];
..... ext.put(_key_name, value.toUnicodeString());
..... }
..... }
..... }
.....
..... byte[] tsImprint=
MessageDigest.getInstance("SM3").digest(Base64Util.decode(orgdata));
..... System.out.println(" 验 签 原 文 数 据 :"+
Base64Util.encode(tsImprint));
.....
..... //返回时间戳对象
..... FmStfApi fmStfApi=new FmStfApi();
.....
..... // 创建连接
..... fmStfApi.FM_STF_Connection(new String[] { FISECTSAClientImp.ip },
FISECTSAClientImp.port,5);
.....
..... System.out.println("验签数据:"+ext.get("tsToken"));

```

图 A-36 关键操作验签代码-2

```

.....
..... // 根据原文 hash 验证时间戳
..... int ..... ret .....
fmStfApi.FM_STF_VerifyTimestampWithDigest(Constants.SGD_SM3_SM2,
Base64Util.decode(ext.get("tsToken")), tsImprint, null); // 签名算法，时间戳数据，原文的 hash
值，验证数据
..... System.out.println("验签结果:" + ret);
..... //如果有时间戳时间，将签名日期刷成时间戳的日期
..... if(pkcs7.getTimestampDate() != null){
..... datestamp = pkcs7.getTimestampDate().getTimelnMillis();
..... }
..... }
..... catch (Exception e){
..... datestamp = 0;
..... // 弱化处理，没有必要暴露痕迹
..... log.error("", e);
..... }
..... }
→ → → if(datestamp == 0){
→ → → datestamp = pkcs7.getSignDate().getTime().getTime();
→ → → }
→ → →
..... return datestamp;
→ → → }
→ → → else if(getStructtype().equals(StructType.ESESIGNATURE)){
→ → → TBS_Sign toSign = sesSignature.getToSign();
→ → → if(toSign != null && toSign.getTimelnfo() != null){
→ → → → return toSign.getTimelnfo().getDate().getTime(); → → →
→ → → }
→ → → }
→ → }
→ → catch (Exception e){
→ → → log.error(e.getMessage(), e);
→ → }
→ → return 0;
→ }

```

图 A-37 关键操作验签代码-3



图 A-38 关键操作签章加盖截图

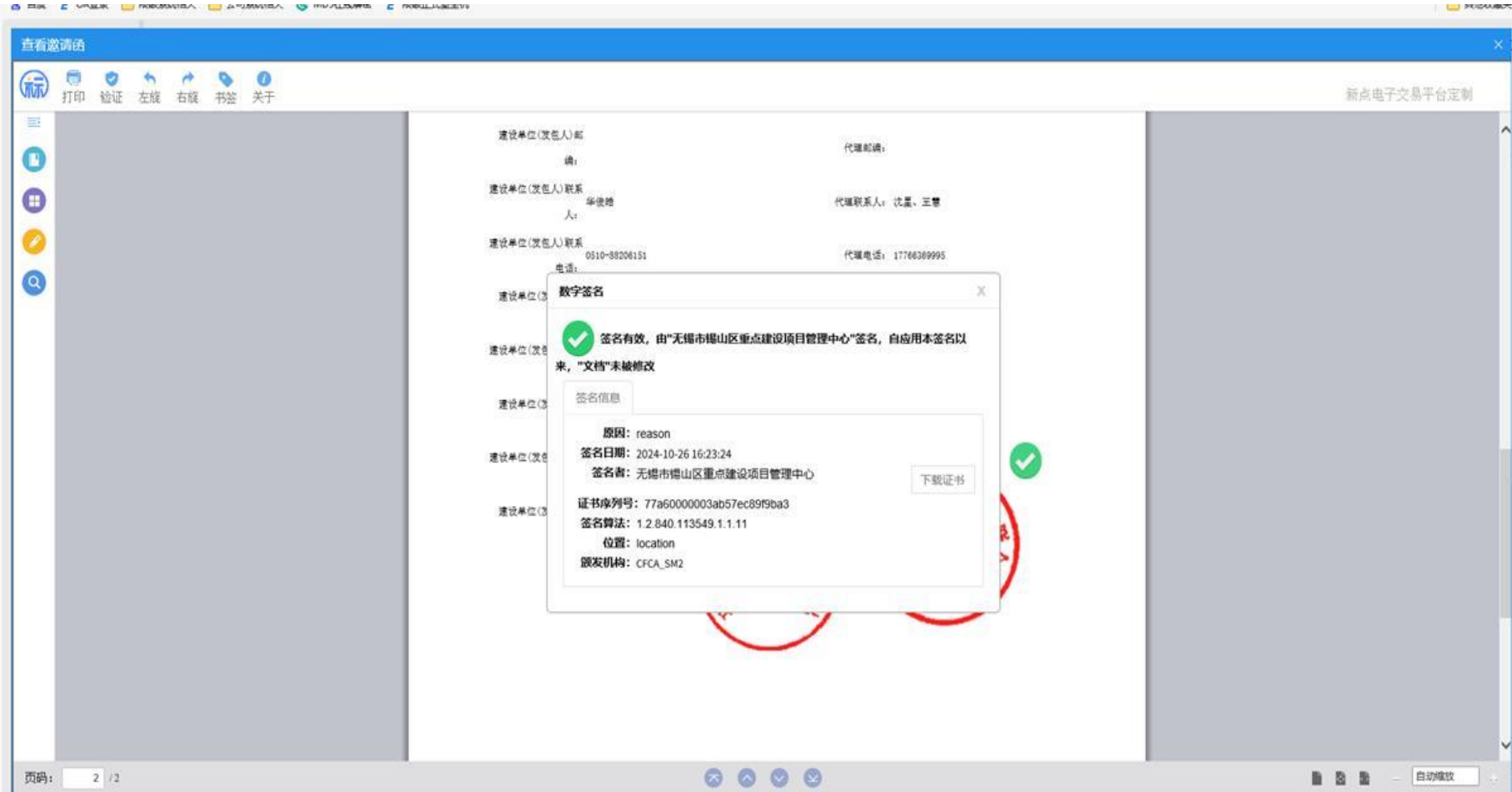


图 A-39 关键操作签章验证截图

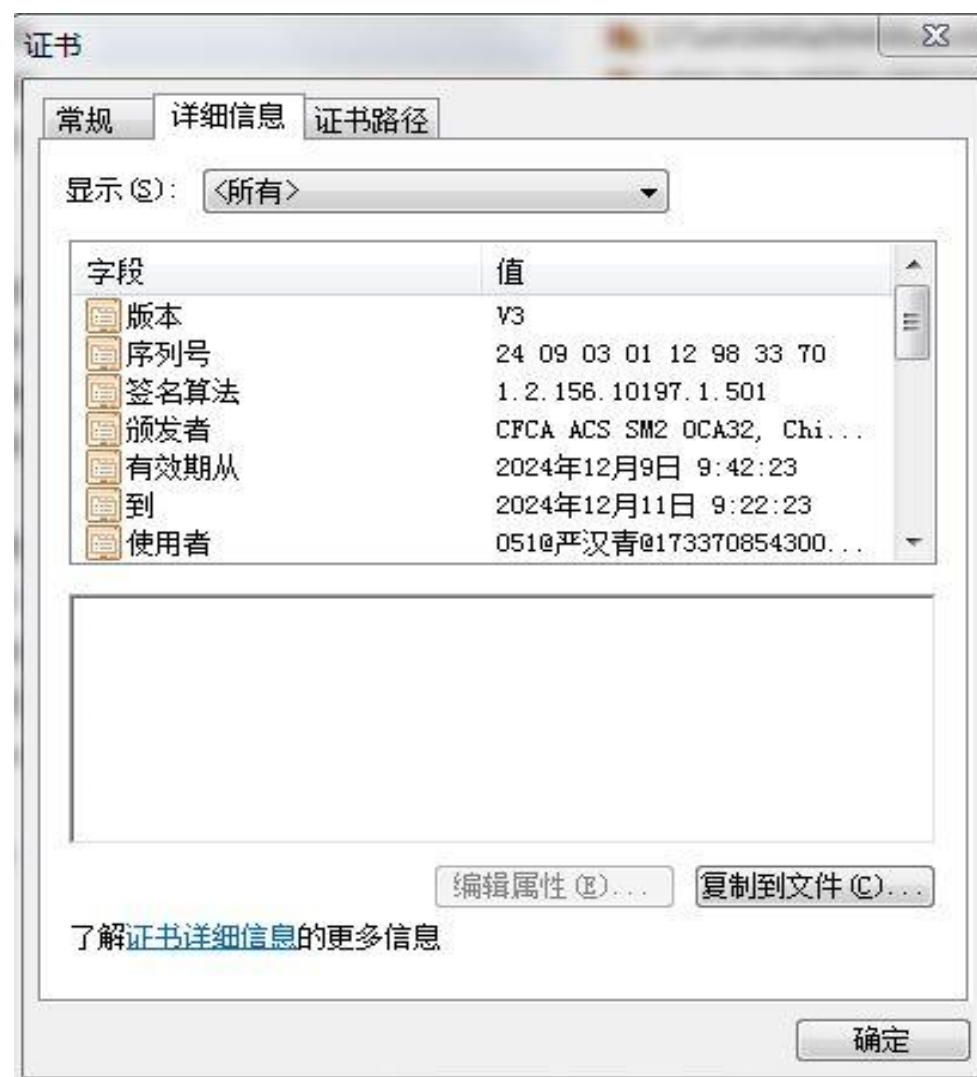


图 A-40 关键操作操作员证书信息截图

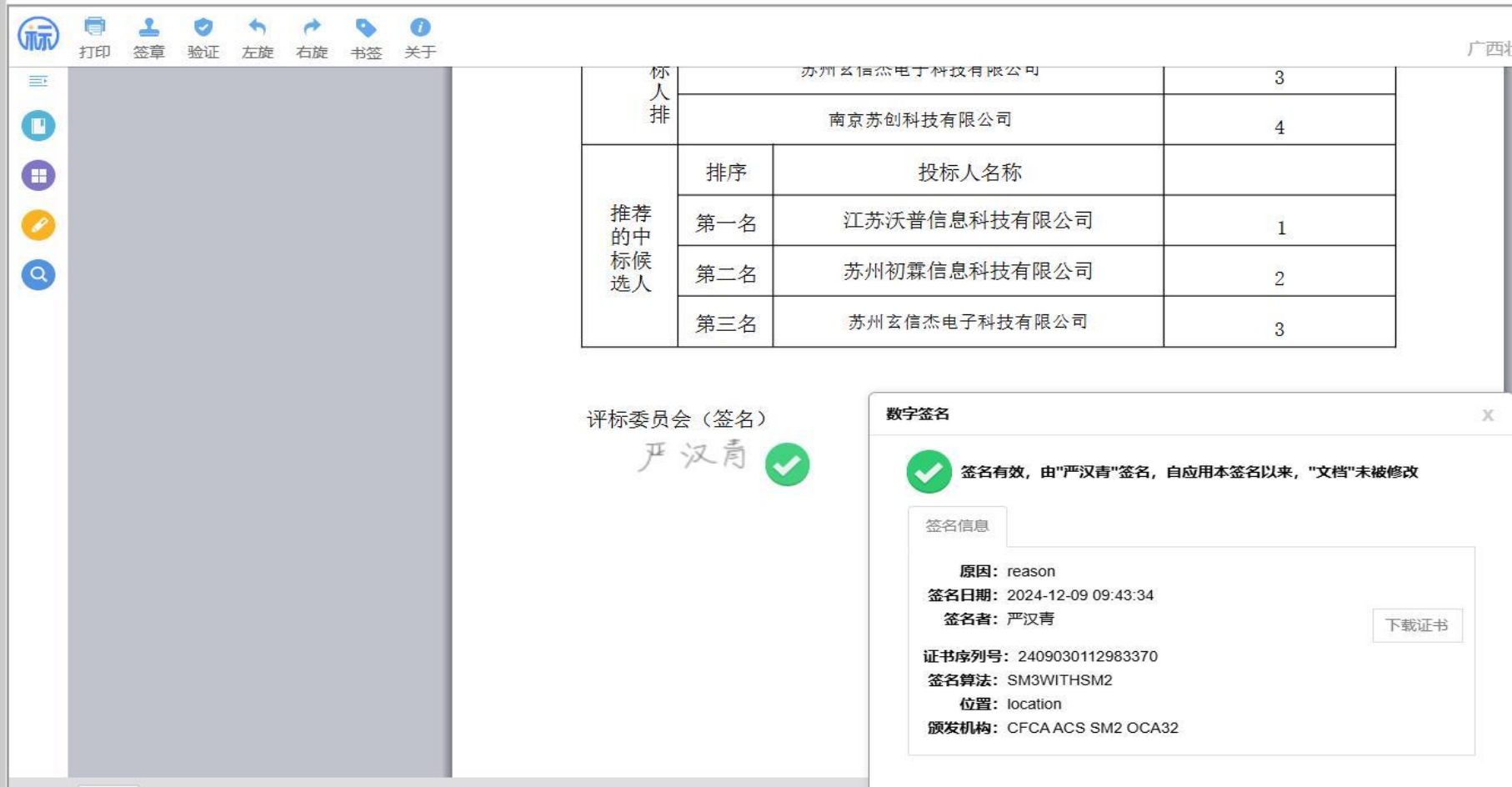


图 A-41 数字签名有效性截图

A. 5. 管理制度

表 A- 5 管理制度测评结果记录

测评指标	测评对象	结果记录	测评指标符合情况	测评单元得分 S_{ij}
具备密码应用安全管理制度	管理体系（包括安全管理制度类文档、密码应用方案、密钥管理制度及策略类文档、操作规程类文档、记录表单类文档、系统相关人员）	经访谈及文档审查，建立了安全管理制度体系，具有《密码应用安全管理制度》、《密钥管理制度》等相关管理制度，规范密码安全管理制度，对密码安全基本原则、组织架构、体系运作、风险管理、系统安全和密钥安全等进行要求。	符合	1.0000
密钥管理规则		经访谈及文档审查，制定了《密码应用安全管理制度》，第四章安全体系的运作管理规定了密码应用技术体系框架，第十章密钥安全管理要求根据密码应用方案建立相应密钥管理规则。	符合	1.0000
建立操作规程		经访谈及文档审查，制定了《密码应用操作管理制度》，对管理人员和操作人员执行的日常管理操作进行规范。	符合	1.0000
定期修订安全管理制度		经访谈及文档审查，制定了《密码安全制度文件控制管理规定》，明确密码安全管理制度评审和修订工作至少每年开展一次。	符合	1.0000
明确管理制度发布流程		经访谈及文档审查，具有《密码安全制度文件控制管理规定》，明确了管理制度的发布流程并进行版本控制。	符合	1.0000
制度执行过程记录留存		经访谈及文档核查，制定了《苏州国泰新点软件有限公司信息系统制度执行记录表》记录了密码应用操作规程的执行情况。	符合	1.0000

A. 6. 人员管理

表 A-6 人员管理测评结果记录

测评指标	测评对象	结果记录	测评指标符合情况	测评单元得分 S_{ij}
了解并遵守密码相关法律法规和密码管理制度	管理体系（包括安全管理制度类文档、记录表单类文档、系统相关人员）	经访谈，系统管理员等了解商用密码的相关法律法规。	符合	1.0000
建立密码应用岗位责任制度		经访谈和文档审查，建立了密码应用岗位责任制度，《密码人员管理制度》明确了人员岗位责任、人员考核、人员培训、人员保密和调离、人员的配备与管理等相关规定，规定了权限、职能不同的角色必须分离，相关设备与系统的管理和使用账号不得多人共用。	符合	1.0000
建立上岗人员培训制度		经访谈和文档审查，建立了人员培训制度和相关培训计划，《密码人员管理制度》中规定设置内部密码专题培训机制，每年组织至少一次培训，由内部人员或聘请外部专家担任培训讲师，内容涉及密码相关法律法规和标准规范、商用密码应用、商用密码应用安全性评估等多个方面，并提供了培训记录。	符合	1.0000
定期进行安全岗位人员考核		经访谈和文档审查，建立了人员考核管理制度和相关培训计划，《密码人员管理制度》中规定每年对相关人员组织一次考核，根据考核结果安排后续的培训并记录，并提供了考核记录。	符合	1.0000

测评指标	测评对象	结果记录	测评指标符合情况	测评单元得分 $S_{i,j}$
建立关键岗位人员保密制度和调离制度		经访谈和文档审查，建立了关键岗位人员保密制度和人员离岗管理制度，《密码人员管理制度》中规定外单位聘任人员或关键岗位人员与被测单位签订保密协议，承担保密义务，相关人员若要调离岗位时，按照制定的人员调离制度承担相应的保密义务。	符合	1.0000

A. 7. 建设运行

表 A-7 建设运行测评结果记录

测评指标	测评对象	结果记录	测评指标符合情况	测评单元得分 $S_{i,j}$
制定密码应用方案	密码应用方案、密钥管理制度及策略类文档、密码实施方案、商用密码应用安全性评估报告、密码应用安全管理制度、攻防对抗演习报告、整改文档、管理体系（包括安全管理制度类文档、记录表单类文档、系统相关人员）	经访谈和文档审查，具有《新点电子交易平台密码应用方案》，且通过了专家评审。	符合	1.0000
制定密钥安全管理策略		经文档核查，被测单位在《密码应用安全管理制度》中明确了密钥管理规则，根据《新点电子交易平台密码应用方案》确定系统涉及的密钥种类、体系及其生命周期环节，制定了密钥安全管理策略。	符合	1.0000
制定实施方案		经文档核查，被测单位在《新点电子交易平台密码应用方案》中明确了项目人员组织、经费保障、质量保证和监督检查。	符合	1.0000
投入运行前进行密码应用安全性评估		经访谈系统管理人员，被测系统目前处于试运行阶段，评估通过后系统才能正式上线运行。	符合	1.0000
定期开展密码应用安全性评估及攻防对抗演习		经访谈及文档审查，《密码应用安全管理制度》中规定了定期开展安全性评估，《密码安全事件应急处置管理制度》中明确了演习步骤，但未提供攻防对抗演习报告。	部分符合	0.5000

A. 8. 应急处置

表 A-8 应急处置测评结果记录

测评指标	测评对象	结果记录	测评指标符合情况	测评单元得分 S_{ij}
应急策略	管理体系（包括密码应用应急处置方案、应急处置记录类文档、安全事件发生情况及处置情况报告、系统相关人员）	经访谈和文档审查，《密码安全事件应急处置管理制度》中明确了应急事件处理流程及其他管理措施，做好了应急资源准备。	符合	1.0000
事件处置		经访谈和文档审查，按照《密码安全事件应急处置管理制度》中规定，发现的密码应用安全事故及时向密码应用安全工作小组报告，密码应用安全工作小组接到故障申报后，填写《应急事件报告表》并初步判定故障的严重程度、影响范围，重大密码应用安全事件需要上报密码应用安全领导小组，同时按信息系统应急预案处理故障。	符合	1.0000
向有关主管部门上报处置情况		经访谈和文档审查，《密码安全事件应急处置管理制度》中规定了事件处置完成后向信息系统主管部门及归属的密码管理部门报告事件发生情况及处置情况。	符合	1.0000

附录 B 密评活动有效性证明记录

B.1. 密评委托证明

表 B-1 委托证明文件

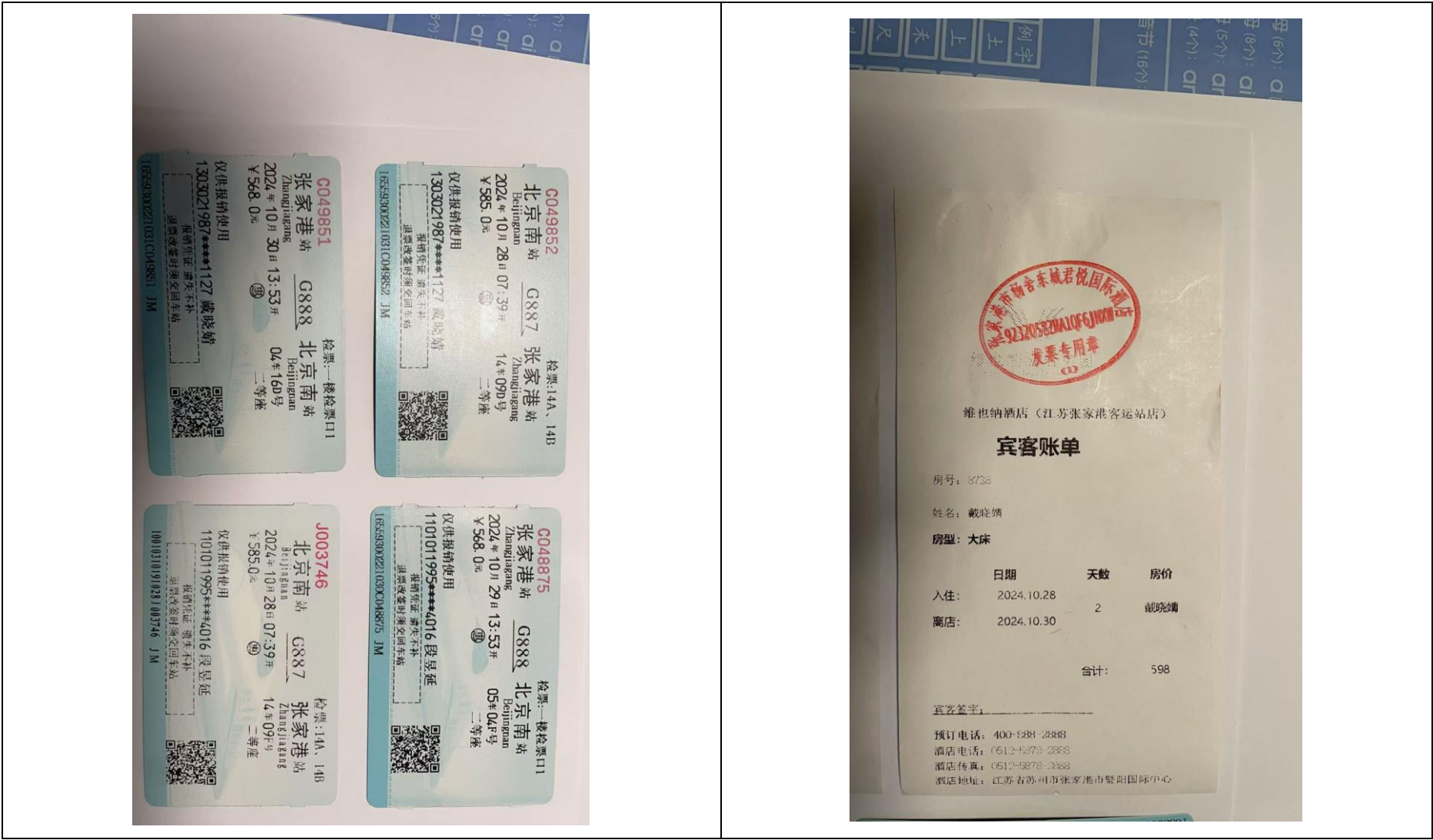
文件类型	合同	签订时间	2024. 8. 27
委托单位	北京丰德启航科技有限公司		
委托金额	60000	系统密评单价	60000
合同编号： 商用密码应用安全性评估技术服务合同 委托人：北京丰德启航科技有限公司（甲方） 受托人：北京市产品质量监督检验研究院（乙方） 签订地点：北京市 签订日期：2024年8月27日 依据《中华人民共和国民法典》的规定，合同双方经友好协商，签订本合同。 一、测评依据 商用密码应用安全性评估主要依据如下法规/技术标准： 1. 《信息安全技术 信息系统密码应用基本要求》（GB/T 39786-2021） 二、项目范围及内容 乙方应在客观、公正、科学的基础上，如实反映甲方信息系统的实际情况，不受他方干扰，完整、准确地向甲方提供其检测系统的数据和信息，并分别出具上述系统的商用密码应用安全性评估报告。 1. 项目范围： 系统名称：【新点电子交易平台系统】（三级）。 2. 项目内容： 商用密码应用安全性评估服务； 依据 GB/T 39786-2021《信息安全技术 信息系统密码应用基本要求》，根据检测计划记录和甲方提交的安全体系相关的设计和建设方案历史数据，并结合甲方的业务特点，对甲方的系统进行整体性安全等级符合性分析。 三、测评方式 方式：人员访谈、现场检查、测试、文档审查。 四、测评开始的时间、地点： 测评开始时间：合同签订后5个工作日内（委托方如有特殊要求，甲、乙双方可另行约定）； 测评开始条件：乙方取得系统检测证明。 测评地点：乙方； 测评完成期限：测评开始后2个自然月内（不数据系统整改时间）。 六、费用及其支付方式 本项目总费用共计人民币（大写）60000元（大写）陆万正整。 付款方式按照实际测评情况进行分期支付： 1. 合同签订后且生效后15个工作日内，甲方按照合同总金额的30%向乙方支付第一笔款项，即：人民币18000元（大写）壹万捌仟元整。 2. 符合要求的检测报告出具后乙方按照合同总金额的 70%向乙方支付尾 一方向可提请北京仲裁委员会按其届时有效的仲裁规则进行仲裁。仲裁裁决为终局性的，对双方均具有法律的效力。仲裁费除仲裁机构另有裁决外应由败诉方负担。 十三、其他 (1) 一方如提出中止项目的单方面要求，须经另一方签字确认并赔偿由此而对其造成的损失。 (2) 本协议的未尽事宜，本着测评顺利实施的原则，由双方友好协商解决。 (3) 本协议经甲乙方签字盖章后，立即生效。 (4) 本协议一式四份，甲乙方各执两份，附件具有同等法律效力。 (5) 本协议的修改和补充都应采用书面形式，并经双方委托代理人签字盖章后生效。 甲方：北京丰德启航科技有限公司(盖章) 委托代理人（签字）：徐海 地址： 日期：2024.8.17 乙方：北京市产品质量监督检验研究院(盖章) 委托代理人（签字）：徐海 地址：北京市东城区东直门内大街122号 日期：2024.8.17			

B. 2. 进场记录

表 B-2 进场记录

入场时间	2024 年 10 月 28 日	离场时间	2024 年 10 月 30 日
信息系统责任单位	苏州国泰新点软件有限公司	现场测评实施地点	张家港市沙洲湖科技创新园
现场测评人员	戴晓婧、段昱延		
现场评测过程记录（现场测评签到表、现场照片、对接记录、机房出入记录等）			
			





B.3. 密评活动质量文件

表 B-3 现场测评授权及风险告知

现场测评授权委托书、工具测试授权委托书（含风险告知内容）	
现场测评授权委托书：	工具测试授权委托书（含风险告知内容）：
项目编号：密评 20240041 现场测评授权委托书 BZJJC-JSIL-TT-060-2022 现场测评授权委托书 委托方：苏州国泰新点软件有限公司 受托方：北京市产品质量监督检验研究院 委托方现授权受托方：北京市产品质量监督检验研究院在 2024 年 9 月 9 日至 2024 年 10 月 31 日对委托方的信息系统进行现场测评。 双方就下列事项已达成共识： 1、受托方所实施的测评必须依照经授权方确认的测试方案进行。 2、委托方相关技术人员在测评过程中全程配合受托方测评人员进行测评实施。对于受测系统的任何操作（包括设备的开关操作、配置检查、必要的尝试等），应由委托方配合人员进行，测评人员进行指导和记录。 3、在测评过程中，如需进行工具测试，应由双方共同确认测试工具的安全性，必要时在接入前进行病毒查杀等。 4、在测评过程中，如需对受测系统进行工具测试，必须向委托方提供书面的申请，告知相应的风险，在委托方同意并签字后方可进行。工具测试应严格按照委托方定的时间、地点和范围进行。 5、委托方在测评之前针对测评可能对系统带来的影响和后果已做好充分应对准备和采取适当措施（特别是测评前已做好系统的全面备份）。 6、如受托方在授权许可范围内开展测评活动而对委托方产生任何不良后果，委托方同意承担相关风险。 委托方：苏州国泰新点软件有限公司 受托方：北京市产品质量监督检验研究院 委托方代表人：严汉青 受托方代表人：戴晓娟 2024 年 9 月 9 日 2024 年 9 月 9 日	项目编号：密评 20240041 工具测试授权委托书 BZJJC-JSIL-TT-050-2022 工具测试授权委托书 委托方：苏州国泰新点软件有限公司 受托方：北京市产品质量监督检验研究院 委托方现授权受托方北京市产品质量监督检验研究院对委托方的信息系统进行工具测试。 双方就下列事项已达成共识： 1、测试对象、测试时间 测试对象（设备、服务器、应用系统名称及IP地址/网址） 服务源密码机、签名验签服务器、综合安全网关、时间戳服务器、新点电子签章系统 应用服务器、数据库服务器、签章服务器、新点电子交易平台、通信信道 测试时间段为：2024年9月9日-2024年10月31日 2、测试目的 对网络传输协议进行抓包，分析数据格式与内容，评估通信协议，进行通信密码算法类型检测、数字证书检测、电子签章检测、电子数字信封检测、系统密钥检测。 3、测试工具 测试工具为：网络传输协议分析工具、网络传输密码使用检测工具 测试开始前由双方相关技术人员对设备进行确认并填写测评工具核查记录表。 4、测试风险 本次工具测试不能完全排除测试过程中的风险，委托方已了解工具测试对系统可能会带来的如下影响： 1) 会对被测网络设备或主机造成异常运行或停机的可能； 2) 会对被测主机上的各种服务和应用程序造成异常运行或终止运行的可能； 3) 测试期间，被测主机上的各种服务的运行速度可能会减慢； 4) 测试期间，网络的处理能力和传输速度可能会减慢。 委托方在测试时段之前针对测试可能对系统带来的影响和后果已做好充分应对准备和采取适当措施（特别是测试前已做好系统的全面备份）。 5、测试成果 测试完成后给出测试报告，测试方承诺对所有可能得到的信息保密，不向任何第三方泄露，并在完成报告后交付给用户方，从本机完全删除。 本授权书在测试前提交给受托方，受托方在获得本授权书和签字确认的测试方案后，方能在授权书指定的时段内对指定的对象进行测试活动。 委托方：苏州国泰新点软件有限公司 受托方：北京市产品质量监督检验研究院 委托方代表人：严汉青 受托方代表人：戴晓娟 2024 年 9 月 9 日 2024 年 9 月 9 日

表 B-4 测评方案评审

方案名称	苏州国泰新点软件有限公司密评	评审时间	2024 年 10 月 11 日																																												
测评方案评审记录：	商用密码应用安全性评估方案评审表 项目编号：密评 20240041 北京市产品质量监督检验研究院 《商用密码应用安全性评估方案评审表》 <table><tr><td>项目名称</td><td>国泰新点软件股份有限公司密评项目</td><td>项目负责人</td><td>戴晓婧</td></tr><tr><td>评审时间</td><td>2024.10.11</td><td>记录人</td><td>段昱廷</td></tr><tr><td>参加评审人员</td><td colspan="3">赵艳华、戴晓婧、段昱廷</td></tr><tr><td>评审输入文件</td><td colspan="3">商用密码应用安全性评估方案 调查问卷 固工作计划 其他：_____</td></tr><tr><td>评审意见</td><td colspan="3"> 1、被测系统描述完整并与调研表一致，测评方案中基本信息准确、完整。 2、测评对象选取了被测单位所负责管理的密码设备 5 台、服务器 3 台、数据库 3 个、应用系统 1 个和相关管理制度。 3、测评方法采用实地查看、访谈、配置检查和工具测试能满足相关要求。 4、被测系统选取了 3 项的指标要求，并对不适用项进行了说明。 5、测评人员安排了 2 人，2 人共同负责技术方面测评，1 人负责管理制度方面测评。 (填写要求测评安排方案中的安排情况) 6、测评方案语言描述清晰、准确、易于理解，但有一个错别字，请进行更改。 7、允许按照方案实施。 评审负责人： 2024 年 10 月 11 日 </td></tr><tr><td>修改验证</td><td colspan="3">验证人： 年 月 日</td></tr></table>	项目名称	国泰新点软件股份有限公司密评项目	项目负责人	戴晓婧	评审时间	2024.10.11	记录人	段昱廷	参加评审人员	赵艳华、戴晓婧、段昱廷			评审输入文件	商用密码应用安全性评估方案 调查问卷 固工作计划 其他：_____			评审意见	1、被测系统描述完整并与调研表一致，测评方案中基本信息准确、完整。 2、测评对象选取了被测单位所负责管理的密码设备 5 台、服务器 3 台、数据库 3 个、应用系统 1 个和相关管理制度。 3、测评方法采用实地查看、访谈、配置检查和工具测试能满足相关要求。 4、被测系统选取了 3 项的指标要求，并对不适用项进行了说明。 5、测评人员安排了 2 人，2 人共同负责技术方面测评，1 人负责管理制度方面测评。 (填写要求测评安排方案中的安排情况) 6、测评方案语言描述清晰、准确、易于理解，但有一个错别字，请进行更改。 7、允许按照方案实施。 评审负责人： 2024 年 10 月 11 日			修改验证	验证人： 年 月 日			测评方案确认记录：	商用密码应用安全性评估方案 项目编号：密评 20240041 修订记录 <table><tr><td>版本号</td><td>修订条款及内容</td><td>修订日期</td><td>修订人</td></tr><tr><td>1.0</td><td>创建</td><td>2024.10.11</td><td>戴晓婧</td></tr><tr><td></td><td></td><td></td><td></td></tr><tr><td></td><td></td><td></td><td></td></tr><tr><td></td><td></td><td></td><td></td></tr></table> 审批人 委托方确认	版本号	修订条款及内容	修订日期	修订人	1.0	创建	2024.10.11	戴晓婧												
项目名称	国泰新点软件股份有限公司密评项目	项目负责人	戴晓婧																																												
评审时间	2024.10.11	记录人	段昱廷																																												
参加评审人员	赵艳华、戴晓婧、段昱廷																																														
评审输入文件	商用密码应用安全性评估方案 调查问卷 固工作计划 其他：_____																																														
评审意见	1、被测系统描述完整并与调研表一致，测评方案中基本信息准确、完整。 2、测评对象选取了被测单位所负责管理的密码设备 5 台、服务器 3 台、数据库 3 个、应用系统 1 个和相关管理制度。 3、测评方法采用实地查看、访谈、配置检查和工具测试能满足相关要求。 4、被测系统选取了 3 项的指标要求，并对不适用项进行了说明。 5、测评人员安排了 2 人，2 人共同负责技术方面测评，1 人负责管理制度方面测评。 (填写要求测评安排方案中的安排情况) 6、测评方案语言描述清晰、准确、易于理解，但有一个错别字，请进行更改。 7、允许按照方案实施。 评审负责人： 2024 年 10 月 11 日																																														
修改验证	验证人： 年 月 日																																														
版本号	修订条款及内容	修订日期	修订人																																												
1.0	创建	2024.10.11	戴晓婧																																												

表 B-5 密评报告评审

评审时间	2024 年 12 月 5 日																								
项目编号: 密评 20240041 报告审核记录表 BZ/JC-JSIL-IT-014-2022 《报告审核记录表》 <table><tr><td>项目名称</td><td colspan="3">北京丰德启航科技有限公司密评项目(密评 20240041-1 江苏新点电子交易平台)</td></tr><tr><td>项目负责人</td><td>戴晓婧</td><td>提交人</td><td>戴晓婧</td></tr><tr><td>报告编号</td><td>密评 20240041-1</td><td>报告类型</td><td>密评报告</td></tr><tr><td>一审记录</td><td colspan="3"> (包括: 测评记录是否清晰和详实、测评项的符合情况判断是否准确、是否具有工具扫描和渗透测试结果、安全问题的描述和评判是否准确、测评结论是否准确、文档格式是否符合要求等) 1、2.4.5 中资产与拓扑图中不一致, 比图中少。 2、3.2.3 中工具检查点与测评对象中勾选的不一致。 3、附录 A1 中的结果未描述测评方式。 4、办公内网浏览器与综合安全网关之间的通信信道、办公内网运维客户端与综合安全网关之间的通信信道两条信道是一个服务端证书, 但结果描述的一模一样, 确认一下是否是一个信道, 如果不是, 描述清楚区别。 5、附录 A4 中不可否认性, 是几个关键操作、提供了一个盖公章的截图和一个盖签名章的截图, 但结果描述中只描述了加盖电子公章的过程, 这两个截图是否是一个文件? 确认一下。 审核人:  </td></tr><tr><td>二审记录</td><td colspan="3"> 1. 报告编号是否与基本信息表一样 ☒; 页眉 (奇偶页) 是否一致 ☒. 2. 附录扩展要求是否齐全 ☒; 不适用项是否齐全 ☒. 3. 报告结果是否与渗透、漏扫结果一致 ☒. 其他问题: 1. 目录页新 P1 2. P1 被叫单位名称, 公文替换 3. P10 字体 4. 附录 A B3-P66 字体 审核人:  </td></tr><tr><td>三审记录</td><td colspan="3"> 1. 物理环境防护措施不到位, 降低风险。 2. 拓补图。3. 网络层结果描述 审核人:  </td></tr></table> 报告类型: 等级测评报告、安全性测评报告、风险评估报告、安全评估报告、渗透测试报告、差距分析报告、问题清单及整改建议、密评报告。 北京山产品质量监督检验研究院 第 1 页 共 1 页		项目名称	北京丰德启航科技有限公司密评项目(密评 20240041-1 江苏新点电子交易平台)			项目负责人	戴晓婧	提交人	戴晓婧	报告编号	密评 20240041-1	报告类型	密评报告	一审记录	(包括: 测评记录是否清晰和详实、测评项的符合情况判断是否准确、是否具有工具扫描和渗透测试结果、安全问题的描述和评判是否准确、测评结论是否准确、文档格式是否符合要求等) 1、2.4.5 中资产与拓扑图中不一致, 比图中少。 2、3.2.3 中工具检查点与测评对象中勾选的不一致。 3、附录 A1 中的结果未描述测评方式。 4、办公内网浏览器与综合安全网关之间的通信信道、办公内网运维客户端与综合安全网关之间的通信信道两条信道是一个服务端证书, 但结果描述的一模一样, 确认一下是否是一个信道, 如果不是, 描述清楚区别。 5、附录 A4 中不可否认性, 是几个关键操作、提供了一个盖公章的截图和一个盖签名章的截图, 但结果描述中只描述了加盖电子公章的过程, 这两个截图是否是一个文件? 确认一下。 审核人: 			二审记录	1. 报告编号是否与基本信息表一样 ☒; 页眉 (奇偶页) 是否一致 ☒. 2. 附录扩展要求是否齐全 ☒; 不适用项是否齐全 ☒. 3. 报告结果是否与渗透、漏扫结果一致 ☒. 其他问题: 1. 目录页新 P1 2. P1 被叫单位名称, 公文替换 3. P10 字体 4. 附录 A B3-P66 字体 审核人: 			三审记录	1. 物理环境防护措施不到位, 降低风险。 2. 拓补图。3. 网络层结果描述 审核人: 		
项目名称	北京丰德启航科技有限公司密评项目(密评 20240041-1 江苏新点电子交易平台)																								
项目负责人	戴晓婧	提交人	戴晓婧																						
报告编号	密评 20240041-1	报告类型	密评报告																						
一审记录	(包括: 测评记录是否清晰和详实、测评项的符合情况判断是否准确、是否具有工具扫描和渗透测试结果、安全问题的描述和评判是否准确、测评结论是否准确、文档格式是否符合要求等) 1、2.4.5 中资产与拓扑图中不一致, 比图中少。 2、3.2.3 中工具检查点与测评对象中勾选的不一致。 3、附录 A1 中的结果未描述测评方式。 4、办公内网浏览器与综合安全网关之间的通信信道、办公内网运维客户端与综合安全网关之间的通信信道两条信道是一个服务端证书, 但结果描述的一模一样, 确认一下是否是一个信道, 如果不是, 描述清楚区别。 5、附录 A4 中不可否认性, 是几个关键操作、提供了一个盖公章的截图和一个盖签名章的截图, 但结果描述中只描述了加盖电子公章的过程, 这两个截图是否是一个文件? 确认一下。 审核人: 																								
二审记录	1. 报告编号是否与基本信息表一样 ☒; 页眉 (奇偶页) 是否一致 ☒. 2. 附录扩展要求是否齐全 ☒; 不适用项是否齐全 ☒. 3. 报告结果是否与渗透、漏扫结果一致 ☒. 其他问题: 1. 目录页新 P1 2. P1 被叫单位名称, 公文替换 3. P10 字体 4. 附录 A B3-P66 字体 审核人: 																								
三审记录	1. 物理环境防护措施不到位, 降低风险。 2. 拓补图。3. 网络层结果描述 审核人: 																								

B. 4. 密评人员资格证明

表 B-6 密评人员资格情况

序号	姓名	角色	密评人员考试通过时间
1	戴晓婧	组长、密评报告编制人	2022 年 7 月
2	段昱延	组员	2022 年 7 月
4	赵艳华	密评报告审核人	2022 年 7 月
5	刘振峰	密评报告批准人	2017 年 11 月

表 B-7 密评人员考核成绩证明

戴晓婧成绩证明：



段昱延成绩证明：



赵艳华成绩证明：



刘振峰成绩证明：



B. 5. 系统定级匹配证明

表 B-8 系统定级备案证明

系统等级定级备案名称	未定级
系统等级定级备案时间	-
本系统未进行等级定级备案	